

BAN CƠ YẾU CHÍNH PHỦ  
**HỌC VIỆN KỸ THUẬT MẬT MÃ**



CHUYÊN ĐỀ AN TOÀN HỆ THỐNG THÔNG TIN  
**XÂY DỰNG SOC MINI VỚI PHÁT HIỆN BẤT THƯỜNG BẰNG AI  
TÍCH HỢP TRONG SPLUNK VÀ TỰ ĐỘNG ỨNG PHÓ**

Ngành: An toàn thông tin  
Mã số: 7.48.02.02

*Sinh viên thực hiện:*

**Nguyễn Công Vũ Hà**  
Lớp: AT19E

*Người hướng dẫn:*

**ThS. Cao Minh Tuấn**  
Khoa An toàn thông tin – Học viện Kỹ thuật mật mã

**Hà Nội, 2025**

BAN CƠ YẾU CHÍNH PHỦ  
HỌC VIỆN KỸ THUẬT MẬT MÃ



CHUYÊN ĐỀ AN TOÀN HỆ THỐNG THÔNG TIN  
**XÂY DỰNG SOC MINI VỚI PHÁT HIỆN BẤT THƯỜNG BẰNG AI  
TÍCH HỢP TRONG SPLUNK VÀ TỰ ĐỘNG ỨNG PHÓ**

Ngành: An toàn thông tin  
Mã số: 7.48.02.02

*Sinh viên thực hiện:*

**Nguyễn Công Vũ Hà**  
Lớp: AT19E

*Người hướng dẫn:*

**ThS. Cao Minh Tuấn**  
Khoa An toàn thông tin – Học viện Kỹ thuật mật mã

**Hà Nội, 2025**

# MỤC LỤC

|                                                                                                                |    |
|----------------------------------------------------------------------------------------------------------------|----|
| DANH MỤC KÍ HIỆU VÀ VIẾT TẮT .....                                                                             | i  |
| DANH MỤC HÌNH VẼ .....                                                                                         | ii |
| DANH MỤC BẢNG .....                                                                                            | iv |
| LỜI CẢM ƠN.....                                                                                                | v  |
| LỜI NÓI ĐẦU.....                                                                                               | vi |
| Chương I. Tổng quan về hệ thống SOC và nhu cầu giám sát an ninh mạng.....                                      | 1  |
| 1.1. Tổng quan về an ninh mạng và các mối đe dọa hiện nay .....                                                | 1  |
| 1.2. Khái niệm và vai trò của SOC trong an toàn thông tin.....                                                 | 2  |
| 1.2.1. Khái niệm Trung tâm điều hành an ninh mạng (SOC).....                                                   | 2  |
| 1.2.2. Vai trò của SOC trong bảo đảm an toàn thông tin.....                                                    | 3  |
| 1.2.3. Ví dụ thực tế về vai trò của SOC trong giám sát và ứng phó sự cố .....                                  | 4  |
| 1.2.4. Ý nghĩa của Trung tâm Điều hành An ninh (SOC) đối với Mô hình SOC Mini trong Nghiên cứu và Đào tạo..... | 6  |
| 1.3. Thành phần Cơ bản của Trung tâm Điều hành An ninh (SOC) và Chức năng Chính ....                           | 7  |
| 1.3.1. Con người (People).....                                                                                 | 7  |
| 1.3.2. Quy trình (Process).....                                                                                | 8  |
| 1.3.3. Công nghệ (Technology).....                                                                             | 9  |
| 1.3.4. Chức năng Chính của Trung tâm Điều hành An ninh (SOC).....                                              | 11 |
| 1.4. Giới thiệu về Splunk và vai trò trong thu thập, phân tích log .....                                       | 12 |
| 1.5. Tổng kết Chương I.....                                                                                    | 13 |
| Chương II. Phát hiện bất thường bằng trí tuệ nhân tạo trong SOC .....                                          | 16 |
| 2.1. Khái niệm phát hiện bất thường (Anomaly Detection) .....                                                  | 16 |
| 2.2. Một số phương pháp phát hiện bất thường đơn giản phù hợp cho môi trường nhỏ .....                         | 18 |
| 2.2.1. Phương pháp ngưỡng thống kê (Statistical Threshold) .....                                               | 19 |
| 2.2.2. Phương pháp Isolation Forest.....                                                                       | 20 |
| 2.2.3. Phương pháp Local Outlier Factor (LOF).....                                                             | 22 |
| 2.2.4. So sánh các phương pháp trong bối cảnh SOC mini .....                                                   | 23 |
| 2.3. Các bước cơ bản để xây dựng mô hình phát hiện bất thường .....                                            | 25 |
| 2.3.1. Thu thập Dữ liệu (Data Collection).....                                                                 | 26 |
| 2.3.2. Tiền xử lý Dữ liệu (Data Preprocessing).....                                                            | 26 |
| 2.3.3. Trích Đặc trưng (Feature Extraction) .....                                                              | 27 |
| 2.3.4. Huấn luyện mô hình .....                                                                                | 28 |
| 2.3.5. Đánh giá mô hình .....                                                                                  | 30 |
| 2.4. Ứng dụng cơ bản của Splunk trong phát hiện bất thường .....                                               | 31 |
| 2.4.1. Ngôn ngữ truy vấn SPL trong phân tích và phát hiện bất thường .....                                     | 31 |
| 2.4.2. Cơ chế cảnh báo (Alert) trong Splunk.....                                                               | 32 |
| 2.4.3. Ứng dụng Splunk Machine Learning Toolkit trong phát hiện bất thường .....                               | 33 |

|                                                                                                          |           |
|----------------------------------------------------------------------------------------------------------|-----------|
| 2.5. Tổng kết Chương II .....                                                                            | 34        |
| Chương III. Thiết kế và triển khai mô hình SOC mini.....                                                 | 37        |
| 3.1. Kiến trúc tổng thể SOC mini .....                                                                   | 37        |
| 3.1.1. Lựa chọn mô hình triển khai và công cụ .....                                                      | 37        |
| 3.1.2. Thành phần hệ thống và vai trò của từng máy ảo.....                                               | 37        |
| 3.1.3. Mô hình mạng và luồng dữ liệu log .....                                                           | 38        |
| 3.2. Triển khai Splunk và thu thập dữ liệu log .....                                                     | 40        |
| 3.2.1. Chuẩn bị môi trường và kiểm tra kết nối hệ thống.....                                             | 40        |
| 3.2.2. Cài đặt Splunk Server và Splunk Universal Forwarder.....                                          | 41        |
| a) Cài đặt và cấu hình Splunk Server .....                                                               | 41        |
| b) Cài đặt và cấu hình Splunk Universal Forwarder trên máy được giám sát .....                           | 42        |
| c) Kiểm tra thu thập dữ liệu log trên Splunk Server.....                                                 | 42        |
| 3.3. Thiết kế dữ liệu log phục vụ giám sát và phát hiện bất thường.....                                  | 44        |
| 3.3.1. Cấu trúc chung của một bản ghi Windows Event Log trong Splunk .....                               | 44        |
| 3.3.2. Các trường thông tin quan trọng trong Security Event Log .....                                    | 45        |
| 3.3.3. Các trường thông tin quan trọng trong System Event Log.....                                       | 46        |
| 3.3.4. Định hướng sử dụng dữ liệu log cho phát hiện bất thường .....                                     | 47        |
| 3.3.5. Các kịch bản giám sát trong SOC mini .....                                                        | 48        |
| a) Kịch bản giám sát đăng nhập thất bại liên tiếp (Login failure monitoring) .....                       | 48        |
| b) Kịch bản giám sát truy cập SSH bất thường .....                                                       | 48        |
| c) Kịch bản giám sát dấu hiệu dò quét cổng dịch vụ (Port scan monitoring).....                           | 49        |
| 1, Mục tiêu giám sát .....                                                                               | 49        |
| 2, Nguồn dữ liệu sử dụng .....                                                                           | 49        |
| 3, Phân tích nguyên nhân chỉ ghi nhận cổng 22 .....                                                      | 50        |
| 3.4. Pipeline phát hiện bất thường và phản ứng cơ bản trong SOC mini .....                               | 51        |
| 3.4.1. Pipeline xử lý dữ liệu và phát hiện bất thường trong SOC mini .....                               | 51        |
| 3.4.2. Phân tích log và phát hiện bất thường dựa trên hành vi .....                                      | 52        |
| 3.4.3. Hiển thị, giám sát và hỗ trợ phản ứng trong SOC mini .....                                        | 53        |
| 3.5. Tổng kết Chương 3 .....                                                                             | 54        |
| <b>CHƯƠNG IV. THỰC NGHIỆM MÔ HÌNH SOC MINI VỚI PHÁT HIỆN BẤT THƯỜNG BẰNG AI VÀ TỰ ĐỘNG ỨNG PHÓ .....</b> | <b>55</b> |
| 4.1. Mục tiêu thực nghiệm.....                                                                           | 55        |
| 4.2. Mô hình và môi trường thực nghiệm.....                                                              | 55        |
| 4.2.1. Mô hình tổng thể SOC mini .....                                                                   | 55        |
| 4.2.2. Môi trường thực nghiệm.....                                                                       | 56        |
| 4.3. Thiết kế kịch bản thực nghiệm .....                                                                 | 56        |
| 4.3.1. Giai đoạn 1 – Hệ thống hoạt động bình thường (Baseline) .....                                     | 57        |
| 4.3.2. Huấn luyện mô hình hành vi bình thường bằng học máy.....                                          | 57        |

|                                                                                              |    |
|----------------------------------------------------------------------------------------------|----|
| 4.3.3. Giai đoạn 2 – Kích hoạt ransomware và phát sinh bất thường.....                       | 59 |
| 4.4. Chuỗi logic phát hiện bất thường trong SOC mini.....                                    | 60 |
| 4.4.1. Bước 1 – AI phát hiện bất thường.....                                                 | 61 |
| 4.4.2. Bước 2 – AI trả kết quả cho hệ thống Splunk.....                                      | 61 |
| 4.4.3. Bước 3 – Splunk kích hoạt cảnh báo.....                                               | 63 |
| a, Cấu hình cảnh báo.....                                                                    | 64 |
| b, Nguyên lý hoạt động của cảnh báo.....                                                     | 65 |
| c, Ý nghĩa trong mô hình SOC mini.....                                                       | 65 |
| 4.4.4. Bước 4 – Cấu hình phản ứng tự động và gửi cảnh báo về Telegram (SOAR mức cơ bản)..... | 65 |
| 4.5. Đánh giá kết quả thực nghiệm.....                                                       | 67 |
| 4.6. Hạn chế và hướng phát triển.....                                                        | 67 |
| 4.7. Tổng kết chương 4.....                                                                  | 67 |
| KẾT LUẬN.....                                                                                | 69 |
| TÀI LIỆU THAM KHẢO.....                                                                      | 70 |
| PHỤ LỤC.....                                                                                 | 71 |

## DANH MỤC KÍ HIỆU VÀ VIẾT TẮT

|                       |                                                                                           |
|-----------------------|-------------------------------------------------------------------------------------------|
| SOC                   | Security Operations Center – Trung tâm điều hành an ninh thông tin                        |
| SIEM                  | Security Information and Event Management – Hệ thống quản lý và phân tích sự kiện an ninh |
| EDR                   | Endpoint Detection and Response – Giải pháp phát hiện và phản ứng trên máy trạm           |
| VM                    | Virtual Machine – Máy ảo                                                                  |
| IP                    | Internet Protocol – Giao thức Internet                                                    |
| TCP                   | Transmission Control Protocol – Giao thức truyền tải                                      |
| Sysmon                | System Monitor – Công cụ giám sát sự kiện hệ thống Windows                                |
| EventCode             | Mã định danh loại sự kiện trong Sysmon                                                    |
| Process Create        | Sự kiện tạo tiến trình trong hệ điều hành                                                 |
| Registry              | Cơ sở dữ liệu cấu hình của hệ điều hành Windows                                           |
| Persistence           | Cơ chế duy trì tồn tại của mã độc trên hệ thống                                           |
| Malware               | Phần mềm độc hại                                                                          |
| Ransomware            | Mã độc tống tiền                                                                          |
| WannaCry              | Mã độc ransomware khai thác lỗ hổng SMB                                                   |
| Log                   | Nhật ký sự kiện hệ thống                                                                  |
| Alert                 | Cảnh báo an ninh                                                                          |
| Webhook               | Cơ chế gửi dữ liệu tự động theo sự kiện                                                   |
| API                   | Application Programming Interface – Giao diện lập trình ứng dụng                          |
| Machine Learning (ML) | Học máy                                                                                   |
| Anomaly               | Hành vi bất thường                                                                        |

## DANH MỤC HÌNH VẼ

|                                                                                               |    |
|-----------------------------------------------------------------------------------------------|----|
| Hình 1: Mô hình tổng quan kiến trúc và quy trình vận hành của SOC .....                       | 3  |
| Hình 2: Giao diện giám sát và xử lý cảnh báo của SOC .....                                    | 5  |
| Hình 3: Quy trình xử lý sự cố an ninh trong SOC .....                                         | 8  |
| Hình 4: Kiến trúc công nghệ SOC .....                                                         | 10 |
| Hình 5: Kiến trúc tổng quát của Splunk trong thu thập và phân tích log .....                  | 12 |
| Hình 6: Minh họa khái niệm phát hiện bất thường trong dữ liệu an ninh .....                   | 17 |
| Hình 7: Phát hiện bất thường dựa trên ngưỡng thống kê trong chuỗi dữ liệu .....               | 19 |
| Hình 8: Nguyên lý cô lập dữ liệu bất thường của thuật toán Isolation Forest .....             | 21 |
| Hình 9: Minh họa phát hiện bất thường dựa trên mật độ cục bộ bằng LOF .....                   | 23 |
| Hình 10: Quy trình cơ bản xây dựng mô hình phát hiện bất thường trong SOC .....               | 25 |
| Hình 11: Minh họa quá trình huấn luyện mô hình phát hiện bất thường .....                     | 29 |
| Hình 12: Minh họa quá trình đánh giá mô hình phát hiện bất thường trong SOC .....             | 30 |
| Hình 13: Ứng dụng Splunk trong phân tích log, phát hiện bất thường và sinh cảnh báo .....     | 31 |
| Hình 15: Thiết lập và kích hoạt cảnh báo trong Splunk .....                                   | 33 |
| Hình 16: Ứng dụng Splunk Machine Learning Toolkit trong phát hiện bất thường .....            | 34 |
| Hình 17: Kiến trúc tổng thể mô hình SOC mini trong môi trường máy ảo .....                    | 38 |
| Hình 18: Mô hình mạng thực nghiệm của hệ thống SOC mini .....                                 | 39 |
| Hình 18: Mô hình mạng thực nghiệm của hệ thống SOC mini .....                                 | 40 |
| Hình 19: Kiểm tra kết nối mạng giữa các máy ảo trong mô hình SOC mini .....                   | 41 |
| Hình 20: Bản ghi Windows Security Event ID 4625 – Sự kiện đăng nhập thất bại .....            | 43 |
| Hình 20: Bản ghi Windows Security Event ID 4625 – Sự kiện đăng nhập thất bại .....            | 44 |
| Hình 20: Bản ghi Windows Security Event ID 4625 – Sự kiện đăng nhập thất bại .....            | 45 |
| Hình 21: Một sự kiện trong system được ghi lại .....                                          | 46 |
| Hình 23: Kết quả truy vấn của một cuộc dò quét mật khẩu được ghi lại .....                    | 48 |
| Hình 24: Kết quả truy vấn của việc truy cập SSH bất thường .....                              | 49 |
| Hình 25: Kết quả truy vấn với EventCode=3 .....                                               | 50 |
| Hình 26: Kiến trúc pipeline thu thập, phân tích log và giám sát trong hệ thống SOC mini ..... | 51 |
| Hình 27. Mô hình thực nghiệm .....                                                            | 55 |
| Hình 28. Sysmon đang hoạt động trên Windows 10 .....                                          | 56 |
| Hình 29. Cài AI Toolkit thành công .....                                                      | 56 |
| Hình 30. Log hệ thống trong giai đoạn bình thường .....                                       | 57 |
| Hình 31. Biểu đồ số lượng sự kiện ổn định theo thời gian .....                                | 57 |
| Hình 32. Dataset hành vi bình thường dùng cho huấn luyện .....                                | 58 |
| Hình 33. AI học được outlier .....                                                            | 58 |
| Hình 34. AI học thành công hành vi bình thường .....                                          | 59 |

|                                                                |    |
|----------------------------------------------------------------|----|
| Hình 35. Lưu model AI .....                                    | 59 |
| Hình 36. Mốc thời gian kích hoạt WannaCry.exe .....            | 60 |
| Hình 37. Biểu đồ số lượng sự kiện tăng đột biến .....          | 60 |
| Hình 38. Biểu đồ anomaly score theo thời gian .....            | 61 |
| Hình 39. Điều tra log với EventID=1 .....                      | 61 |
| Hình 40. Điều tra log với EventID=11 .....                     | 62 |
| Hình 41. Research lại sự kiện để tạo alert .....               | 63 |
| Hình 42. Cấu hình alert.....                                   | 64 |
| Hình 43. Tạo Telegram Bot và thông tin bot token.....          | 66 |
| Hình 44: Cấu hình alert action gửi Telegram trong Splunk ..... | 66 |
| Hình 45. Thông báo cảnh báo được gửi tới Telegram.....         | 67 |



## DANH MỤC BẢNG

|                                                                                        |    |
|----------------------------------------------------------------------------------------|----|
| Bảng 1: Phân loại bất thường và ví dụ trong an ninh mạng .....                         | 18 |
| Bảng 2: So sánh phương pháp phát hiện bất thường phù hợp cho môi trường SOC mini ..... | 24 |
| Bảng 3: Các Đặc trưng Phổ biến trong Phát hiện Bất thường từ Log An ninh .....         | 28 |

## **LỜI CẢM ƠN**

Trong quá trình thực hiện đồ án chuyên đề này, tôi đã nhận được sự giúp đỡ tận tình của cán bộ hướng dẫn là ThS. Cao Minh Tuấn – Giảng viên Khoa An toàn thông tin Học viện Kỹ thuật Mật mã, sự quan tâm sâu sát của cán bộ Hệ quản lý học viên quốc tế, sự động viên của người thân và bạn bè.

Xin cảm ơn tất cả mọi người đã tạo những điều kiện tốt nhất để tôi hoàn thành đồ án tốt nghiệp này!

## **SINH VIÊN THỰC HIỆN ĐỒ ÁN**

Nguyễn Công Vũ Hà

## LỜI NÓI ĐẦU

Trong những năm gần đây, cùng với sự phát triển mạnh mẽ của công nghệ thông tin và quá trình chuyển đổi số diễn ra sâu rộng trong nhiều lĩnh vực, không gian mạng đã trở thành môi trường hoạt động quan trọng của các tổ chức, doanh nghiệp và cơ quan nhà nước. Song song với những lợi ích mà công nghệ mang lại, các mối đe dọa an ninh mạng cũng ngày càng gia tăng về quy mô, tần suất và mức độ tinh vi. Các hình thức tấn công như dò quét hệ thống, tấn công brute-force, xâm nhập trái phép, đánh cắp dữ liệu hay phá hoại dịch vụ xuất hiện ngày càng phổ biến, đặt ra yêu cầu cấp thiết về việc giám sát, phát hiện sớm và xử lý kịp thời các sự cố an ninh mạng.

Trong bối cảnh đó, Trung tâm điều hành an ninh mạng (Security Operations Center – SOC) đã trở thành một mô hình quan trọng, đóng vai trò tập trung trong việc thu thập, phân tích dữ liệu an ninh, phát hiện các dấu hiệu bất thường và điều phối hoạt động ứng phó sự cố. Việc xây dựng SOC thường gắn liền với các hệ thống quản lý và phân tích sự kiện an ninh (Security Information and Event Management – SIEM), cho phép thu thập log từ nhiều nguồn khác nhau và hỗ trợ phân tích, tương quan sự kiện. Trong số các nền tảng SIEM hiện nay, Splunk là một giải pháp được sử dụng rộng rãi nhờ khả năng xử lý dữ liệu lớn, linh hoạt trong phân tích log và hỗ trợ mở rộng các kỹ thuật phân tích nâng cao.

Cùng với sự phát triển của SIEM, việc ứng dụng trí tuệ nhân tạo trong lĩnh vực an ninh mạng, đặc biệt là các phương pháp phát hiện bất thường (Anomaly Detection), ngày càng được quan tâm nhằm khắc phục những hạn chế của các phương pháp phát hiện dựa trên luật hoặc chữ ký truyền thống. Các mô hình phát hiện bất thường cho phép nhận diện những hành vi sai lệch so với trạng thái hoạt động bình thường của hệ thống, từ đó hỗ trợ phát hiện các hình thức tấn công mới hoặc chưa được định nghĩa trước.

Tuy nhiên, trên thực tế, việc triển khai một hệ thống SOC hoàn chỉnh thường đòi hỏi chi phí đầu tư lớn, hạ tầng phức tạp và nguồn nhân lực có trình độ chuyên môn cao, gây khó khăn cho các tổ chức nhỏ cũng như trong môi trường đào tạo và nghiên cứu. Nhiều nghiên cứu và tài liệu hiện có chủ yếu tập trung vào các mô hình SOC ở quy mô doanh nghiệp, trong khi các mô hình SOC thu nhỏ phục vụ mục đích học tập, thử nghiệm và minh họa quy trình vận hành vẫn còn hạn chế. Do đó, việc xây dựng một mô hình SOC mini với mức độ triển khai cơ bản nhưng vẫn thể hiện được các chức năng cốt lõi như giám sát, phát hiện bất thường và phản ứng sự cố là cần thiết và có ý nghĩa thực tiễn.

Xuất phát từ thực tiễn đó, đề án được thực hiện nhằm mục đích tìm hiểu và bước đầu tiếp cận các vấn đề liên quan đến giám sát, phát hiện và ứng phó sự cố an ninh mạng trong mô hình SOC ở quy mô nhỏ. Trên cơ sở nghiên cứu tổng quan

về SOC, SIEM và Splunk, đồ án tập trung khảo sát và áp dụng một số phương pháp phát hiện bất thường đơn giản dựa trên trí tuệ nhân tạo, đồng thời xây dựng cơ chế cảnh báo và phản ứng tự động ở mức cơ bản nhằm minh họa quy trình vận hành của một SOC.

Mục tiêu của đồ án là hệ thống hóa các kiến thức nền tảng về SOC và vai trò của Splunk trong giám sát an ninh mạng; tìm hiểu và áp dụng các phương pháp phát hiện bất thường phù hợp với môi trường thử nghiệm nhỏ; thiết kế và triển khai mô hình SOC mini sử dụng Splunk để thu thập và phân tích log; đồng thời xây dựng và thử nghiệm cơ chế phản ứng tự động đơn giản nhằm củng cố các kiến thức lý thuyết đã nghiên cứu thông qua thực nghiệm.

Sau khoảng thời gian thực hiện đồ án, các mục tiêu cơ bản đã đạt được, thể hiện qua việc xây dựng được mô hình SOC mini, triển khai thử nghiệm thu thập và phân tích log, phát hiện bất thường và thực hiện phản ứng tự động ở mức đơn giản. Tuy nhiên, an ninh mạng và trí tuệ nhân tạo là những lĩnh vực có phạm vi nghiên cứu rộng và tính phức tạp cao, trong khi thời gian và điều kiện thực hiện đồ án còn hạn chế, do đó nội dung nghiên cứu khó tránh khỏi những thiếu sót và chưa thể bao quát đầy đủ các khía cạnh nâng cao. Tác giả rất mong nhận được sự góp ý của các thầy cô và các bạn học viên để đồ án được hoàn thiện hơn và có thể tiếp tục phát triển trong các nghiên cứu tiếp theo.

## **SINH VIÊN THỰC HIỆN ĐỒ ÁN**

Nguyễn Công Vũ Hà

# **Chương I. Tổng quan về hệ thống SOC và nhu cầu giám sát an ninh mạng**

## **1.1. Tổng quan về an ninh mạng và các mối đe dọa hiện nay**

Trong bối cảnh chuyển đổi số đang diễn ra mạnh mẽ trên phạm vi toàn cầu, các hệ thống công nghệ thông tin ngày càng đóng vai trò quan trọng trong hoạt động của cơ quan nhà nước, doanh nghiệp và đời sống xã hội. Việc mở rộng sử dụng các dịch vụ trực tuyến, nền tảng điện toán đám mây, Internet vạn vật và các ứng dụng dữ liệu lớn đã mang lại nhiều lợi ích về hiệu quả và khả năng kết nối, song đồng thời cũng làm gia tăng đáng kể các nguy cơ mất an toàn thông tin. An ninh mạng vì vậy đã trở thành một trong những thách thức lớn, ảnh hưởng trực tiếp đến tính bảo mật, toàn vẹn và sẵn sàng của các hệ thống thông tin.

Các số liệu thống kê trong những năm gần đây cho thấy tình hình an ninh mạng đang diễn biến theo chiều hướng ngày càng phức tạp. Theo báo cáo Internet Crime Report năm 2024 của Cục Điều tra Liên bang Hoa Kỳ (FBI), trong năm 2023 đã ghi nhận hơn 859.000 đơn tố cáo liên quan đến tội phạm mạng, với tổng thiệt hại kinh tế vượt mức 16 tỷ đô la Mỹ, tăng hơn 30% so với năm trước đó. Sự gia tăng mạnh về thiệt hại tài chính phản ánh xu hướng các cuộc tấn công mạng không chỉ nhắm vào cá nhân mà còn tập trung vào các tổ chức, doanh nghiệp và hạ tầng quan trọng, trong đó nhiều cuộc tấn công có tính tổ chức cao và được thực hiện một cách có chủ đích.

Tại Việt Nam, tình hình an ninh mạng cũng ghi nhận nhiều diễn biến đáng lo ngại. Theo các báo cáo tổng hợp về an toàn thông tin trong năm 2024 và nửa đầu năm 2025, Việt Nam đã ghi nhận hàng trăm triệu bản ghi dữ liệu bị rò rỉ, cùng hàng triệu tài khoản người dùng bị lộ thông tin. Riêng trong nửa đầu năm 2025, số lượng tài khoản bị đánh cắp và dữ liệu bị rò rỉ tăng hơn 20% so với cùng kỳ năm trước. Các con số này cho thấy mức độ khai thác lỗ hổng hệ thống và yếu tố con người ngày càng gia tăng, đồng thời phản ánh thực tế rằng nhiều hệ thống thông tin vẫn chưa được giám sát và bảo vệ một cách hiệu quả.

Bên cạnh các sự cố rò rỉ dữ liệu, các hình thức tấn công chủ động như tấn công từ chối dịch vụ phân tán, dò quét hệ thống, tấn công brute-force và phát tán mã độc cũng gia tăng đáng kể. Thống kê trong năm 2025 cho thấy số lượng các cuộc tấn công DDoS tại Việt Nam lên tới hàng trăm nghìn vụ trong một năm, với xu hướng nhắm vào các hệ thống dịch vụ công trực tuyến, cổng thông tin điện tử và các doanh nghiệp vừa và nhỏ. Điều này cho thấy các đối tượng tấn công ngày càng mở rộng phạm vi mục tiêu, không chỉ tập trung vào các hệ thống lớn mà còn khai thác những hệ thống có mức độ bảo mật thấp hơn.

Sự gia tăng về số lượng và mức độ tinh vi của các mối đe dọa mạng cho thấy các biện pháp bảo mật truyền thống như tường lửa hay phần mềm chống mã độc đơn lẻ không còn đủ khả năng đáp ứng yêu cầu bảo vệ hệ thống trong môi trường hiện đại. Nhiều cuộc tấn công được thực hiện theo từng giai đoạn, có độ trễ và sử dụng các kỹ thuật che giấu nhằm tránh bị phát hiện ngay lập tức. Điều này làm nổi bật nhu cầu phải giám sát liên tục, phân tích hành vi và phát hiện các dấu hiệu bất thường trong quá trình vận hành hệ thống.

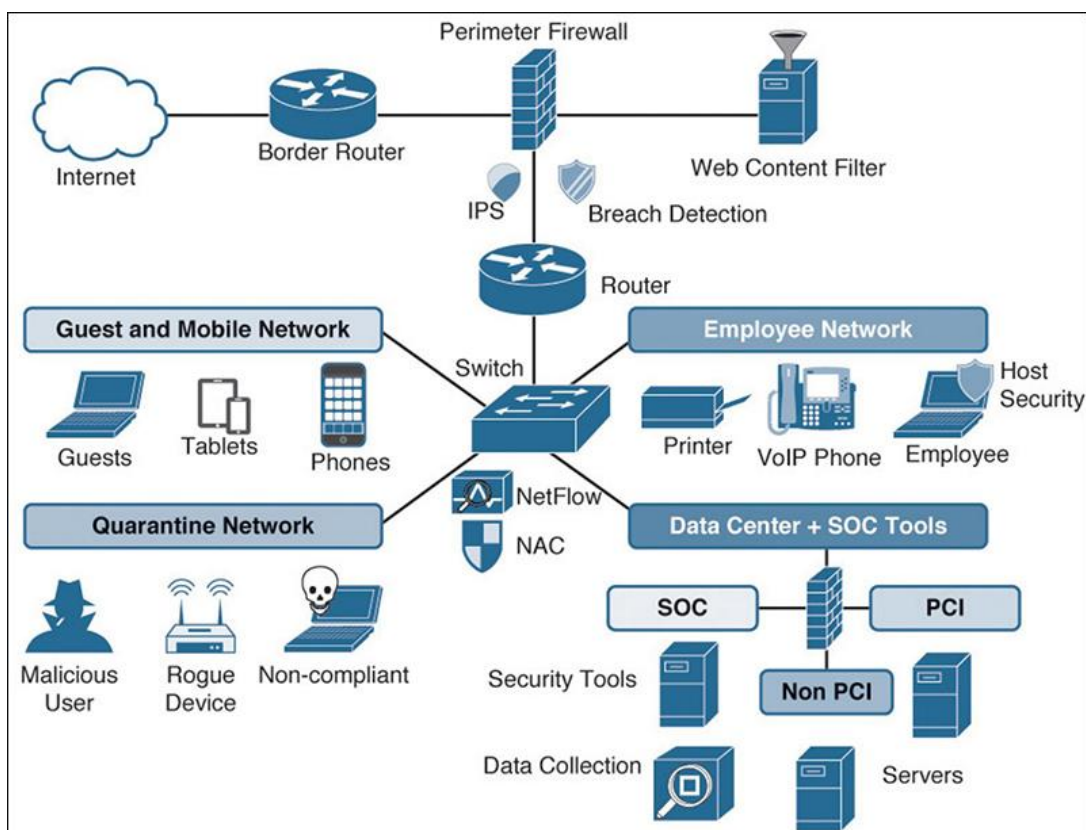
Trước thực tế đó, việc xây dựng các giải pháp giám sát an ninh mạng mang tính tổng thể, có khả năng thu thập và phân tích dữ liệu từ nhiều nguồn khác nhau, trở thành yêu cầu cấp thiết. Các mô hình vận hành như Trung tâm điều hành an ninh mạng (SOC) cho phép tập trung hóa việc giám sát, phân tích sự kiện an ninh và hỗ trợ ra quyết định ứng phó kịp thời. Việc nghiên cứu và triển khai các mô hình SOC, kể cả ở quy mô thu nhỏ, không chỉ có ý nghĩa thực tiễn trong việc nâng cao năng lực bảo đảm an toàn thông tin mà còn đóng vai trò quan trọng trong công tác đào tạo và nghiên cứu, góp phần chuẩn bị nguồn nhân lực cho lĩnh vực an ninh mạng trong bối cảnh hiện nay.

## **1.2. Khái niệm và vai trò của SOC trong an toàn thông tin**

### *1.2.1. Khái niệm Trung tâm điều hành an ninh mạng (SOC)*

Trung tâm điều hành an ninh mạng (Security Operations Center – SOC) là một mô hình tổ chức và kỹ thuật được thiết kế nhằm giám sát, phát hiện, phân tích và ứng phó với các sự cố an ninh thông tin trong một hệ thống công nghệ thông tin. SOC đóng vai trò là đầu mối tập trung, nơi tiếp nhận và xử lý dữ liệu an ninh được thu thập từ nhiều nguồn khác nhau như máy chủ, máy trạm, thiết bị mạng, ứng dụng và các hệ thống bảo mật chuyên dụng. Thông qua việc phân tích dữ liệu log và sự kiện an ninh, SOC giúp tổ chức duy trì khả năng quan sát liên tục đối với trạng thái an toàn của hệ thống.

Về bản chất, SOC không chỉ đơn thuần là một hệ thống kỹ thuật mà còn bao gồm con người, quy trình và công nghệ. Các hoạt động của SOC thường được vận hành theo quy trình chuẩn, bao gồm giám sát liên tục, phát hiện sự cố, phân tích nguyên nhân, đánh giá mức độ ảnh hưởng và triển khai các biện pháp ứng phó phù hợp. Trong các mô hình SOC hiện đại, nền tảng SIEM thường được sử dụng làm trung tâm thu thập và phân tích dữ liệu, kết hợp với các công cụ hỗ trợ điều tra và tự động hóa phản ứng sự cố.



Hình 1: Mô hình tổng quan kiến trúc và quy trình vận hành của SOC

Hình 1 minh họa kiến trúc tổng quát của một SOC điển hình, trong đó các nguồn log và sự kiện an ninh từ hệ thống máy chủ, máy trạm, thiết bị mạng và ứng dụng được thu thập tập trung về nền tảng SIEM. Dữ liệu sau khi được chuẩn hóa và phân tích sẽ phục vụ cho quá trình phát hiện bất thường và sinh cảnh báo. Các cảnh báo này được chuyển đến đội ngũ SOC để tiến hành phân tích sâu và triển khai các biện pháp ứng phó. Mô hình này cho thấy SOC đóng vai trò là trung tâm kết nối giữa dữ liệu kỹ thuật và hoạt động vận hành an ninh, giúp đảm bảo khả năng giám sát và phản ứng kịp thời trước các mối đe dọa.

### 1.2.2. Vai trò của SOC trong bảo đảm an toàn thông tin

Trong bối cảnh các mối đe dọa an ninh mạng ngày càng gia tăng về số lượng và mức độ tinh vi, SOC giữ vai trò then chốt trong việc nâng cao năng lực phòng thủ của tổ chức. Trước hết, SOC giúp duy trì khả năng giám sát liên tục hệ thống công nghệ thông tin thông qua việc phân tích log và sự kiện an ninh theo thời gian thực hoặc gần thời gian thực. Điều này cho phép phát hiện sớm các dấu hiệu bất thường, từ đó giảm thiểu thời gian tồn tại của các cuộc tấn công trong hệ thống.

Một vai trò quan trọng khác của SOC là hỗ trợ phân tích và điều tra sự cố an ninh. Khi một cảnh báo được phát sinh, SOC tiến hành tương quan các sự kiện liên quan, xác định nguồn gốc, phạm vi ảnh hưởng và mức độ nghiêm trọng của sự cố. Ví dụ, trong trường hợp xảy ra tấn công brute-force vào dịch vụ SSH, SOC

có thể phân tích log đăng nhập thất bại, địa chỉ IP nguồn, tần suất truy cập và thời gian xảy ra sự kiện để xác định đây là hành vi tấn công có chủ đích hay chỉ là lỗi cấu hình thông thường. Quá trình phân tích này giúp tránh các phản ứng sai lệch và nâng cao hiệu quả xử lý sự cố.

Ngoài ra, SOC còn đóng vai trò quan trọng trong việc hỗ trợ ứng phó và khắc phục sự cố. Thông qua các quy trình phản ứng đã được xây dựng sẵn, SOC có thể phối hợp với các bộ phận liên quan để cô lập hệ thống bị tấn công, ngăn chặn sự lan rộng của mối đe dọa và khôi phục hoạt động bình thường. Trong các mô hình SOC hiện đại, nhiều hoạt động ứng phó có thể được tự động hóa nhằm rút ngắn thời gian xử lý và giảm phụ thuộc vào can thiệp thủ công.

### *1.2.3. Ví dụ thực tế về vai trò của SOC trong giám sát và ứng phó sự cố*

Thực tiễn hoạt động an ninh mạng hiện đại đã chứng minh Trung tâm Điều hành An ninh (SOC) đóng vai trò là tuyến phòng thủ và phản ứng then chốt, chịu trách nhiệm chính trong việc phát hiện, phân tích và giảm thiểu các mối đe dọa. Nhiều sự cố an ninh mạng nghiêm trọng, gây tổn thất lớn về tài chính và danh tiếng, đã được phát hiện và giảm thiểu thiệt hại đáng kể nhờ các quy trình và khả năng giám sát liên tục của SOC.

Trong bối cảnh các cuộc tấn công ngày càng tinh vi, đặc biệt là các cuộc tấn công bằng mã độc tống tiền (ransomware) nhằm vào hệ thống doanh nghiệp, SOC thường là đơn vị đầu tiên xác định được các dấu hiệu bất thường. Các dấu hiệu này được thu thập và phân tích từ nhiều nguồn dữ liệu (log, lưu lượng mạng, thông tin điểm cuối) và bao gồm: sự gia tăng đột biến về lưu lượng truy cập mạng không rõ nguyên nhân, các hành vi truy cập trái phép vào tài nguyên nhạy cảm hoặc sự xuất hiện của các tiến trình lạ thực hiện hành vi mã hóa dữ liệu hàng loạt. Khả năng phát hiện sớm này cho phép tổ chức thực hiện các biện pháp khẩn cấp như ngắt kết nối các máy chủ hoặc máy trạm bị ảnh hưởng khỏi mạng chính. Đây là một hành động mang tính quyết định nhằm hạn chế phạm vi lây lan của mã độc, ngăn chặn thiệt hại lan rộng và bảo vệ tính toàn vẹn của dữ liệu hệ thống.





Hình 2: Giao diện giám sát và xử lý cảnh báo của SOC

Hình 2: Giao diện giám sát và xử lý cảnh báo của SOC thể hiện rõ ràng môi trường làm việc điển hình của các chuyên viên an ninh. Giao diện này, thường là bảng điều khiển (dashboard) của một hệ thống Quản lý Sự kiện và Thông tin An ninh (SIEM) hoặc nền tảng Ứng phó và Phân tích Mối đe dọa (SOAR), đóng vai trò trung tâm trong quy trình giám sát và ứng phó.

Trên giao diện này, hàng tỷ sự kiện an ninh được chuẩn hóa và tổng hợp, sau đó được trực quan hóa thành các cảnh báo có ý nghĩa. Việc các sự kiện và cảnh báo được hiển thị tập trung cho phép nhân viên SOC thực hiện các chức năng cốt lõi sau:

1. Theo dõi Trạng thái Hệ thống và Mức độ Rủi ro: Bảng điều khiển cung cấp cái nhìn tổng thể theo thời gian thực về tình trạng an ninh của cơ sở hạ tầng. Nó cho phép nhân viên SOC theo dõi các chỉ số hiệu suất bảo mật chính (KPIs), nhận diện các khu vực có rủi ro cao hoặc các lỗ hổng đang bị khai thác.
2. Đánh giá Mức độ Nghiêm trọng và Ưu tiên: Hệ thống tự động phân loại mức độ nghiêm trọng của các sự cố (ví dụ: Critical, High, Medium). Dựa trên sự trực quan hóa này, nhân viên SOC có thể nhanh chóng nhận diện các sự kiện quan trọng nhất cần được ưu tiên xử lý ngay lập tức, từ đó tối ưu hóa việc phân bổ nguồn lực và giảm thiểu thời gian phản ứng (Mean Time To Respond – MTTR).
3. Quản lý Vòng đời Sự cố: Giao diện không chỉ hiển thị cảnh báo mới mà còn lưu trữ lịch sử xử lý, trạng thái hiện tại (ví dụ: Pending, Investigating, Closed) và người chịu trách nhiệm đối với từng sự cố. Điều này đảm bảo tính minh bạch, hỗ trợ cho quá trình kiểm toán nội bộ và cho phép đội ngũ SOC liên tục đánh giá và cải tiến hiệu quả quy trình ứng phó theo thời gian.

Tóm lại, việc sử dụng các bảng điều khiển trực quan như mô tả trong Hình 2 là yếu tố then chốt giúp nâng cao hiệu quả giám sát và ứng phó của SOC. Công

cụ này chuyển đổi dữ liệu thô thành thông tin có thể hành động, cho phép đội ngũ an ninh phản ứng một cách nhanh chóng, có tổ chức và chiến lược đối với các mối đe dọa mạng.

#### *1.2.4. Ý nghĩa của Trung tâm Điều hành An ninh (SOC) đối với Mô hình SOC Mini trong Nghiên cứu và Đào tạo*

Trong bối cảnh chi phí và độ phức tạp của hạ tầng an ninh mạng doanh nghiệp ngày càng tăng, việc triển khai một Trung tâm Điều hành An ninh (SOC) ở quy mô đầy đủ trong môi trường đào tạo và nghiên cứu thường gặp nhiều hạn chế đáng kể về ngân sách, giấy phép phần mềm chuyên dụng và nguồn lực kỹ thuật. Tuy nhiên, khái niệm và quy trình hoạt động của SOC vẫn là nền tảng cốt lõi không thể thiếu trong giáo dục an ninh mạng.

Mô hình SOC mini (Miniature Security Operations Center) ra đời nhằm giải quyết những thách thức này. Dựa trên việc tinh giản và tích hợp các công cụ mã nguồn mở hoặc công cụ miễn phí, mô hình SOC mini vẫn có khả năng tái hiện đầy đủ các chức năng vận hành cốt lõi của một SOC thương mại, bao gồm:

- Thu thập và Chuẩn hóa Log (Log Aggregation and Normalization): Mô phỏng việc thu thập dữ liệu nhật ký từ nhiều nguồn khác nhau (máy chủ, tường lửa, hệ thống phát hiện xâm nhập) vào một kho lưu trữ tập trung.
- Phân tích Sự kiện và Tương quan (Event Analysis and Correlation): Sử dụng các công cụ Quản lý Thông tin và Sự kiện An ninh (SIEM) quy mô nhỏ để xử lý và liên kết các sự kiện log nhằm phát hiện các chuỗi hành vi đáng ngờ.
- Phát hiện Bất thường và Cảnh báo (Anomaly Detection and Alerting): Áp dụng các quy tắc phát hiện để tạo ra các cảnh báo (alerts) khi phát hiện dấu hiệu xâm nhập, lạm dụng hoặc cấu hình sai.
- Phản ứng và Khắc phục Sự cố (Incident Response and Remediation): Mô phỏng các quy trình xử lý theo kịch bản ứng phó sự cố (playbooks) cơ bản.

Thông qua việc vận hành mô hình SOC mini, người học có thể tiếp cận trực tiếp với quy trình vận hành và vòng đời sự cố của SOC một cách thực tế. Điều này không chỉ giúp củng cố kiến thức lý thuyết mà còn tạo cơ hội rèn luyện các kỹ năng thực hành quan trọng như: Phân tích dữ liệu log chuyên sâu, hiểu rõ mối liên hệ giữa các sự kiện kỹ thuật và các quyết định chiến lược an ninh, và xử lý các tình huống sự cố mạng (incident handling) trong một môi trường thực nghiệm có kiểm soát.

Chính vì những lý do trên, việc nghiên cứu kỹ lưỡng về khái niệm, cấu trúc, và vai trò của SOC không chỉ mang ý nghĩa lý thuyết thuần túy mà còn là cơ sở nền tảng quan trọng cho việc thiết kế, xây dựng và triển khai mô hình SOC mini trong phạm vi các đề tài nghiên cứu hoặc đồ án tốt nghiệp. Mô hình này góp phần minh họa một cách trực quan, thực tế và hiệu quả các nội dung đã được nghiên

cứu, từ đó nâng cao chất lượng đào tạo và nghiên cứu khoa học trong lĩnh vực an ninh mạng.

### **1.3. Thành phần Cơ bản của Trung tâm Điều hành An ninh (SOC) và Chức năng Chính**

Mô hình vận hành hiệu quả của Trung tâm Điều hành An ninh (SOC) được xây dựng dựa trên sự tương tác và phối hợp chặt chẽ của ba trụ cột cơ bản là Con người (People), Quy trình (Process) và Công nghệ (Technology). Sự thành công trong việc bảo vệ hệ thống trước các mối đe dọa phức tạp phụ thuộc vào sự cân bằng và tối ưu hóa của cả ba yếu tố này.

#### *1.3.1. Con người (People)*

Con người là thành phần trung tâm và quyết định trong mô hình SOC, giữ vai trò trực tiếp giám sát, phân tích, diễn giải dữ liệu và ra quyết định chiến lược trong suốt quá trình xử lý sự cố an ninh mạng. Mặc dù công nghệ tự động hóa ngày càng được ứng dụng rộng rãi, khả năng tư duy phản biện, phán đoán bối cảnh, và đưa ra quyết định ứng phó phức tạp vẫn là chức năng độc quyền của đội ngũ nhân sự chuyên môn cao.

Cấu trúc nhân sự của SOC được tổ chức theo mô hình phân cấp trách nhiệm (Tiers) nhằm đảm bảo sự chuyên môn hóa và hiệu quả trong việc xử lý khối lượng cảnh báo lớn. Cấu trúc điển hình bao gồm: nhân viên giám sát cấp 1 (SOC Analyst Tier 1) chịu trách nhiệm chính trong việc theo dõi cảnh báo (alert monitoring), thực hiện sàng lọc ban đầu (triage) và xử lý các sự cố đơn giản theo quy trình chuẩn đã được định sẵn. Những sự cố phức tạp hơn sẽ được chuyển giao lên cấp cao hơn, cụ thể là nhân viên phân tích cấp 2 (SOC Analyst Tier 2), người đảm nhiệm việc phân tích chuyên sâu, điều tra nguyên nhân gốc rễ (root cause analysis), và điều phối các hành động ứng phó chi tiết như cô lập và khắc phục hệ thống. Trong các SOC quy mô lớn hoặc có mức độ trưởng thành cao, các vai trò chuyên biệt hóa khác cũng được thiết lập, chẳng hạn như chuyên gia săn tìm mối đe dọa (Threat Hunter) thực hiện các hoạt động chủ động truy tìm các dấu hiệu xâm nhập âm thầm, hoặc Quản lý SOC (SOC Manager) giám sát tổng thể hoạt động và xây dựng chiến lược an ninh.

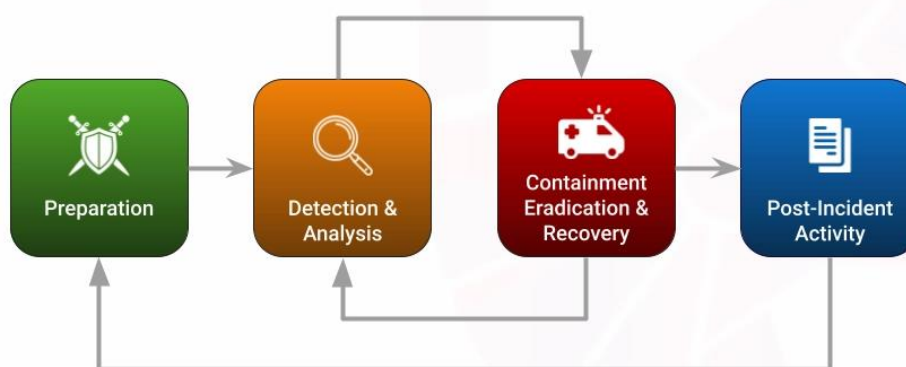
Đối với mô hình SOC mini được thiết lập phục vụ mục đích đào tạo và nghiên cứu, vai trò con người thường được giản lược do hạn chế về nguồn lực. Trong môi trường này, một hoặc hai người học có thể đảm nhiệm nhiều chức năng và trách nhiệm của các cấp độ phân tích khác nhau. Tuy nhiên, việc mô phỏng và phân biệt rõ ràng các vai trò và nhiệm vụ cơ bản này, ví dụ như sự khác biệt giữa việc sàng lọc ban đầu (Tier 1) và phân tích điều tra (Tier 2), vẫn có ý nghĩa phương pháp luận quan trọng. Điều này nhằm đảm bảo rằng người học có thể nắm bắt

được luồng công việc, quy trình leo thang sự cố (incident escalation) và mối quan hệ giữa các chức năng trong vận hành SOC thực tế.

### 1.3.2. Quy trình (Process)

Quy trình là yếu tố nền tảng đảm bảo các hoạt động của Trung tâm Điều hành An ninh (SOC) được thực hiện một cách nhất quán, có hệ thống và hiệu quả. Việc thiết lập các quy trình tiêu chuẩn hóa giúp đội ngũ nhân sự SOC hoạt động đồng bộ, đặc biệt quan trọng trong các tình huống khủng hoảng cần ra quyết định nhanh chóng. Các quy trình cơ bản trong SOC bao gồm toàn bộ vòng đời của một sự kiện an ninh, từ giám sát liên tục, phát hiện sự cố, phân tích và đánh giá mức độ nghiêm trọng, ứng phó và khắc phục, cho đến giai đoạn rút kinh nghiệm và cải tiến sau sự cố. Những quy trình này thường được xây dựng dựa trên các khung tham chiếu và tiêu chuẩn quốc tế đã được công nhận, chẳng hạn như tiêu chuẩn NIST SP 800-61 về hướng dẫn xử lý sự cố an ninh máy tính.

Việc áp dụng các quy trình chuẩn mực đảm bảo rằng mọi cảnh báo đều được xử lý theo một logic nhất định, giảm thiểu sự phụ thuộc vào kinh nghiệm cá nhân và tối ưu hóa thời gian phản ứng. Đặc biệt, việc xác định rõ ràng quy trình leo thang (escalation process) cho phép chuyển giao sự cố từ cấp độ phân tích thấp lên cấp độ cao hơn một cách nhanh chóng khi cần thiết, đảm bảo sự cố nghiêm trọng được giải quyết kịp thời bởi chuyên gia phù



Hình 3: Quy trình xử lý sự cố an ninh trong SOC

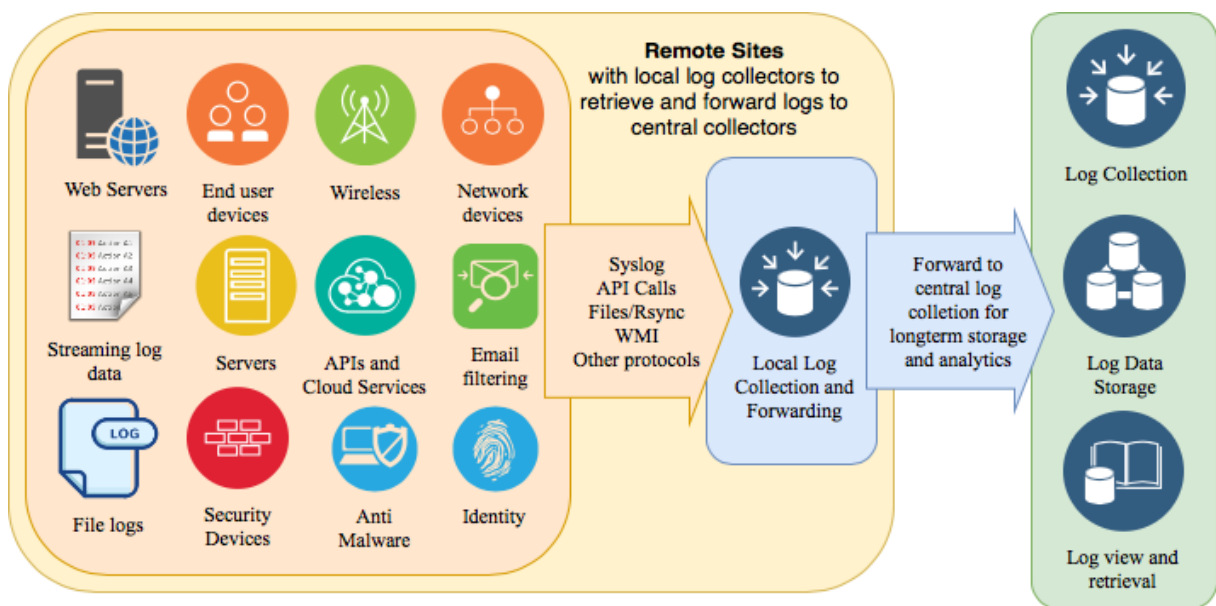
Hình 3: Quy trình xử lý sự cố an ninh trong SOC mô tả một cách trực quan vòng đời xử lý sự cố an ninh mạng điển hình mà mọi SOC đều tuân thủ. Quy trình này cho thấy hoạt động của SOC không chỉ dừng lại ở việc phát hiện cảnh báo mà còn đóng vai trò xuyên suốt và chủ đạo trong toàn bộ quá trình xử lý sự cố.

Vòng đời này bao gồm các giai đoạn kế tiếp nhau từ Phát hiện (Detection), Phân tích (Analysis), Ứng phó và Cô lập (Containment and Response), cho đến Phục hồi (Recovery) và cuối cùng là Rút kinh nghiệm (Post-Incident Review). Giai đoạn Phát hiện và Phân tích là nơi các công cụ công nghệ và chuyên viên cấp 1, 2 thực hiện chức năng thu thập dữ liệu và xác định bản chất của mối đe dọa. Giai đoạn Ứng phó và Cô lập đòi hỏi các quy trình đã được xác định trước (playbooks) để nhanh chóng ngăn chặn sự lây lan của cuộc tấn công. Sau khi sự cố đã được kiểm soát, giai đoạn Phục hồi và Cải tiến là nơi SOC phân tích lại toàn bộ quá trình, xác định những điểm yếu trong quy trình hoặc công nghệ đã bị khai thác. Sự cải tiến này là yếu tố quan trọng giúp nâng cao khả năng phòng thủ của tổ chức trong tương lai.

Đối với mô hình SOC mini trong môi trường đào tạo, việc áp dụng quy trình xử lý sự cố này ở mức đơn giản và có kiểm soát là thiết yếu. Điều này giúp người học không chỉ hiểu được lý thuyết mà còn nắm rõ mối liên hệ thực tế giữa từng bước trong quy trình, từ đó hiểu rõ vai trò cụ thể của SOC trong việc giảm thiểu tác động của sự cố an ninh đối với hoạt động của tổ chức.

### *1.3.3. Công nghệ (Technology)*

Công nghệ là thành phần hỗ trợ cốt lõi, cung cấp khả năng thực hiện các chức năng giám sát, phân tích và ứng phó của Trung tâm Điều hành An ninh (SOC) trên quy mô lớn và liên tục. Việc triển khai các giải pháp công nghệ tiên tiến là yếu tố thiết yếu để tự động hóa các tác vụ lặp đi lặp lại, xử lý khối lượng dữ liệu khổng lồ và tăng cường độ chính xác trong phát hiện mối đe dọa. Các công nghệ thường được sử dụng trong SOC là một hệ sinh thái phức tạp bao gồm: hệ thống Quản lý Thông tin và Sự kiện An ninh (SIEM) để thu thập và phân tích log; các công cụ Phát hiện và Phòng chống Xâm nhập (IDS/IPS); các hệ thống Giám sát Hiệu suất Mạng (NPM); các nền tảng Phân tích Hành vi Người dùng và Thực thể (UEBA); và các công cụ hỗ trợ Ứng phó và Tự động hóa An ninh (SOAR). Trong số đó, hệ thống SIEM đóng vai trò trung tâm, cho phép tập trung dữ liệu nhật ký từ hàng ngàn điểm nguồn khác nhau và hỗ trợ tương quan sự kiện nhằm phát hiện các dấu hiệu bất thường mà từng log riêng lẻ không thể làm được.



Hình 4: Kiến trúc công nghệ SOC

Hình 4: Kiến trúc công nghệ SOC minh họa cấu trúc công nghệ điển hình, làm nổi bật vai trò trung tâm của SIEM. Theo kiến trúc này, các nguồn log đa dạng, bao gồm máy chủ, máy trạm, thiết bị mạng, ứng dụng và các hệ thống bảo mật khác, được thu thập, chuẩn hóa và tổng hợp về hệ thống SIEM.

Việc tập trung dữ liệu này tạo ra một hồ sơ dữ liệu an ninh thống nhất, cho phép SOC có một cái nhìn toàn diện và thời gian thực về trạng thái an ninh của toàn bộ hệ thống. SIEM sau đó sử dụng các bộ quy tắc (rules) và thuật toán học máy để phân tích các sự kiện được tổng hợp, từ đó phát hiện các mẫu hành vi bất thường, các chuỗi tấn công (kill chain) đang diễn ra và sinh ra các cảnh báo có độ tin cậy cao. Điều này không chỉ tạo điều kiện thuận lợi cho việc phát hiện sớm mà còn cung cấp bối cảnh cần thiết cho đội ngũ phân tích để điều tra và ứng phó một cách chính xác.

Trong phạm vi của mô hình SOC mini phục vụ nghiên cứu và đào tạo, kiến trúc công nghệ có thể được thu gọn đáng kể về quy mô và số lượng nguồn log. Tuy nhiên, nguyên tắc cốt lõi vẫn được giữ nguyên, đó là duy trì vai trò trung tâm của một nền tảng SIEM (chẳng hạn như các phiên bản miễn phí hoặc cộng đồng của Splunk, ELK Stack hoặc Wazuh) trong việc thu thập, phân tích log và sinh cảnh báo. Sự mô phỏng này đảm bảo người học nắm bắt được cơ chế hoạt động của công nghệ nền tảng, yếu tố quyết định hiệu quả của các quy trình giám sát và ứng phó trong thực tế.

#### 1.3.4. Chức năng Chính của Trung tâm Điều hành An ninh (SOC)

Từ sự kết hợp đồng bộ và tương tác chặt chẽ giữa ba thành phần cốt lõi là Con người, Quy trình và Công nghệ đã được trình bày, SOC thực hiện một tập hợp các chức năng chính yếu nhằm đảm bảo an ninh liên tục và toàn diện cho hệ thống thông tin. Các chức năng này được thiết kế để tạo thành một chu trình khép kín, bổ trợ lẫn nhau, từ đó không ngừng nâng cao khả năng phòng thủ của tổ chức.

##### **Các chức năng chính của SOC bao gồm:**

Thứ nhất là Giám sát An ninh Liên tục (Continuous Security Monitoring). Đây là chức năng cơ bản nhất, yêu cầu hoạt động giám sát 24/7 các cảnh báo, log và lưu lượng mạng để kịp thời nhận diện bất kỳ dấu hiệu hoặc hoạt động đáng ngờ nào. Giám sát liên tục đảm bảo không có khoảng trống về thời gian mà các mối đe dọa có thể khai thác.

Thứ hai là Phát hiện và Cảnh báo Sự cố (Incident Detection and Alerting). Dựa trên dữ liệu được thu thập từ quá trình giám sát, SOC sử dụng các công cụ phân tích (như SIEM) và các quy tắc tương quan để phát hiện các sự kiện an ninh thực sự và đưa ra cảnh báo kịp thời cho đội ngũ phân tích. Chức năng này đòi hỏi sự tinh chỉnh liên tục để giảm thiểu tỷ lệ cảnh báo sai (false positives) và tăng cường khả năng phát hiện mối đe dọa thực tế.

Thứ ba là Phân tích và Điều tra Nguyên nhân (Analysis and Root Cause Investigation). Khi một cảnh báo đã được xác thực, SOC thực hiện chức năng phân tích chuyên sâu để hiểu rõ bản chất, phạm vi và mục tiêu của cuộc tấn công. Chức năng này bao gồm việc phân tích mã độc, truy vết kẻ tấn công (threat actor), và xác định nguyên nhân gốc rễ (root cause) đã dẫn đến lỗ hổng bị khai thác.

Thứ tư là Hỗ trợ Ứng phó và Khắc phục Sự cố (Incident Response and Remediation Support). Sau khi điều tra, SOC điều phối và hỗ trợ các đội ngũ vận hành và kỹ thuật trong việc cô lập hệ thống bị ảnh hưởng (containment), loại bỏ mối đe dọa (eradication) và khôi phục hệ thống về trạng thái hoạt động an toàn (recovery). Mặc dù đội ngũ kỹ thuật có thể thực hiện hành động khắc phục, SOC là đơn vị chỉ đạo về mặt chiến lược và cung cấp thông tin tình báo về mối đe dọa.

Thứ năm là Báo cáo và Cải tiến Hệ thống An ninh (Reporting and Security Improvement). Sau khi sự cố được giải quyết, SOC có trách nhiệm tổng hợp báo cáo về sự cố, phân tích các bài học kinh nghiệm và đề xuất các biện pháp cải tiến. Sự cải tiến này bao gồm việc cập nhật quy trình, tinh chỉnh quy tắc phát hiện trên các công cụ công nghệ và đề xuất nâng cấp hạ tầng phòng thủ, qua đó hoàn thành chu trình khép kín nhằm nâng cao khả năng phòng thủ của hệ thống thông tin.

Trong mô hình SOC mini được sử dụng cho mục đích nghiên cứu và đào tạo, việc triển khai đầy đủ các chức năng này ở mức cơ bản và đơn giản hóa là rất

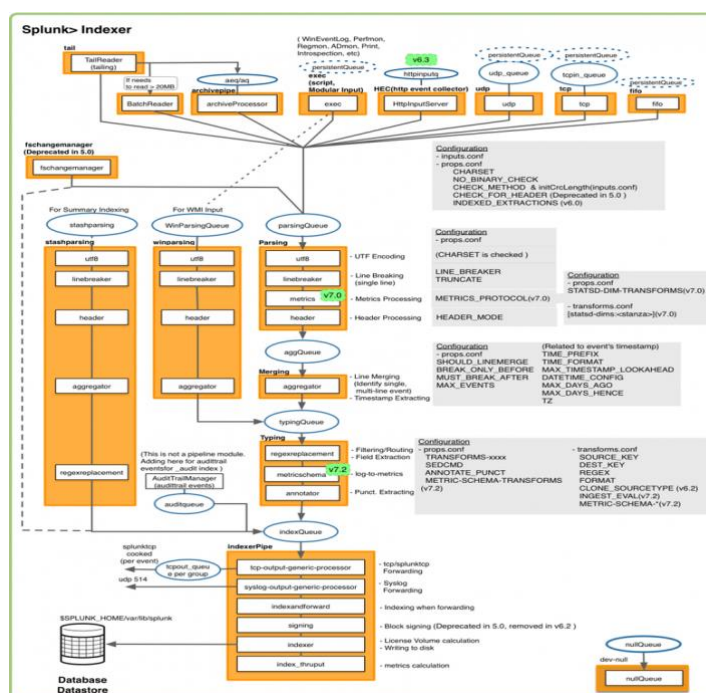


cần thiết. Điều này không chỉ giúp người học minh họa rõ ràng vai trò đa chiều của SOC mà còn tạo nền tảng thực tiễn vững chắc cho các nghiên cứu và mở rộng chuyên sâu trong tương lai.

#### 1.4. Giới thiệu về Splunk và vai trò trong thu thập, phân tích log

Trong các hệ thống giám sát an ninh mạng hiện đại, việc thu thập và phân tích dữ liệu log đóng vai trò then chốt trong quá trình phát hiện và xử lý sự cố. Log là nguồn dữ liệu phản ánh trực tiếp các hoạt động diễn ra trong hệ thống, bao gồm hành vi người dùng, trạng thái dịch vụ, sự kiện hệ điều hành và các tương tác mạng. Tuy nhiên, do log thường được sinh ra với khối lượng lớn, định dạng đa dạng và phân tán ở nhiều thành phần khác nhau, việc quản lý và khai thác hiệu quả dữ liệu log đặt ra nhiều thách thức đối với các tổ chức.

Splunk là một nền tảng phân tích dữ liệu máy (machine data) được sử dụng rộng rãi trong các hệ thống giám sát, vận hành và an ninh mạng. Trong lĩnh vực an toàn thông tin, Splunk thường được triển khai như một hệ thống SIEM, cho phép thu thập, lưu trữ, tìm kiếm và phân tích log từ nhiều nguồn khác nhau trong thời gian gần thực. Splunk hỗ trợ đa dạng các loại dữ liệu đầu vào, từ log hệ điều hành, ứng dụng, thiết bị mạng cho đến các nguồn dữ liệu bảo mật chuyên dụng, đồng thời cung cấp ngôn ngữ truy vấn SPL (Search Processing Language) để thực hiện phân tích và tương quan sự kiện.



Hình 5: Kiến trúc tổng quát của Splunk trong thu thập và phân tích log



Hình 5 minh họa kiến trúc tổng quát của Splunk, trong đó các nguồn log từ hệ thống máy chủ, máy trạm và thiết bị mạng được thu thập thông qua các thành phần như Splunk Universal Forwarder và gửi về máy chủ Splunk để xử lý. Dữ liệu sau khi được tiếp nhận sẽ trải qua quá trình lập chỉ mục, lưu trữ và phân tích, từ đó cho phép người vận hành thực hiện tìm kiếm, xây dựng dashboard và thiết lập cảnh báo. Kiến trúc này cho thấy Splunk đóng vai trò trung tâm trong việc tập trung hóa dữ liệu log, giúp SOC có cái nhìn thống nhất và toàn diện về trạng thái hoạt động của hệ thống.

Trong bối cảnh vận hành SOC, Splunk không chỉ hỗ trợ việc giám sát thụ động mà còn đóng vai trò quan trọng trong phát hiện và cảnh báo sự cố an ninh. Thông qua việc xây dựng các truy vấn SPL và các quy tắc cảnh báo, Splunk cho phép phát hiện các hành vi bất thường như đăng nhập thất bại liên tiếp, truy cập trái phép hoặc lưu lượng truy cập tăng đột biến. Ngoài ra, Splunk còn hỗ trợ mở rộng khả năng phân tích thông qua các ứng dụng bổ trợ như Splunk Machine Learning Toolkit, cho phép áp dụng các phương pháp phân tích nâng cao nhằm phát hiện bất thường dựa trên dữ liệu lịch sử.

Đối với mô hình SOC mini trong phạm vi đề án, Splunk là lựa chọn phù hợp nhờ khả năng triển khai linh hoạt, hỗ trợ đầy đủ các chức năng cơ bản của một hệ thống SIEM và có thể hoạt động hiệu quả trong môi trường thử nghiệm nhỏ. Việc sử dụng Splunk giúp minh họa rõ ràng quy trình thu thập, phân tích log và phát hiện sự cố an ninh, đồng thời tạo nền tảng kỹ thuật cho việc tích hợp các mô hình phát hiện bất thường và cơ chế phản ứng tự động ở các chương tiếp theo của đề án.

## **1.5. Tổng kết Chương I**

Chương I đã trình bày những nội dung tổng quan nhằm làm rõ bối cảnh và cơ sở lý luận cho việc nghiên cứu đề tài. Trước hết, chương đã phân tích tình hình an ninh mạng hiện nay thông qua các số liệu và xu hướng thực tế, qua đó cho thấy mức độ gia tăng cả về số lượng lẫn tính chất phức tạp của các mối đe dọa an ninh mạng. Những phân tích này làm nổi bật nhu cầu cấp thiết của việc giám sát, phát hiện và xử lý kịp thời các sự cố an ninh trong hệ thống công nghệ thông tin.

Tiếp đó, chương đã giới thiệu khái niệm và vai trò của Trung tâm điều hành an ninh mạng (SOC), nhấn mạnh SOC như một mô hình tổ chức và kỹ thuật đóng vai trò trung tâm trong công tác bảo đảm an toàn thông tin. Các thành phần cơ bản của SOC, bao gồm con người, quy trình và công nghệ, đã được trình bày nhằm làm rõ cách thức SOC vận hành và phối hợp để thực hiện các chức năng giám sát, phân tích và ứng phó sự cố.

Cuối cùng, chương đã giới thiệu Splunk như một nền tảng SIEM phổ biến, đóng vai trò quan trọng trong việc thu thập và phân tích log phục vụ giám sát an ninh mạng. Những nội dung của Chương I tạo nền tảng lý thuyết cần thiết cho việc nghiên cứu các phương pháp phát hiện bất thường và triển khai mô hình SOC mini ở các chương tiếp theo của đề án.

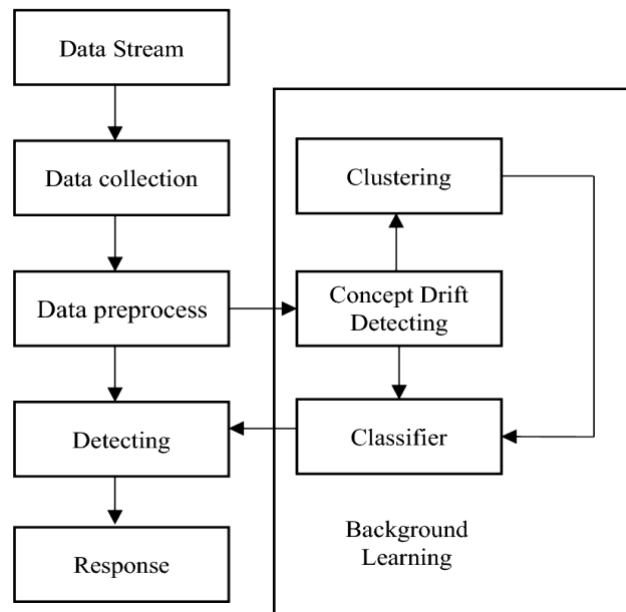
## **Chương II. Phát hiện bất thường bằng trí tuệ nhân tạo trong SOC**

### **2.1. Khái niệm phát hiện bất thường (Anomaly Detection)**

Trong các hệ thống công nghệ thông tin hiện đại, dữ liệu được sinh ra liên tục với khối lượng lớn và phản ánh trực tiếp trạng thái hoạt động của hệ thống. Phần lớn các dữ liệu này thể hiện những hành vi bình thường, ổn định theo thời gian, trong khi chỉ một tỷ lệ nhỏ mang tính bất thường và có thể liên quan đến lỗi hệ thống hoặc các hành vi tấn công an ninh mạng. Phát hiện bất thường (Anomaly Detection) là quá trình nhận diện những dữ liệu, sự kiện hoặc hành vi có đặc điểm sai lệch đáng kể so với mô hình hoạt động thông thường của hệ thống.

Về mặt khái niệm, bất thường có thể được hiểu là những quan sát không tuân theo các quy luật, phân bố hoặc hành vi đã được xác định trước từ dữ liệu lịch sử. Trong lĩnh vực an ninh mạng, các bất thường thường xuất hiện dưới dạng tần suất truy cập tăng đột biến, hành vi đăng nhập khác thường, lưu lượng mạng không phù hợp với mô hình sử dụng thông thường hoặc các chuỗi sự kiện hiếm gặp. Khác với các phương pháp phát hiện dựa trên chữ ký hay luật cố định, phát hiện bất thường tập trung vào việc học và mô hình hóa hành vi bình thường, từ đó phát hiện các sai lệch mà không cần biết trước mẫu tấn công cụ thể.

Trong bối cảnh SOC, phát hiện bất thường đóng vai trò quan trọng trong việc nhận diện sớm các mối đe dọa mới hoặc các cuộc tấn công tinh vi chưa được định nghĩa trong hệ thống luật. Khi một kẻ tấn công sử dụng kỹ thuật mới hoặc thay đổi hành vi để né tránh các cơ chế phát hiện truyền thống, các phương pháp anomaly detection có khả năng phát hiện sự sai lệch trong hành vi tổng thể, qua đó cung cấp cảnh báo sớm cho đội ngũ vận hành SOC.



Hình 6: Minh họa khái niệm phát hiện bất thường trong dữ liệu an ninh

Hình 6 minh họa sự khác biệt giữa các hành vi bình thường và hành vi bất thường trong dữ liệu an ninh. Phần lớn các điểm dữ liệu tập trung thành các cụm thể hiện trạng thái hoạt động ổn định của hệ thống, trong khi các điểm nằm tách biệt khỏi các cụm này được xem là bất thường. Trong SOC, các điểm bất thường này có thể tương ứng với các sự kiện như đăng nhập thất bại với tần suất cao, truy cập từ vị trí địa lý không phổ biến hoặc lưu lượng mạng tăng đột ngột, từ đó trở thành cơ sở để sinh cảnh báo an ninh.

Tùy theo bản chất của dữ liệu và mục tiêu phát hiện, bất thường trong an ninh mạng có thể được phân loại theo nhiều cách khác nhau. Một cách phân loại phổ biến là dựa trên hình thức xuất hiện của bất thường, bao gồm bất thường điểm (point anomaly), bất thường ngữ cảnh (contextual anomaly) và bất thường tập thể (collective anomaly). Bất thường điểm là những sự kiện đơn lẻ có giá trị khác biệt rõ rệt so với dữ liệu còn lại, chẳng hạn như một lần đăng nhập với số lượng lớn yêu cầu trong thời gian ngắn. Bất thường ngữ cảnh là những sự kiện chỉ được coi là bất thường khi xét trong một ngữ cảnh cụ thể, ví dụ như hoạt động đăng nhập vào ban đêm đối với một tài khoản chỉ hoạt động trong giờ hành chính. Bất thường tập thể là những chuỗi sự kiện mà từng phần tử riêng lẻ có thể bình thường, nhưng khi xét tổng thể lại thể hiện hành vi bất thường, chẳng hạn như một chuỗi truy cập liên tiếp vào nhiều cổng dịch vụ khác nhau.

Bảng 1 dưới đây tổng hợp các loại bất thường thường gặp trong dữ liệu an ninh mạng cùng với ví dụ minh họa trong môi trường SOC.

| <b>Loại bất thường</b> | <b>Đặc điểm</b>                                      | <b>Ví dụ trong SOC</b>                                                     |
|------------------------|------------------------------------------------------|----------------------------------------------------------------------------|
| Bất thường điểm        | Một sự kiện đơn lẻ khác biệt rõ rệt                  | Một IP gửi số lượng lớn yêu cầu đăng nhập trong thời gian ngắn             |
| Bất thường ngưỡng cảnh | Phụ thuộc vào thời gian, vị trí hoặc trạng thái      | Đăng nhập hợp lệ nhưng xảy ra vào khung giờ không thông thường             |
| Bất thường tập thể     | Chuỗi sự kiện có ý nghĩa bất thường khi xét tổng thể | Nhiều lần truy cập vào các cổng khác nhau trong thời gian ngắn (port scan) |

Bảng 1: Phân loại bất thường và ví dụ trong an ninh mạng

Từ góc độ ứng dụng thực tế, anomaly detection đã được sử dụng rộng rãi trong các hệ thống SOC để phát hiện các hành vi như brute-force, dò quét mạng, xâm nhập trái phép hoặc hành vi nội gián. Ví dụ, trong một hệ thống máy chủ Linux, số lần đăng nhập thất bại qua SSH thường duy trì ở mức thấp và ổn định. Khi số lượng đăng nhập thất bại tăng đột biến trong một khoảng thời gian ngắn, mô hình phát hiện bất thường có thể nhận diện sự sai lệch này và sinh cảnh báo, ngay cả khi địa chỉ IP hoặc phương thức tấn công chưa từng xuất hiện trước đó.

Như vậy, phát hiện bất thường là một hướng tiếp cận quan trọng trong SOC, giúp bổ sung và nâng cao hiệu quả của các phương pháp phát hiện truyền thống. Việc áp dụng anomaly detection, đặc biệt là các phương pháp dựa trên trí tuệ nhân tạo, cho phép SOC nâng cao khả năng nhận diện sớm các mối đe dọa mới, giảm phụ thuộc vào tập luật cố định và tạo nền tảng cho các cơ chế phát hiện thông minh hơn. Nội dung này là cơ sở lý thuyết quan trọng cho các phần tiếp theo, trong đó đề án sẽ tập trung vào việc lựa chọn và triển khai các phương pháp phát hiện bất thường phù hợp với mô hình SOC mini.

## 2.2. Một số phương pháp phát hiện bất thường đơn giản phù hợp cho môi trường nhỏ

Trong mô hình SOC mini hoặc các môi trường giám sát an ninh mạng quy mô nhỏ, việc áp dụng các phương pháp phát hiện bất thường cần ưu tiên tính đơn giản, khả năng triển khai và mức độ giải thích kết quả. Các phương pháp quá phức tạp hoặc yêu cầu dữ liệu lớn thường không phù hợp với điều kiện hạ tầng hạn chế. Vì vậy, đề án tập trung vào một số phương pháp phát hiện bất thường phổ biến, dễ triển khai và có hiệu quả thực tiễn, bao gồm phương pháp ngưỡng thống kê, Isolation Forest và Local Outlier Factor.

### 2.2.1. Phương pháp ngưỡng thống kê (Statistical Threshold)

Phương pháp ngưỡng thống kê là một trong những kỹ thuật cơ bản và phổ biến nhất trong phát hiện bất thường, đặc biệt trong lĩnh vực an ninh mạng. Phương pháp này hoạt động dựa trên giả định nền tảng rằng các hành vi vận hành bình thường của hệ thống sẽ dao động quanh một giá trị trung bình ổn định theo thời gian và có thể được mô tả một cách hiệu quả bằng các đại lượng thống kê cơ bản như giá trị trung bình ( $\mu$ ) và độ lệch chuẩn ( $\sigma$ ). Theo đó, hệ thống sẽ tính toán một phạm vi hành vi được coi là "bình thường", và khi giá trị quan sát của một chỉ số bất kỳ vượt quá một ngưỡng xác định trước, sự kiện đó sẽ được phân loại là bất thường (anomaly).

Trong an ninh mạng, phương pháp ngưỡng thống kê được áp dụng rộng rãi để phát hiện các hiện tượng có tính đột biến rõ ràng và có thể đo lường được. Các trường hợp ứng dụng điển hình bao gồm: phát hiện số lần đăng nhập thất bại tăng cao bất thường, theo dõi lưu lượng truy cập mạng vượt quá băng thông thông thường, hoặc ghi nhận số lượng yêu cầu dịch vụ (service requests) tăng đột ngột. Ví dụ cụ thể, trong quá trình giám sát log giao thức SSH, nếu số lần đăng nhập thất bại trong một khoảng thời gian ngắn vượt xa mức trung bình lịch sử (ví dụ:  $3\sigma$  so với mức trung bình), đây có thể là dấu hiệu rõ ràng của một cuộc tấn công vét cạn mật khẩu (brute-force attack) đang diễn ra.

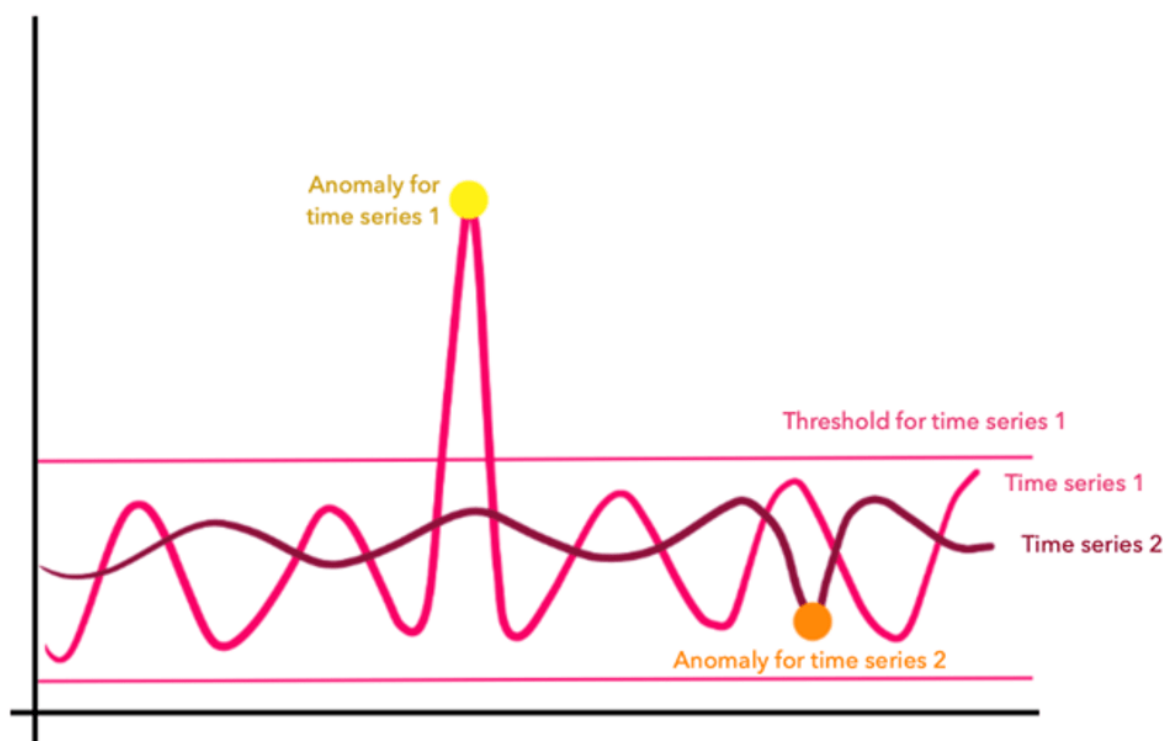


Figure 1

Hình 7: Phát hiện bất thường dựa trên ngưỡng thống kê trong chuỗi dữ liệu

Hình 7: Phát hiện bất thường dựa trên ngưỡng thống kê trong chuỗi dữ liệu minh họa trực quan cách thức áp dụng phương pháp này trên một chuỗi dữ liệu theo thời gian (time series data). Trên biểu đồ, hành vi bình thường của dữ liệu nằm trong giới hạn được xác định bởi đường ngưỡng trên và đường ngưỡng dưới (thường được tính toán dựa trên độ lệch chuẩn). Khi một điểm dữ liệu (chẳng hạn như số lượng kết nối mạng) vượt lên trên đường ngưỡng này, nó ngay lập tức được đánh dấu là bất thường.

Trong môi trường vận hành của SOC mini, tính đơn giản và hiệu quả của phương pháp này cho phép nó được triển khai trực tiếp thông qua các truy vấn thống kê mạnh mẽ trong các nền tảng SIEM như Splunk, ELK Stack hoặc Wazuh. Bằng cách thiết lập các truy vấn để tính toán các đại lượng thống kê trong cửa sổ thời gian xác định, đội ngũ SOC mini có thể nhanh chóng phát hiện các hành vi bất thường dễ nhận biết (ví dụ: spikes/drops) và hỗ trợ sinh cảnh báo kịp thời. Phương pháp ngưỡng thống kê do đó cung cấp một lớp phòng thủ cơ bản nhưng hiệu quả cao, giúp sàng lọc và ưu tiên các mối đe dọa cần được điều tra ngay lập tức.

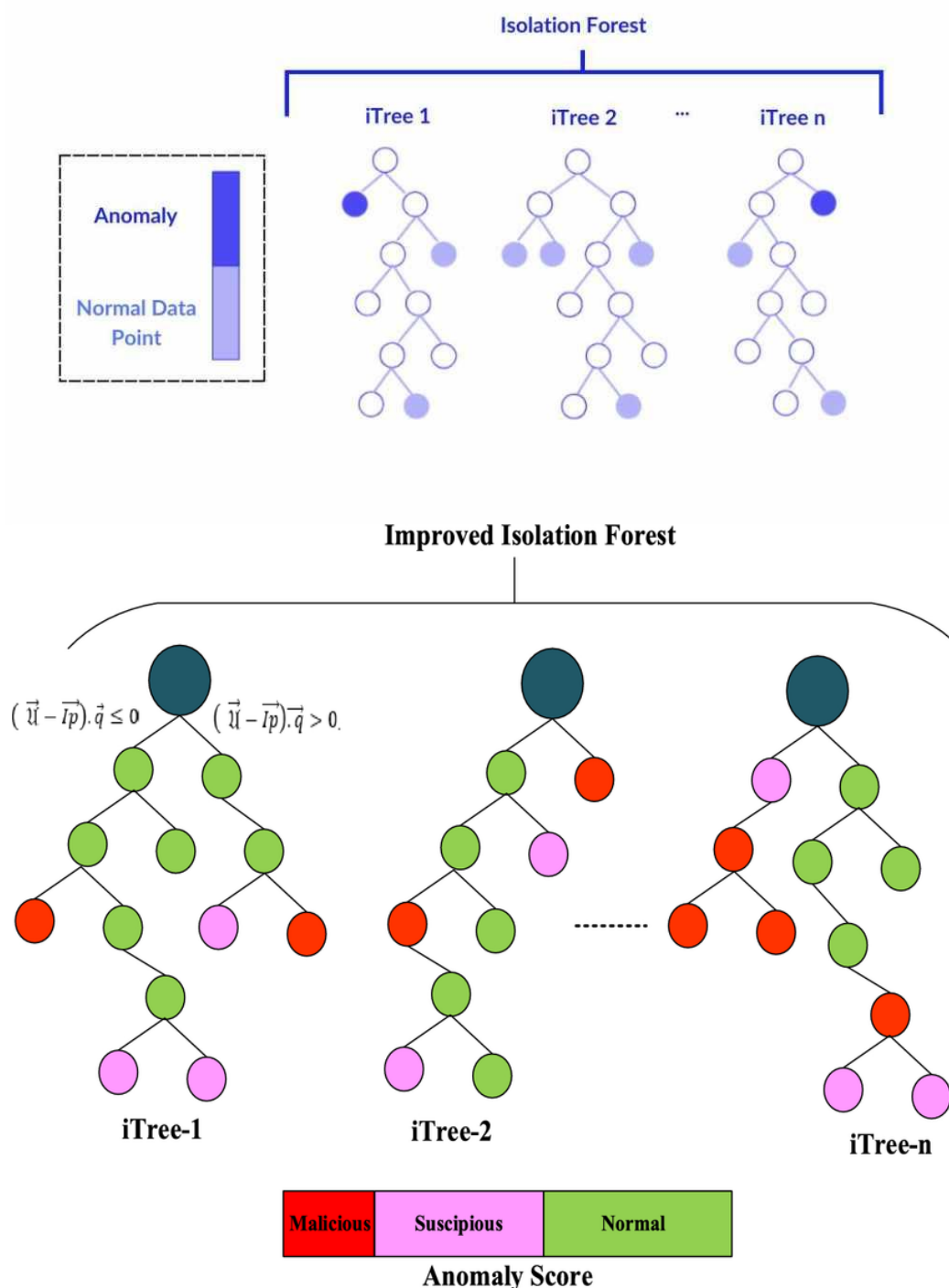
### 2.2.2. Phương pháp Isolation Forest

Phương pháp Cô lập Rừng (Isolation Forest – iForest) là một thuật toán học máy không giám sát tiên tiến được thiết kế chuyên biệt cho việc phát hiện các điểm dữ liệu bất thường (anomaly detection). Khác biệt căn bản so với các phương pháp xây dựng mô hình hành vi bình thường, Isolation Forest hoạt động dựa trên nguyên lý hiệu quả là cô lập các điểm dữ liệu hiếm gặp. Thuật toán này dựa trên nhận định rằng các điểm bất thường là các điểm có tần suất xuất hiện thấp và khác biệt đáng kể về mặt đặc trưng so với phần lớn dữ liệu, do đó chúng sẽ dễ bị tách rời (isolated) khỏi các điểm còn lại trong quá trình phân tách dữ liệu.

Cơ chế hoạt động của iForest bao gồm việc xây dựng một tập hợp lớn các cây phân tách ngẫu nhiên (Isolation Trees). Trong quá trình xây dựng mỗi cây, dữ liệu được phân tách một cách ngẫu nhiên bằng cách chọn ngẫu nhiên một thuộc tính và một giá trị tách ngẫu nhiên trong phạm vi của thuộc tính đó. Các điểm bất thường, do nằm ở các khu vực có mật độ dữ liệu thấp, thường chỉ cần một số lượng phân tách ít hơn để bị cô lập, trong khi các điểm bình thường (normal instances) yêu cầu nhiều bước phân tách hơn vì chúng nằm sâu trong các cụm dữ liệu dày đặc.

Trong môi trường Trung tâm Điều hành An ninh (SOC), Isolation Forest chứng tỏ tính hiệu quả cao trong việc phân tích các đặc trưng tổng hợp được trích xuất từ các log dữ liệu. Các đặc trưng này phản ánh hành vi hệ thống theo thời gian, bao gồm nhưng không giới hạn ở số lượng sự kiện phát sinh trong một khoảng thời gian xác định, số lượng kết nối mạng được thiết lập, hoặc tần suất truy cập một dịch vụ cụ thể. Phương pháp này đặc biệt phù hợp trong các tình huống thực tế mà dữ liệu nhãn (labeled data) không đầy đủ hoặc không có sẵn, và

khi các mẫu tấn công (threat patterns) liên tục thay đổi theo thời gian. Sự thay đổi liên tục của các mẫu tấn công khiến việc xây dựng các luật (rules) cố định hoặc ngưỡng thống kê truyền thống trở nên kém hiệu quả.



Hình 8: Nguyên lý cô lập dữ liệu bất thường của thuật toán Isolation Forest

Hình 8: Nguyên lý cô lập dữ liệu bất thường của thuật toán Isolation Forest cung cấp một minh họa trực quan về cơ chế cốt lõi của thuật toán này. Hình ảnh cho thấy rõ ràng các điểm dữ liệu bất thường (được biểu diễn bằng các điểm nằm ngoài cụm chính) đã bị cô lập khỏi tập dữ liệu thông thường chỉ sau một vài lần phân tách ngẫu nhiên. Điều này dẫn đến một độ sâu trung bình (average path



length) nhỏ hơn trong cấu trúc cây so với các điểm bình thường. Chính cơ chế này cho phép thuật toán gán một điểm số bất thường (anomaly score) cho từng quan sát; điểm số càng cao khi độ sâu trung bình của điểm đó càng nhỏ.

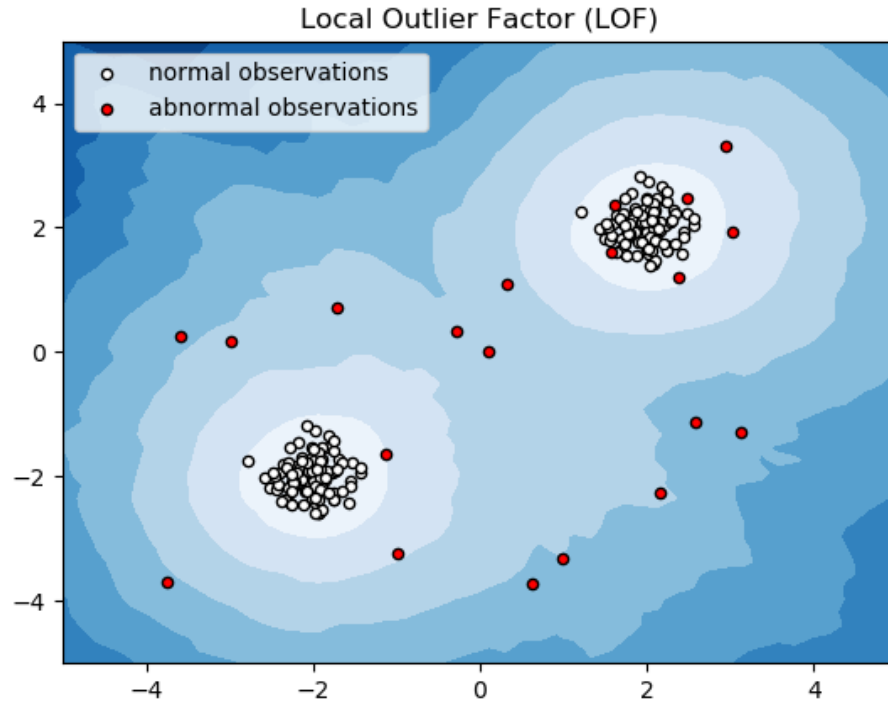
Việc áp dụng Isolation Forest trong các dự án thực nghiệm, ví dụ như trong mô hình SOC mini của đồ án, giúp mở rộng đáng kể khả năng phát hiện của hệ thống. Trong khi phương pháp ngưỡng thống kê chỉ hiệu quả với các hành vi đột biến đơn giản, Isolation Forest có thể nhận diện các hành vi phức tạp hơn, đa chiều hơn, và các bất thường nằm trong không gian đặc trưng nhiều chiều. Sự kết hợp của Isolation Forest với các phương pháp truyền thống tạo nên một lớp phát hiện mạnh mẽ và linh hoạt hơn, là nền tảng vững chắc cho các nghiên cứu và mở rộng chuyên sâu về khả năng nhận diện môi đe dọa trong tương lai.

### 2.2.3. Phương pháp Local Outlier Factor (LOF)

Phương pháp Hệ số Bất thường Cục bộ (Local Outlier Factor – LOF) là một thuật toán phát hiện bất thường dựa trên học máy không giám sát, hoạt động hiệu quả trên nguyên lý mật độ cục bộ của dữ liệu. Khác biệt với các phương pháp dựa trên khoảng cách tuyệt đối hoặc ngưỡng thống kê toàn cục, LOF đánh giá mức độ bất thường của một điểm dữ liệu bằng cách so sánh mật độ của chính điểm đó với mật độ của các điểm lân cận gần nhất (k-nearest neighbors). Một điểm được xem là bất thường nếu nó nằm trong một khu vực có mật độ thấp hơn đáng kể so với mật độ trung bình của các láng giềng.

Thuật toán LOF đặc biệt có giá trị vì nó không bị ảnh hưởng bởi sự phân bố mật độ không đồng đều của toàn bộ tập dữ liệu. Điều này có nghĩa là, một điểm dữ liệu có thể được coi là bình thường trong một vùng dữ liệu thưa thớt (mật độ thấp) nhưng sẽ được coi là bất thường nếu nó nằm ở cùng mật độ đó nhưng trong một vùng lân cận dày đặc hơn. Giá trị LOF được tính toán bằng cách lấy tỷ lệ giữa mật độ lân cận có thể tiếp cận (local reachability density) của điểm đó và mật độ lân cận trung bình của các điểm lân cận gần nhất của nó. Giá trị  $LOF \approx 1$  biểu thị điểm dữ liệu đó có mật độ tương đương với các láng giềng và được coi là bình thường, trong khi giá trị  $LOF \gg 1$  cho thấy điểm đó nằm trong khu vực có mật độ thấp hơn đáng kể, xác nhận tính bất thường của nó.

Trong bối cảnh an ninh mạng, LOF là một công cụ lý tưởng để phát hiện các hành vi bất thường mang tính cục bộ hoặc theo nhóm đối tượng. Phương pháp này đặc biệt phù hợp để xác định một người dùng hoặc một máy trạm có hành vi khác biệt rõ rệt so với nhóm đồng cấp hoặc các đối tượng tương tự. Ví dụ, trong một mạng nội bộ, nếu một máy trạm thuộc phòng ban Kế toán đột nhiên có số lượng kết nối tới các máy chủ Phát triển hoặc kiểu truy cập cơ sở dữ liệu khác biệt rõ rệt so với các máy trạm Kế toán khác, LOF sẽ gán một điểm bất thường cao cho hành vi đó.



Hình 9: Minh họa phát hiện bất thường dựa trên mật độ cục bộ bằng LOF

Hình 9: Minh họa phát hiện bất thường dựa trên mật độ cục bộ bằng LOF mô tả rõ ràng cách LOF xác định các điểm bất thường dựa trên sự chênh lệch mật độ này. Hình ảnh thường biểu diễn các cụm dữ liệu với mật độ khác nhau. Các điểm nằm ở vùng thưa thớt so với khu vực lân cận của chúng được gán giá trị LOF cao và được xem là bất thường, ngay cả khi chúng không nằm quá xa so với trung tâm của toàn bộ tập dữ liệu.

Việc tích hợp phương pháp LOF vào môi trường SOC mini giúp mở rộng khả năng phát hiện sang các sai lệch hành vi tinh vi hơn mà các phương pháp ngưỡng toàn cục dễ bỏ sót. Tuy nhiên, việc triển khai LOF đòi hỏi dữ liệu đầu vào phải được tiền xử lý và chuẩn hóa cẩn thận, đồng thời việc lựa chọn tham số  $\kappa$  (số lượng láng giềng gần nhất) phải phù hợp với bản chất và quy mô của dữ liệu đang được phân tích.

#### 2.2.4. So sánh các phương pháp trong bối cảnh SOC mini

Việc lựa chọn và tích hợp các phương pháp phát hiện bất thường vào một môi trường vận hành thực nghiệm như mô hình SOC mini đòi hỏi sự cân bằng chiến lược giữa độ phức tạp tính toán, tính khả thi trong triển khai (đặc biệt với nguồn lực hạn chế), và mức độ hiệu quả đạt được đối với các loại tấn công khác nhau. Các phương pháp đã được nghiên cứu — Ngưỡng Thống kê, Isolation Forest và Local Outlier Factor (LOF) — đều có những ưu điểm và hạn chế riêng, quyết định mức độ phù hợp của chúng trong môi trường đào tạo và nghiên cứu.

Bảng 2, So sánh các phương pháp phát hiện bất thường phù hợp cho môi trường SOC mini tổng hợp các đặc điểm chính để phục vụ cho việc ra quyết định này.

| Phương pháp                | Nguyên lý                  | Ưu điểm                      | Hạn chế                           | Mức độ phù hợp |
|----------------------------|----------------------------|------------------------------|-----------------------------------|----------------|
| Ngưỡng thống kê            | So sánh với ngưỡng cố định | Dễ triển khai, dễ giải thích | Khó phát hiện bất thường phức tạp | Cao            |
| Isolation Forest           | Cô lập điểm dữ liệu        | Không cần nhãn, linh hoạt    | Khó giải thích chi tiết           | Cao            |
| Local Outlier Factor (LOF) | So sánh mật độ cục bộ      | Phát hiện bất thường tinh vi | Nhạy với nhiễu                    | Trung bình     |

Bảng 2: So sánh phương pháp phát hiện bất thường phù hợp cho môi trường SOC mini

Phân tích chi tiết:

Phương pháp Ngưỡng thống kê (Statistical Threshold) hoạt động dựa trên nguyên lý so sánh giá trị quan sát với một ngưỡng cố định được suy ra từ các đại lượng thống kê lịch sử như trung bình và độ lệch chuẩn. Ưu điểm nổi bật của phương pháp này là tính trực quan, dễ triển khai bằng các truy vấn đơn giản trong hệ thống SIEM, và dễ giải thích (explainability), giúp chuyên viên SOC nhanh chóng xác định lý do cảnh báo được kích hoạt. Chính vì lý do này, mức độ phù hợp của nó trong SOC mini được đánh giá là Cao, đặc biệt để phát hiện các sự kiện đột biến rõ ràng. Tuy nhiên, hạn chế lớn nhất là khả năng phát hiện kém hiệu quả đối với các hành vi bất thường tinh vi hoặc thay đổi chậm theo thời gian.

Ngược lại, Isolation Forest sử dụng nguyên lý học máy không giám sát bằng cách cô lập các điểm dữ liệu khác biệt, thay vì định nghĩa ranh giới của hành vi bình thường. Thuật toán này có ưu điểm vượt trội là không yêu cầu dữ liệu phải có nhãn (unlabeled data) và rất linh hoạt trong việc thích ứng với các mẫu dữ liệu mới, điều này khiến nó trở nên rất mạnh mẽ trong việc nhận diện các tấn công chưa từng thấy (zero-day). Mặc dù độ phức tạp hơn so với ngưỡng thống kê, Isolation Forest vẫn được đánh giá là có mức độ phù hợp Cao đối với SOC mini do tính hiệu quả và khả năng mở rộng trong nghiên cứu. Hạn chế chủ yếu là tính khó giải thích chi tiết về lý do một điểm bị cô lập.

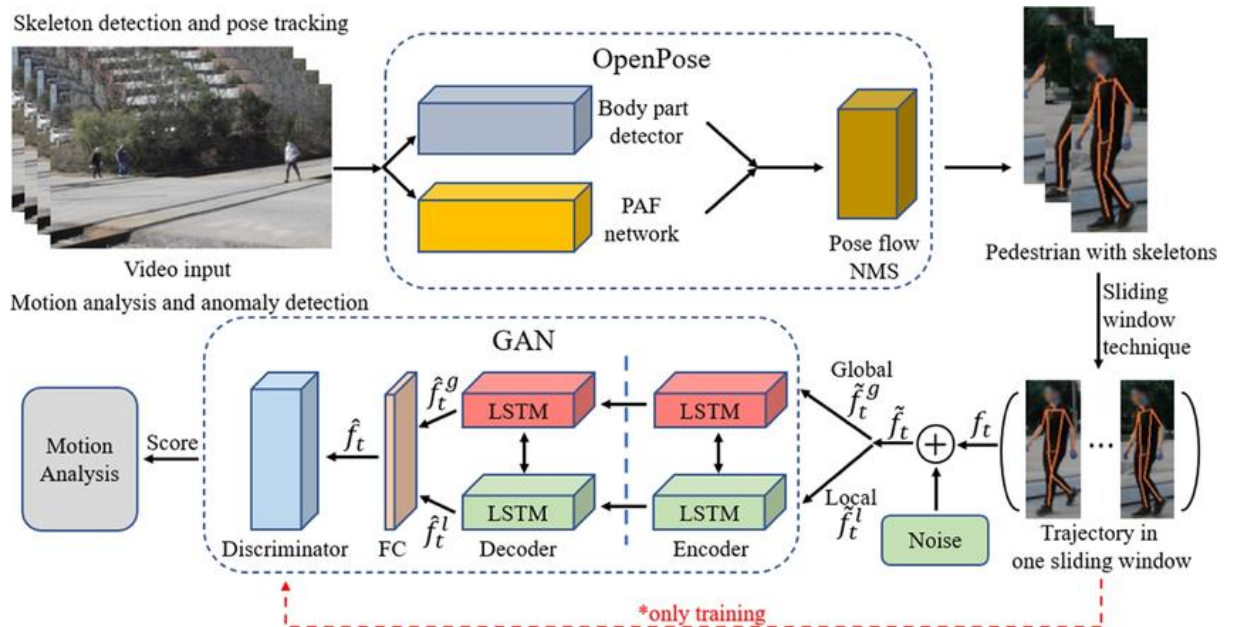
Cuối cùng, Local Outlier Factor (LOF) tập trung vào nguyên lý so sánh mật độ cục bộ, giúp phát hiện các bất thường tinh vi hơn, đặc biệt là những điểm nằm trong các cụm dữ liệu có mật độ khác nhau. Ưu điểm của LOF là khả năng phát hiện các hành vi bất thường theo nhóm hoặc cục bộ (ví dụ: một máy trạm khác biệt so với nhóm đồng cấp). Tuy nhiên, phương pháp này nhạy cảm với dữ liệu

hiệu (noise) và yêu cầu việc lựa chọn tham số  $k$  (số lượng láng giềng) phải được tối ưu hóa cẩn thận, làm tăng độ phức tạp trong triển khai. Do đó, mức độ phù hợp của LOF trong SOC mini được đánh giá là Trung bình, chủ yếu phù hợp cho các nghiên cứu chuyên sâu hơn sau khi đã làm chủ hai phương pháp đầu tiên.

Tóm lại, trong môi trường SOC mini, sự kết hợp của Ngưỡng Thống kê (cho các bất thường rõ ràng và dễ giải thích) và Isolation Forest (cho các bất thường phức tạp không cần nhãn) tạo nên một nền tảng phát hiện mạnh mẽ và cân bằng, là cơ sở vững chắc để người học và nhà nghiên cứu tiếp tục phát triển và mở rộng khả năng của hệ thống.

### 2.3. Các bước cơ bản để xây dựng mô hình phát hiện bất thường

Việc xây dựng một mô hình phát hiện bất thường trong SOC, dù ở quy mô nhỏ hay lớn, đều cần tuân theo một quy trình có hệ thống nhằm đảm bảo tính nhất quán và hiệu quả. Quy trình này thường bao gồm các bước từ thu thập dữ liệu, tiền xử lý, trích đặc trưng, huấn luyện mô hình cho đến đánh giá kết quả. Trong phạm vi SOC mini, các bước này được triển khai ở mức cơ bản nhưng vẫn phản ánh đúng bản chất của một pipeline phát hiện bất thường trong thực tế.



Hình 10: Quy trình cơ bản xây dựng mô hình phát hiện bất thường trong SOC

Hình 10 minh họa pipeline tổng quát của quá trình xây dựng mô hình phát hiện bất thường, trong đó dữ liệu log được thu thập từ hệ thống, trải qua các bước xử lý và phân tích trước khi được đưa vào mô hình học máy. Pipeline này phản

ánh cách SOC chuyển đổi dữ liệu thô thành tri thức phục vụ cho việc phát hiện và cảnh báo sự cố an ninh.

### *2.3.1. Thu thập Dữ liệu (Data Collection)*

Thu thập dữ liệu là bước đầu tiên và có ý nghĩa quyết định đối với chất lượng đầu vào của toàn bộ quy trình phát hiện bất thường. Trong bối cảnh Trung tâm Điều hành An ninh (SOC), dữ liệu được thu thập chủ yếu dưới dạng các tệp nhật ký (log files) từ một loạt các nguồn phân tán trong hệ thống thông tin. Các nguồn dữ liệu này rất đa dạng, bao gồm: log từ hệ điều hành (như Windows Event Logs hoặc Linux Syslogs), log từ các dịch vụ mạng quan trọng (như DNS, DHCP), log từ các ứng dụng kinh doanh cốt lõi và log từ các thiết bị an ninh chuyên dụng (như Tường lửa, Hệ thống Phát hiện và Phòng chống Xâm nhập - IDS/IPS). Những tệp nhật ký này phản ánh một cách trực tiếp hành vi của người dùng, luồng truy cập mạng và trạng thái hoạt động của hệ thống theo thời gian, là bằng chứng vật lý quan trọng để phân tích an ninh.

Chất lượng và tính đầy đủ của dữ liệu thu thập ảnh hưởng trực tiếp đến độ tin cậy của mô hình phát hiện bất thường. Việc thiếu log từ một nguồn quan trọng có thể tạo ra các "điểm mù" (blind spots) cho mô hình, khiến các cuộc tấn công tinh vi không bị phát hiện. Do đó, quy trình thu thập phải đảm bảo tính liên tục, toàn vẹn và đồng bộ hóa thời gian (time synchronization) giữa các nguồn dữ liệu.

Trong mô hình SOC mini được xây dựng cho đồ án nghiên cứu, dữ liệu được thu thập và tập trung hóa thông qua nền tảng Quản lý Thông tin và Sự kiện An ninh (SIEM) là Splunk. Việc triển khai Splunk Universal Forwarder trên các máy chủ và máy trạm đóng vai trò là điểm sinh log giúp đảm bảo luồng dữ liệu liên tục và đáng tin cậy. Các loại log được ưu tiên lựa chọn bao gồm log đăng nhập SSH, log xác thực hệ thống (ví dụ: Windows Security Event Logs 4624/4625), và log truy cập dịch vụ web. Sự lựa chọn này dựa trên mối liên hệ chặt chẽ của chúng với các kịch bản tấn công phổ biến như dò quét cổng, tấn công vét cạn mật khẩu (brute-force) và leo thang đặc quyền. Việc lựa chọn đúng nguồn log giúp mô hình tập trung nỗ lực phân tích vào các hành vi có ý nghĩa an ninh cao nhất và tránh thu thập dữ liệu dư thừa không cần thiết, từ đó tối ưu hóa hiệu suất xử lý trong môi trường nghiên cứu có hạn chế về tài nguyên.

### *2.3.2. Tiền xử lý Dữ liệu (Data Preprocessing)*

Tiền xử lý dữ liệu là một giai đoạn thiết yếu trong bất kỳ quy trình phát hiện bất thường nào, nhằm chuyển đổi dữ liệu log thô từ trạng thái ban đầu sang một định dạng sạch, đồng nhất và phù hợp để đưa vào các mô hình phân tích học máy. Dữ liệu log thô thường là các luồng dữ liệu lớn, có định dạng không đồng nhất, chứa nhiều thông tin dư thừa, các giá trị thiếu hoặc bị ảnh hưởng nặng bởi

hiệu (noise), những yếu tố này nếu không được xử lý sẽ làm giảm đáng kể hiệu suất và độ chính xác của mô hình phát hiện bất thường.

Quá trình tiền xử lý dữ liệu bao gồm nhiều thao tác quan trọng:

Một là Lọc bỏ bản ghi không liên quan (Filtering Irrelevant Records), nhằm loại bỏ các log sự kiện không có ý nghĩa an ninh hoặc log hoạt động quá thường xuyên đến mức trở thành nhiễu.

Hai là Chuẩn hóa định dạng (Normalization), bao gồm việc chuẩn hóa định dạng thời gian (timestamp) để đảm bảo tính nhất quán giữa các nguồn log khác nhau, và chuyển đổi các trường dữ liệu rời rạc (categorical data) thành định dạng số hóa (numerical format) phù hợp cho các thuật toán học máy.

Ba là Xử lý giá trị thiếu (Handling Missing Values), nơi các giá trị trống hoặc lỗi được xử lý bằng cách loại bỏ bản ghi đó hoặc điền vào bằng các phương pháp thống kê (ví dụ: giá trị trung bình hoặc giá trị mặc định).

Bốn là Trích xuất và Tổng hợp Đặc trưng (Feature Extraction and Aggregation), là bước quan trọng nhất trong việc chuyển đổi log sự kiện thành các đặc trưng có ý nghĩa, ví dụ như tổng hợp số lượng sự kiện, số lượng kết nối, hoặc lưu lượng dữ liệu trong một khoảng thời gian cố định.

Trong môi trường SOC mini, quá trình tiền xử lý dữ liệu được thực hiện một cách hiệu quả trực tiếp thông qua các công cụ thu thập và quản lý log như Splunk. Các truy vấn SPL (Search Processing Language) mạnh mẽ của Splunk cho phép trích xuất các trường dữ liệu quan trọng (ví dụ: địa chỉ IP nguồn, đích, mã lỗi) và tổng hợp dữ liệu theo các cửa sổ thời gian (time windows) cố định. Việc tiền xử lý tại chỗ này không chỉ giúp dữ liệu trở nên nhất quán và phù hợp hơn cho các bước phân tích mô hình tiếp theo, mà còn giúp giảm độ phức tạp tính toán và dung lượng lưu trữ cần thiết cho mô hình. Độ chính xác và hiệu suất của toàn bộ hệ thống phát hiện bất thường phụ thuộc rất lớn vào chất lượng của giai đoạn tiền xử lý dữ liệu này.

### 2.3.3. Trích Đặc trưng (Feature Extraction)

Trích đặc trưng là giai đoạn kế tiếp sau tiền xử lý, đóng vai trò chuyển đổi dữ liệu đã được làm sạch và tổng hợp thành các thuộc tính số hóa có ý nghĩa sâu sắc đối với mô hình phát hiện bất thường. Sự thành công của bất kỳ mô hình học máy nào đều phụ thuộc vào chất lượng của tập đặc trưng đầu vào, bởi lẽ các đặc trưng được lựa chọn cần phải phản ánh rõ bản chất hành vi hoạt động của hệ thống và phải có khả năng phân biệt hiệu quả giữa trạng thái vận hành bình thường và trạng thái có sự cố hoặc tấn công bất thường.

Trong bối cảnh phân tích an ninh mạng, các đặc trưng được xây dựng thường tập trung vào việc định lượng các hành vi giao tiếp, tần suất hoạt động

và sự phân tán của các sự kiện. Các đặc trưng phổ biến bao gồm: số lượng sự kiện xảy ra trong một khoảng thời gian cố định, tổng số lần đăng nhập thất bại, số lượng địa chỉ IP nguồn khác nhau tương tác với một tài nguyên, hoặc khoảng thời gian giữa các sự kiện liên tiếp. Việc lựa chọn đặc trưng phù hợp giúp mô hình tập trung vào bản chất thay đổi của hành vi (ví dụ: đột biến tần suất) thay vì các chi tiết log không quan trọng, từ đó nâng cao độ nhạy và hiệu quả phát hiện bất thường của hệ thống.

| Đặc trưng                       | Mô tả                                             | Ý nghĩa an ninh              |
|---------------------------------|---------------------------------------------------|------------------------------|
| Số lần đăng nhập thất bại       | Tổng số sự kiện login fail trong khoảng thời gian | Phát hiện brute-force        |
| Số IP nguồn                     | Số lượng địa chỉ IP khác nhau                     | Phát hiện tấn công phân tán  |
| Tần suất sự kiện                | Số sự kiện trên đơn vị thời gian                  | Phát hiện hành vi bất thường |
| Thời gian giữa các lần truy cập | Khoảng cách thời gian giữa các sự kiện            | Nhận diện truy cập tự động   |

Bảng 3: Các Đặc trưng Phổ biến trong Phát hiện Bất thường từ Log An ninh

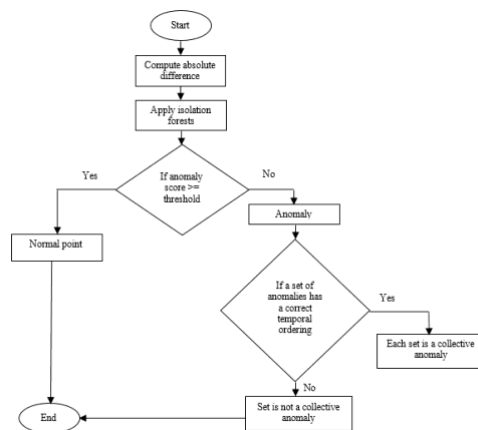
Bảng 3: Một số đặc trưng phổ biến dùng trong phát hiện bất thường từ log an ninh cung cấp một cái nhìn hệ thống về mối liên hệ giữa các thuộc tính được trích xuất và ý nghĩa an ninh tiềm tàng của chúng. Cụ thể, đặc trưng Số lần đăng nhập thất bại (Total login fail events within a time window) là chỉ số trực tiếp giúp phát hiện các cuộc tấn công vét cạn mật khẩu (brute-force) hoặc tấn công từ điển, nơi kẻ tấn công cố gắng thử một lượng lớn mật khẩu trong thời gian ngắn. Tương tự, đặc trưng Số IP nguồn (Number of distinct source IPs) là chỉ báo quan trọng cho việc phát hiện các cuộc tấn công phân tán, nơi lưu lượng truy cập đáng ngờ được rải từ nhiều nguồn khác nhau để tránh bị các cơ chế phát hiện đơn giản nhận diện. Tần suất sự kiện (Event frequency per unit time) giúp định lượng tốc độ hoạt động, từ đó nhận diện sự gia tăng đột ngột của một loại hoạt động nào đó. Cuối cùng, Thời gian giữa các lần truy cập (Time difference between consecutive events) giúp nhận diện hành vi truy cập tự động của robot hoặc script, vốn có khoảng thời gian giữa các hành động rất đồng đều, khác biệt rõ rệt so với hành vi của người dùng thông thường. Việc tích hợp các đặc trưng đa dạng và có tính phân biệt cao này là yếu tố then chốt để xây dựng mô hình phát hiện bất thường mạnh mẽ và toàn diện.

#### 2.3.4. Huấn luyện mô hình

Sau khi hoàn thành bước trích đặc trưng, dữ liệu được sử dụng để huấn luyện mô hình phát hiện bất thường. Trong bối cảnh SOC mini, các mô hình học máy không giám sát như Isolation Forest hoặc các phương pháp thống kê thường

được ưu tiên lựa chọn do không yêu cầu dữ liệu gán nhãn, phù hợp với thực tế vận hành khi các mẫu tấn công chưa được xác định rõ ràng từ trước. Quá trình huấn luyện nhằm giúp mô hình học được các đặc trưng đại diện cho hành vi hoạt động bình thường của hệ thống dựa trên dữ liệu lịch sử đã thu thập.

Trong quá trình huấn luyện, dữ liệu đầu vào thường được giả định là chủ yếu phản ánh trạng thái bình thường của hệ thống, hoặc chỉ chứa một tỷ lệ nhỏ các hành vi bất thường. Mô hình sẽ khai thác các đặc trưng thống kê hoặc cấu trúc phân bố của dữ liệu để xây dựng ranh giới phân biệt giữa hành vi bình thường và các sai lệch tiềm ẩn. Đối với Isolation Forest, mô hình học cách cô lập các điểm dữ liệu hiếm gặp thông qua việc xây dựng nhiều cây phân tách ngẫu nhiên, trong khi các phương pháp thống kê học các giá trị đặc trưng như trung bình, phương sai hoặc phân vị của dữ liệu.



Hình 11: Minh họa quá trình huấn luyện mô hình phát hiện bất thường

Hình 11 mô tả quá trình huấn luyện mô hình phát hiện bất thường, trong đó dữ liệu đặc trưng được đưa vào mô hình để học các mẫu hành vi bình thường. Kết quả của quá trình huấn luyện là một mô hình có khả năng gán điểm số bất thường cho các quan sát mới. Trong SOC mini, mô hình sau huấn luyện thường được lưu lại và sử dụng để phân tích dữ liệu theo thời gian gần thực, phục vụ cho việc sinh cảnh báo an ninh.

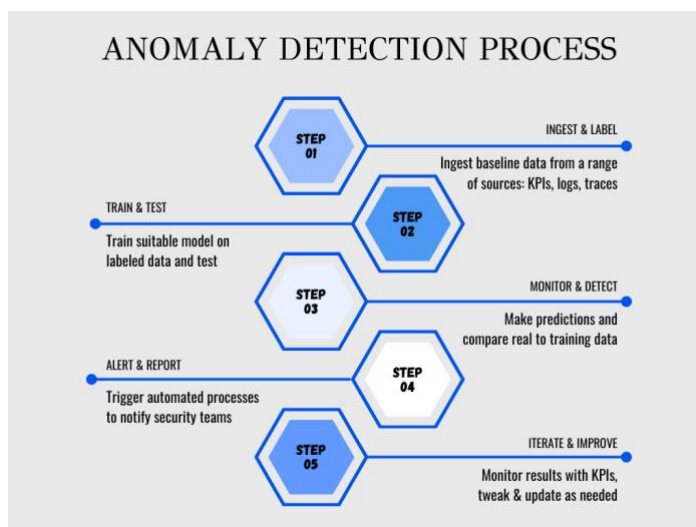
Việc lựa chọn và điều chỉnh các tham số mô hình đóng vai trò quan trọng trong quá trình huấn luyện. Các tham số như số lượng cây, tỷ lệ mẫu hoặc ngưỡng xác định bất thường ảnh hưởng trực tiếp đến mức độ nhạy của mô hình. Nếu tham số được cấu hình quá nhạy, mô hình có thể sinh ra nhiều cảnh báo giả, trong khi cấu hình không chặt chẽ có thể dẫn đến việc bỏ sót các hành vi bất thường thực sự. Do đó, trong SOC mini, mục tiêu của huấn luyện không phải đạt độ chính xác tuyệt đối mà là xây dựng một mô hình có khả năng minh họa rõ ràng nguyên lý phát hiện bất thường và hỗ trợ sinh cảnh báo có ý nghĩa để phục vụ nghiên cứu và đào tạo.



### 2.3.5. Đánh giá mô hình

Đánh giá mô hình là bước cuối cùng trong quy trình xây dựng mô hình phát hiện bất thường, nhằm kiểm tra mức độ hiệu quả và tính phù hợp của mô hình trong môi trường vận hành thực tế. Đối với các mô hình không giám sát, việc đánh giá thường gặp nhiều thách thức do thiếu dữ liệu gán nhãn và khó xác định chính xác ranh giới giữa hành vi bình thường và bất thường. Vì vậy, quá trình đánh giá thường dựa trên các kịch bản thử nghiệm, quan sát thực nghiệm và phân tích mức độ hợp lý của các cảnh báo sinh ra.

Trong SOC mini, một cách đánh giá phổ biến là mô phỏng các hành vi tấn công đơn giản như tấn công brute-force, dò quét cổng hoặc truy cập dịch vụ với tần suất cao bất thường, sau đó quan sát phản ứng của mô hình. Khi mô hình được huấn luyện đúng cách, các hành vi mô phỏng này sẽ được gán điểm số bất thường cao và kích hoạt cảnh báo. Ngược lại, các hoạt động hợp lệ trong điều kiện bình thường sẽ ít bị gán cờ bất thường, giúp hạn chế số lượng cảnh báo giả.



Hình 12: Minh họa quá trình đánh giá mô hình phát hiện bất thường trong SOC

Hình 12 minh họa quá trình đánh giá mô hình thông qua việc so sánh các cảnh báo sinh ra với các kịch bản hoạt động đã được kiểm soát. Các cảnh báo được phân tích để xác định mức độ phù hợp và tính nhất quán với hành vi quan sát được trong hệ thống. Trong SOC mini, kết quả đánh giá thường được thể hiện thông qua số lượng cảnh báo, mức độ nghiêm trọng và khả năng phát hiện các kịch bản tấn công mẫu.

Thông qua quá trình đánh giá, các điểm mạnh và hạn chế của mô hình được làm rõ, từ đó cung cấp cơ sở cho việc điều chỉnh tham số hoặc lựa chọn phương pháp phát hiện khác phù hợp hơn. Việc đánh giá không chỉ giúp cải thiện chất lượng mô hình mà còn đóng vai trò quan trọng trong việc minh họa mối liên hệ

giữa lý thuyết và thực tiễn, giúp người học hiểu rõ hơn cách thức một mô hình phát hiện bất thường được triển khai và vận hành trong SOC.

## 2.4. Ứng dụng cơ bản của Splunk trong phát hiện bất thường

Trong mô hình SOC, Splunk được sử dụng như một nền tảng trung tâm để thu thập, phân tích dữ liệu log và hỗ trợ phát hiện các sự kiện an ninh. Nhờ khả năng xử lý dữ liệu theo thời gian gần thực và cung cấp công cụ phân tích linh hoạt, Splunk cho phép triển khai các phương pháp phát hiện bất thường từ mức đơn giản dựa trên thống kê đến các mô hình học máy nâng cao. Trong phạm vi SOC mini, Splunk được khai thác chủ yếu thông qua ba thành phần chính gồm ngôn ngữ truy vấn SPL, cơ chế cảnh báo (alert) và các công cụ phân tích học máy như Splunk Machine Learning Toolkit khi điều kiện cho phép.



Hình 13: Ứng dụng Splunk trong phân tích log, phát hiện bất thường và sinh cảnh báo

Hình 13 minh họa quy trình ứng dụng Splunk trong SOC, từ việc thu thập log, phân tích bằng SPL, phát hiện bất thường đến sinh cảnh báo và kích hoạt phản ứng. Hình ảnh cho thấy Splunk đóng vai trò là cầu nối giữa dữ liệu log thô và các quyết định an ninh, giúp SOC chuyển hóa dữ liệu thành thông tin có giá trị phục vụ giám sát và ứng phó sự cố.

### 2.4.1. Ngôn ngữ truy vấn SPL trong phân tích và phát hiện bất thường

Search Processing Language (SPL) là ngôn ngữ truy vấn cốt lõi của Splunk, cho phép thực hiện các thao tác tìm kiếm, lọc, tổng hợp và phân tích dữ liệu log với mức độ linh hoạt cao. Trong mô hình SOC mini, SPL đóng vai trò đặc biệt

quan trọng do cho phép triển khai các kỹ thuật phát hiện bất thường dựa trên thống kê và quy luật đơn giản mà không cần đến các công cụ học máy phức tạp.

Thông qua SPL, dữ liệu log có thể được tổ chức lại theo nhiều chiều khác nhau như thời gian, địa chỉ IP nguồn, tài khoản người dùng hoặc loại sự kiện. Từ đó, các chỉ số thống kê như số lượng sự kiện trong một khoảng thời gian, tần suất xuất hiện của một hành vi hoặc giá trị trung bình có thể được tính toán và so sánh với trạng thái hoạt động thông thường. Việc phát hiện sự sai lệch của các chỉ số này là cơ sở để nhận diện các hành vi bất thường.

Trong thực tế, một ví dụ phổ biến trong SOC mini là giám sát log xác thực của hệ thống Linux. Thông thường, số lần đăng nhập thất bại qua SSH trong một khoảng thời gian ngắn là rất thấp. Khi SPL được sử dụng để thống kê số lần đăng nhập thất bại theo từng khoảng thời gian cố định, việc xuất hiện các khoảng thời gian có số lượng đăng nhập thất bại tăng đột biến có thể được xem là dấu hiệu của tấn công brute-force. SPL cho phép xác định rõ thời điểm xảy ra bất thường, tài khoản bị nhắm tới và địa chỉ IP nguồn, từ đó hỗ trợ quá trình phân tích và điều tra sự cố.

Ngoài chức năng phát hiện, SPL còn hỗ trợ quá trình điều tra sự cố thông qua việc truy vết chuỗi sự kiện liên quan. Khi một bất thường được phát hiện, người vận hành có thể sử dụng SPL để mở rộng phạm vi truy vấn, xác định các sự kiện xảy ra trước và sau thời điểm bất thường, từ đó làm rõ bối cảnh và nguyên nhân của sự cố.

#### *2.4.2. Cơ chế cảnh báo (Alert) trong Splunk*

Cảnh báo là thành phần giúp chuyển kết quả phân tích dữ liệu thành hành động cụ thể trong quá trình vận hành SOC. Trong Splunk, cảnh báo được xây dựng dựa trên kết quả của các truy vấn SPL và được kích hoạt khi các điều kiện xác định trước được thỏa mãn. Các điều kiện này có thể dựa trên ngưỡng giá trị, số lượng sự kiện hoặc sự xuất hiện của các mẫu hành vi bất thường.

Trong SOC mini, cảnh báo thường được sử dụng để thông báo kịp thời cho người vận hành khi phát hiện các dấu hiệu tấn công hoặc hành vi bất thường. Ví dụ, khi một truy vấn SPL phát hiện số lần đăng nhập thất bại vượt quá ngưỡng cho phép trong một khoảng thời gian ngắn, Splunk có thể sinh cảnh báo để cảnh báo về khả năng xảy ra tấn công brute-force. Cảnh báo này có thể được cấu hình để gửi thông báo qua email, ghi nhận sự kiện vào hệ thống hoặc kích hoạt một script phản ứng đơn giản.

# splunk® alerts

The screenshot shows the Splunk Alerts configuration page. The 'Settings' section on the left includes an 'Alert' description, 'Alert type' (Scheduled/Real-time), 'Time Range' (All time), 'Cron Expression' (0 5 \* \* \*), 'Trigger Conditions' (Number of Results, is equal to 0), and 'Trigger' (Once). The 'When triggered' section on the right includes a 'Send email' checkbox, 'To' (j.smith@corporation.com), 'Priority' (Normal), 'Subject' (Splunk Alert: \$name\$), 'Message' (The alert condition for \$name\$ was triggered.), and 'Include' options (Link to Alert, Link to Results, Search String, Inline CSV, Trigger Condition, Attach CSV, Attach PDF). The 'Type' dropdown is set to 'HTML & Plain Text'.

Hình 15: Thiết lập và kích hoạt cảnh báo trong Splunk

Hình 15 minh họa giao diện cấu hình cảnh báo trong Splunk, nơi người vận hành có thể xác định điều kiện kích hoạt và hành động tương ứng. Hình ảnh cho thấy cảnh báo là cầu nối giữa phân tích dữ liệu và phản ứng sự cố, giúp SOC giảm thiểu độ trễ giữa thời điểm phát sinh bất thường và thời điểm xử lý.

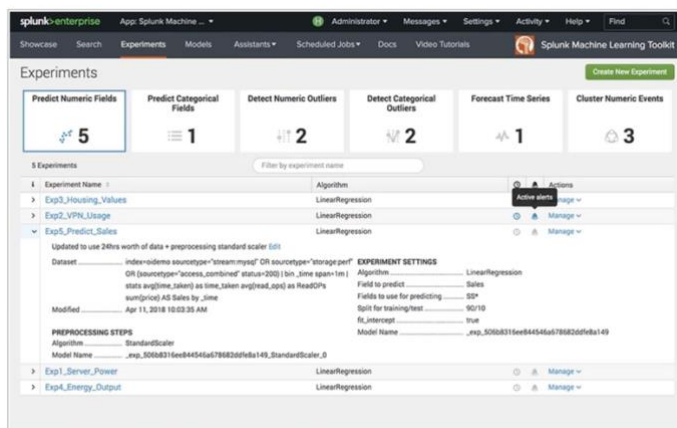
Việc triển khai cơ chế cảnh báo trong SOC mini không chỉ giúp nâng cao khả năng phát hiện sớm mà còn minh họa rõ vai trò của Splunk trong quy trình vận hành SOC. Thông qua cảnh báo, người học có thể hiểu được cách các kết quả phân tích được chuyên hóa thành tín hiệu cảnh báo và hỗ trợ ra quyết định trong thực tế.

### 2.4.3. Ứng dụng Splunk Machine Learning Toolkit trong phát hiện bất thường

Splunk Machine Learning Toolkit (MLTK) là một bộ công cụ mở rộng cho phép tích hợp các thuật toán học máy trực tiếp vào quá trình phân tích dữ liệu trong Splunk. MLTK cung cấp nhiều phương pháp phân tích khác nhau, bao gồm clustering, regression và các thuật toán phát hiện bất thường, cho phép xây dựng và áp dụng mô hình học máy ngay trên dữ liệu log đã được thu thập và xử lý.

Trong bối cảnh SOC mini, MLTK có thể được sử dụng để triển khai các mô hình phát hiện bất thường không giám sát như Isolation Forest hoặc các phương pháp dựa trên phân bố thống kê. Ví dụ, dữ liệu log sau khi được trích xuất đặc trưng có thể được đưa vào mô hình Isolation Forest để học hành vi hoạt động bình thường của hệ thống. Khi dữ liệu mới được phân tích, mô hình sẽ gán điểm

số bất thường cho từng quan sát, từ đó hỗ trợ phát hiện các hành vi sai lệch so với trạng thái thông thường.



Hình 16: Ứng dụng Splunk Machine Learning Toolkit trong phát hiện bất thường

Hình 16 minh họa việc áp dụng các thuật toán học máy trong Splunk thông qua MLTK, cho phép người dùng huấn luyện và sử dụng mô hình phát hiện bất thường trực tiếp trên nền tảng Splunk. Điều này cho thấy khả năng mở rộng của Splunk từ một hệ thống phân tích log truyền thống sang nền tảng hỗ trợ trí tuệ nhân tạo.

Tuy nhiên, trong phạm vi SOC mini, việc sử dụng MLTK chủ yếu mang tính minh họa và thử nghiệm do hạn chế về tài nguyên và quy mô dữ liệu. Mục tiêu không phải là xây dựng mô hình có độ chính xác cao như trong môi trường doanh nghiệp, mà là làm rõ cách thức tích hợp học máy vào quy trình giám sát an ninh và vai trò của trí tuệ nhân tạo trong việc nâng cao khả năng phát hiện bất thường.

## 2.5. Tổng kết Chương II

Chương II tập trung trình bày các vấn đề lý thuyết liên quan đến phát hiện bất thường bằng trí tuệ nhân tạo trong bối cảnh SOC. Trước hết, chương đã làm rõ khái niệm phát hiện bất thường, phân tích ý nghĩa và vai trò của hướng tiếp cận này trong việc bổ sung cho các phương pháp phát hiện dựa trên luật hoặc chữ ký truyền thống. Các dạng bất thường thường gặp trong dữ liệu an ninh mạng cũng được phân tích nhằm làm rõ đặc điểm và khả năng ứng dụng trong giám sát hệ thống.

Tiếp theo, chương đã giới thiệu và phân tích một số phương pháp phát hiện bất thường đơn giản, phù hợp với môi trường SOC mini, bao gồm phương pháp ngưỡng thống kê, Isolation Forest và Local Outlier Factor. Việc so sánh các

phương pháp này giúp làm rõ ưu điểm, hạn chế và mức độ phù hợp của từng phương pháp trong điều kiện hạ tầng và dữ liệu hạn chế.

Bên cạnh đó, chương đã trình bày quy trình cơ bản để xây dựng một mô hình phát hiện bất thường, từ thu thập dữ liệu, tiền xử lý, trích đặc trưng, huấn luyện đến đánh giá mô hình. Trên cơ sở đó, các ứng dụng cơ bản của Splunk trong phát hiện bất thường đã được giới thiệu, bao gồm việc sử dụng ngôn ngữ truy vấn SPL, cơ chế cảnh báo và khả năng tích hợp học máy thông qua Splunk Machine Learning Toolkit.

Nhìn chung, Chương II đã cung cấp cơ sở lý thuyết và phương pháp luận cho việc triển khai phát hiện bất thường trong mô hình SOC mini. Những nội dung này là nền tảng trực tiếp cho Chương III, nơi đề án sẽ tập trung vào thiết kế và triển khai mô hình SOC mini, cũng như áp dụng các phương pháp đã nghiên cứu vào thực nghiệm cụ thể.

## Chương III. Thiết kế và triển khai mô hình SOC mini

### 3.1. Kiến trúc tổng thể SOC mini

Mục tiêu của mô hình SOC mini trong đồ án là xây dựng một môi trường thử nghiệm đơn giản nhưng vẫn phản ánh được các chức năng cốt lõi của một SOC, bao gồm thu thập dữ liệu log, phân tích, phát hiện bất thường và phản ứng sự cố ở mức cơ bản. Do đó, kiến trúc hệ thống được thiết kế theo hướng tối giản, dễ triển khai trong môi trường máy ảo, đồng thời phù hợp cho mục đích học tập và nghiên cứu.

#### 3.1.1. Lựa chọn mô hình triển khai và công cụ

Mô hình SOC mini được triển khai hoàn toàn trên môi trường máy ảo nhằm đảm bảo tính linh hoạt và dễ tái tạo. Việc sử dụng máy ảo cho phép triển khai nhiều thành phần khác nhau trên cùng một máy vật lý, đồng thời thuận tiện cho việc cấu hình mạng, mô phỏng tấn công và quan sát kết quả.

Trong mô hình này, Splunk được lựa chọn làm nền tảng trung tâm cho việc thu thập và phân tích log. Splunk Universal Forwarder được sử dụng để thu thập log từ các máy sinh log và gửi về Splunk Server. Các máy sinh log được cấu hình để mô phỏng các hành vi sử dụng bình thường cũng như các kịch bản tấn công đơn giản phục vụ cho quá trình thực nghiệm.

#### 3.1.2. Thành phần hệ thống và vai trò của từng máy ảo

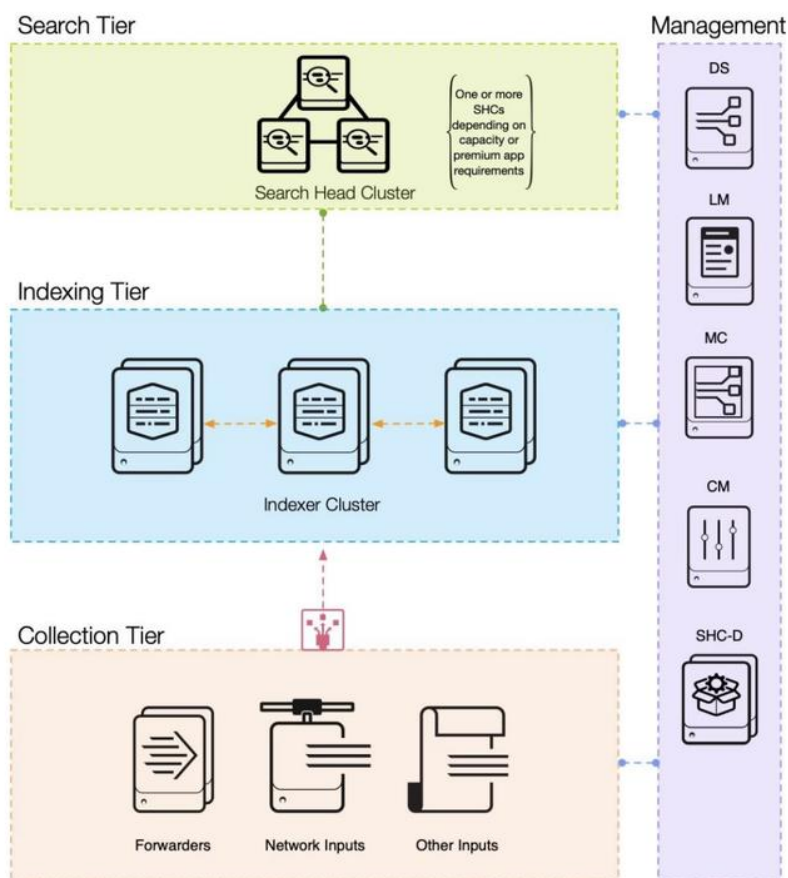
Kiến trúc SOC mini bao gồm ba nhóm thành phần chính, mỗi thành phần đảm nhiệm một vai trò cụ thể trong hệ thống.

Thành phần thứ nhất là máy chủ Splunk Server, đóng vai trò trung tâm của SOC mini. Máy này chịu trách nhiệm tiếp nhận dữ liệu log từ các nguồn khác nhau, lưu trữ, lập chỉ mục và thực hiện các truy vấn phân tích. Ngoài ra, Splunk Server còn đảm nhiệm chức năng sinh cảnh báo khi phát hiện các hành vi bất thường và tích hợp với các script phản ứng đơn giản.

Thành phần thứ hai là máy sinh log Linux, được sử dụng để mô phỏng hệ thống mục tiêu trong SOC. Máy này chạy hệ điều hành Linux và cung cấp các dịch vụ như SSH, từ đó sinh ra các log xác thực và log hệ thống. Các kịch bản tấn công như SSH brute-force hoặc đăng nhập thất bại liên tiếp được thực hiện trên máy này nhằm tạo dữ liệu phục vụ cho việc phát hiện bất thường.



Thành phần thứ ba là máy tấn công hoặc máy người dùng, được sử dụng để mô phỏng các hành vi truy cập bất thường hoặc tấn công đơn giản. Máy này thực hiện các hành vi như đăng nhập sai mật khẩu nhiều lần hoặc dò quét cổng dịch vụ, giúp tạo ra các sự kiện bất thường trong log của hệ thống mục tiêu.



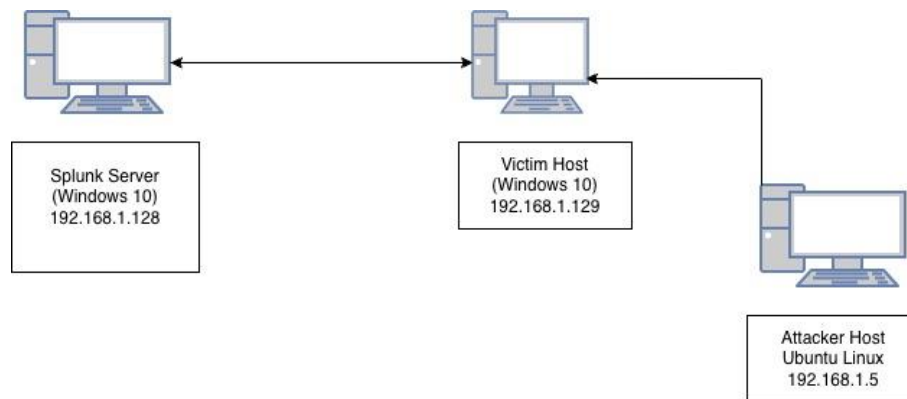
Hình 17: Kiến trúc tổng thể mô hình SOC mini trong môi trường máy ảo

Hình 17 minh họa kiến trúc tổng thể của mô hình SOC mini, trong đó Splunk Server đóng vai trò trung tâm thu thập và phân tích dữ liệu log. Các máy sinh log gửi dữ liệu về Splunk thông qua Splunk Universal Forwarder, tạo nên luồng dữ liệu tập trung phục vụ cho giám sát và phát hiện bất thường. Kiến trúc này giúp người học dễ dàng quan sát mối quan hệ giữa các thành phần và hiểu rõ cách một SOC hoạt động ở mức cơ bản.

### 3.1.3. Mô hình mạng và luồng dữ liệu log

Mô hình mạng của SOC mini trong đồ án được xây dựng dựa trên hạ tầng thực nghiệm đã được triển khai trong đề tài trước về giám sát an toàn thông tin dựa trên Splunk, nhằm tận dụng tính ổn định của mô hình và đảm bảo khả năng tái sử dụng trong quá trình nghiên cứu. Mô hình này được thiết kế theo hướng đơn giản, tập trung vào việc giám sát hệ thống mục tiêu, mô phỏng hành vi tấn công và thu thập dữ liệu log phục vụ cho phát hiện bất thường.





Hình 18: Mô hình mạng thực nghiệm của hệ thống SOC mini

Như thể hiện trong Hình 18, mô hình mạng SOC mini bao gồm ba máy ảo chính được kết nối trong cùng một mạng nội bộ. Splunk Server được triển khai trên hệ điều hành Windows Server 2019 và đóng vai trò là trung tâm của hệ thống SOC mini. Máy này chịu trách nhiệm thu thập, lưu trữ và phân tích dữ liệu log, đồng thời thực hiện các chức năng phát hiện bất thường và sinh cảnh báo.

Máy Victim cũng sử dụng hệ điều hành Windows Server 2019 và đóng vai trò là hệ thống mục tiêu cần được giám sát. Trên máy này diễn ra các hoạt động của người dùng và dịch vụ, từ đó sinh ra các log hệ thống, log bảo mật và các sự kiện liên quan đến hoạt động truy cập. Splunk Universal Forwarder được cài đặt trên máy Victim để thu thập các log cần thiết và gửi về Splunk Server theo thời gian gần thực.

Máy Attacker sử dụng hệ điều hành Kali Linux được triển khai nhằm mô phỏng các hành vi tấn công và truy cập bất thường vào hệ thống Victim. Các kịch bản như đăng nhập sai nhiều lần, dò quét cổng dịch vụ hoặc thực hiện các hành vi nghi ngờ khác được thực hiện từ máy Attacker tới máy Victim, tạo ra các sự kiện an ninh phục vụ cho quá trình phân tích và phát hiện bất thường.

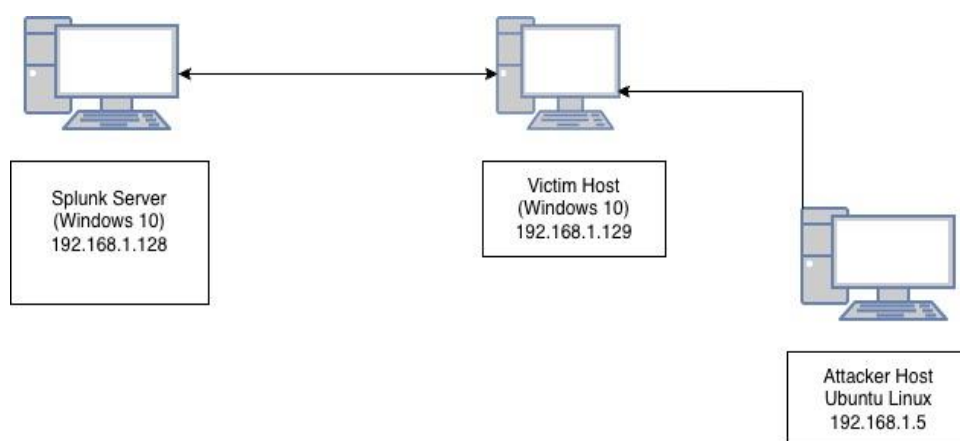
Luồng dữ liệu trong mô hình mạng được thể hiện rõ trong Hình 18. Các hành vi truy cập và tấn công được thực hiện theo hướng từ máy Attacker đến máy Victim, trong khi dữ liệu log phát sinh trên máy Victim được Splunk Universal Forwarder thu thập và chuyển về Splunk Server. Trên Splunk Server, dữ liệu log được phân tích bằng các truy vấn SPL và các phương pháp phát hiện bất thường, từ đó sinh cảnh báo khi phát hiện dấu hiệu nghi ngờ. Chu trình này phản ánh đầy đủ quy trình giám sát và xử lý sự kiện an ninh trong một mô hình SOC mini ở mức cơ bản.

Mô hình mạng như trên đảm bảo tính thực quan, dễ triển khai trong môi trường máy ảo và phù hợp với phạm vi của đề án. Đồng thời, việc kế thừa mô hình đã được sử dụng trong các nghiên cứu trước giúp tăng tính thực tiễn và độ tin cậy cho các kết quả thực nghiệm sẽ được trình bày trong các phần tiếp theo.

## 3.2. Triển khai Splunk và thu thập dữ liệu log

### 3.2.1. Chuẩn bị môi trường và kiểm tra kết nối hệ thống

Trước khi tiến hành cài đặt và cấu hình Splunk để thu thập dữ liệu log, môi trường thực nghiệm của mô hình SOC mini được chuẩn bị và kiểm tra nhằm đảm bảo các điều kiện cần thiết cho quá trình triển khai. Hệ thống được xây dựng trên nền tảng máy ảo với ba máy chính, bao gồm máy chủ Splunk Server, máy Victim và máy Attacker, tất cả đều đã được cài đặt hệ điều hành tương ứng và hoạt động ổn định.

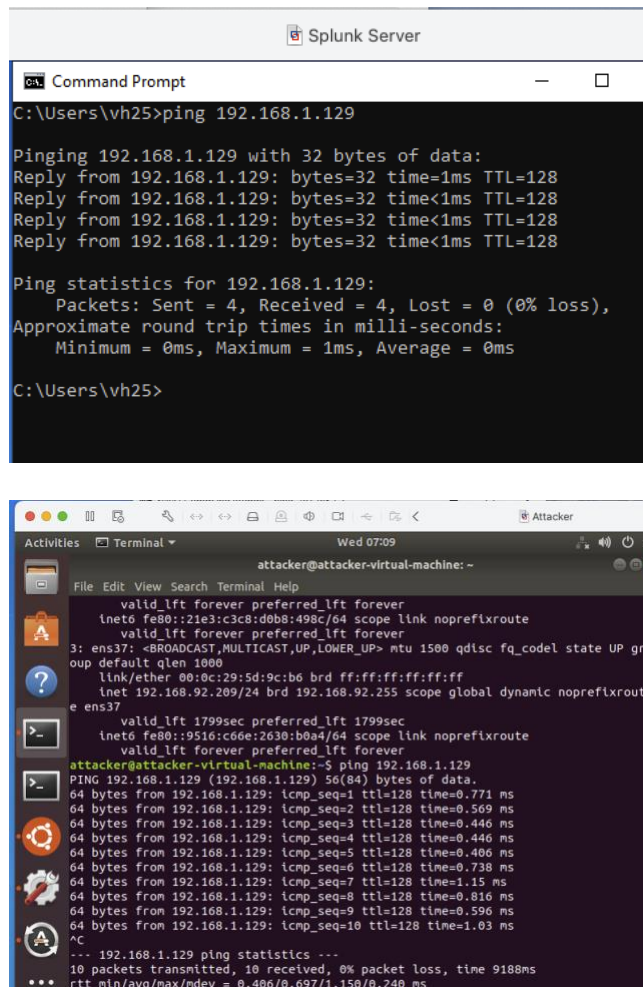


Hình 18: Mô hình mạng thực nghiệm của hệ thống SOC mini

Các máy ảo được cấu hình nằm trong cùng một mạng nội bộ, cho phép giao tiếp trực tiếp giữa các thành phần trong mô hình SOC mini. Việc cấu hình mạng nội bộ giúp đảm bảo các hoạt động thử nghiệm được thực hiện trong môi trường kiểm soát, không ảnh hưởng đến hệ thống mạng bên ngoài. Sau khi hoàn tất cài đặt, các máy ảo được khởi động và kiểm tra trạng thái hoạt động để đảm bảo có thể truy cập và sử dụng bình thường.

Tiếp theo, khả năng kết nối mạng giữa các máy trong hệ thống được kiểm tra thông qua các lệnh kiểm tra kết nối cơ bản. Kết quả kiểm tra cho thấy máy Victim có thể kết nối tới máy chủ Splunk Server, và máy Attacker có thể kết nối tới máy Victim thông qua mạng nội bộ. Điều này xác nhận rằng cấu hình mạng đã được thiết lập đúng và đáp ứng yêu cầu cho việc thu thập và phân tích dữ liệu log trong các bước triển khai tiếp theo.

Việc hoàn tất bước chuẩn bị môi trường và kiểm tra kết nối hệ thống là tiền đề quan trọng cho các bước cấu hình Splunk và Splunk Universal Forwarder. Trên cơ sở môi trường đã được xác nhận hoạt động ổn định, quá trình cài đặt và cấu hình các thành phần của SOC mini được tiến hành ở các mục tiếp theo.



Hình 19: Kiểm tra kết nối mạng giữa các máy ảo trong mô hình SOC mini

### 3.2.2. Cài đặt Splunk Server và Splunk Universal Forwarder

Sau khi hoàn tất bước chuẩn bị môi trường và kiểm tra kết nối hệ thống, quá trình triển khai Splunk và thu thập dữ liệu log được tiến hành. Mục tiêu của bước này là xây dựng một hệ thống thu thập log tập trung, trong đó Splunk Server đóng vai trò trung tâm phân tích, còn Splunk Universal Forwarder được sử dụng để gửi dữ liệu log từ máy được giám sát về máy chủ Splunk.

#### a) Cài đặt và cấu hình Splunk Server

Splunk Enterprise được cài đặt trên máy Splunk Server sử dụng hệ điều hành Windows 10. Bộ cài Splunk Enterprise phiên bản dành cho Windows được tải từ trang chủ chính thức của Splunk nhằm đảm bảo tính ổn định và tương thích với hệ thống. Trong quá trình cài đặt, người thực hiện chấp nhận các điều khoản sử dụng và cấu hình tài khoản quản trị cho Splunk. Các tùy chọn cài đặt được giữ ở mức mặc định để phù hợp với môi trường SOC mini.

Sau khi quá trình cài đặt hoàn tất, Splunk Server được kiểm tra thông qua giao diện web tại địa chỉ cổng mặc định. Kết quả cho thấy Splunk hoạt động ổn

định và có thể truy cập bình thường, cho phép thực hiện các thao tác quản lý và cấu hình hệ thống. Đồng thời, dịch vụ Splunk chạy nền trên hệ điều hành được kiểm tra và xác nhận đang hoạt động, đảm bảo khả năng tiếp nhận dữ liệu log từ các nguồn bên ngoài.

Để phục vụ cho việc lưu trữ và phân tích dữ liệu log, một chỉ mục (index) mới được tạo trên Splunk Server. Chỉ mục này được sử dụng làm nơi lưu trữ dữ liệu log gửi về từ các máy được giám sát trong mô hình SOC mini, giúp việc tìm kiếm và phân tích dữ liệu trở nên thuận tiện hơn trong các bước thực nghiệm tiếp theo.

#### *b) Cài đặt và cấu hình Splunk Universal Forwarder trên máy được giám sát*

Sau khi Splunk Server đã sẵn sàng, Splunk Universal Forwarder được cài đặt trên máy được giám sát (Monitored Host) sử dụng hệ điều hành Windows 10. Universal Forwarder có nhiệm vụ thu thập các log hệ thống và log bảo mật trên máy này, sau đó gửi dữ liệu về Splunk Server theo thời gian gần thực.

Trong quá trình cài đặt Splunk Universal Forwarder, địa chỉ IP và cổng của Splunk Server được cấu hình để đảm bảo forwarder có thể kết nối và gửi dữ liệu log về đúng máy chủ trung tâm. Sau khi cài đặt hoàn tất, dịch vụ Splunk Universal Forwarder được kiểm tra trạng thái hoạt động nhằm xác nhận forwarder đang chạy ổn định trên hệ thống.

Tiếp theo, Universal Forwarder được cấu hình để thu thập các nguồn log quan trọng trên hệ điều hành Windows, bao gồm log hệ thống và log bảo mật. Việc lựa chọn các nguồn log này nhằm phục vụ cho các kịch bản giám sát và phát hiện bất thường sẽ được triển khai trong các phần tiếp theo của đồ án.

#### *c) Kiểm tra thu thập dữ liệu log trên Splunk Server*

Sau khi hoàn tất cấu hình Splunk Server và Splunk Universal Forwarder, quá trình thu thập dữ liệu log được kiểm tra thông qua các truy vấn tìm kiếm cơ bản trên Splunk Web. Kết quả cho thấy các log từ máy được giám sát đã được gửi về Splunk Server và hiển thị trên hệ thống theo thời gian gần thực.

Việc kiểm tra thành công dữ liệu log xác nhận rằng quá trình triển khai Splunk và thu thập log đã được thực hiện đúng, đảm bảo nền tảng dữ liệu cần thiết cho các bước phân tích, phát hiện bất thường và thử nghiệm phản ứng tự động trong mô hình SOC mini.

```

> 19/12/2025 12/19/2025 09:32:09.634 PM
21:32:09.634 LogName=Security
EventCode=4625
EventType=0
ComputerName=victim-host
SourceName=Microsoft Windows security auditing.
Type=Information
RecordNumber=33164
Keywords=Audit Failure
TaskCategory=Logon
OpCode=Info
Message=An account failed to log on.

Subject:
Security ID: S-1-5-18
Account Name: VICTIM-HOST$
Account Domain: WORKGROUP
Logon ID: 0x3E7

```

Hình 20: Bản ghi Windows Security Event ID 4625 – Sự kiện đăng nhập thất bại

Hình 20 minh họa một bản ghi sự kiện bảo mật được thu thập từ Windows Event Log với mã sự kiện Event ID 4625, tương ứng với hành vi đăng nhập không thành công vào hệ thống. Đây là một trong những sự kiện quan trọng nhất trong giám sát an ninh trên nền tảng Windows, thường được sử dụng để phát hiện các dấu hiệu tấn công dò quét mật khẩu hoặc brute-force.

Từ nội dung sự kiện trong hình, có thể thấy LogName được xác định là Security, cho biết đây là log thuộc nhóm bảo mật của hệ điều hành. Trường EventCode = 4625 cùng với Message “An account failed to log on” phản ánh rõ ràng việc hệ thống đã ghi nhận một lần xác thực thất bại. Thông tin ComputerName cho biết sự kiện xảy ra trên máy victim-host, trong khi Keywords = Audit Failure và TaskCategory = Logon giúp phân loại đây là một thất bại trong quá trình đăng nhập.

Ngoài ra, các trường như Account Name, Account Domain và Logon ID cung cấp thêm ngữ cảnh về đối tượng và môi trường mà sự kiện diễn ra. Những thông tin này có giá trị lớn trong quá trình phân tích và điều tra sự cố, cho phép SOC xác định liệu các lần đăng nhập thất bại có mang tính ngẫu nhiên hay có dấu hiệu bất thường về tần suất, thời điểm hoặc nguồn phát sinh.

Việc thu thập và hiển thị thành công sự kiện Event ID 4625 trên Splunk cho thấy quá trình cấu hình Splunk Universal Forwarder và cơ chế thu thập Windows Event Log đã hoạt động đúng như thiết kế. Đồng thời, đây cũng là dữ liệu đầu vào tiêu biểu cho các kịch bản phát hiện bất thường trong SOC mini, chẳng hạn như phát hiện số lượng lớn đăng nhập thất bại trong một khoảng thời gian ngắn hoặc phát hiện hành vi xác thực bất thường so với hành vi thông thường của hệ thống.

### 3.3. Thiết kế dữ liệu log phục vụ giám sát và phát hiện bất thường

Sau khi hoàn tất quá trình triển khai Splunk Server và thu thập log từ máy được giám sát, bước tiếp theo trong SOC mini là phân tích và thiết kế dữ liệu log theo hướng phục vụ giám sát an ninh và phát hiện bất thường. Việc thiết kế dữ liệu log không chỉ nhằm mục đích lưu trữ mà còn giúp chuẩn hóa các trường thông tin quan trọng, từ đó hỗ trợ quá trình phân tích, xây dựng truy vấn SPL và áp dụng các phương pháp phát hiện bất thường.

Trong phạm vi SOC mini của đề tài, Windows Event Log được lựa chọn làm nguồn dữ liệu chính, với trọng tâm là hai nhóm log Security và System. Các bản ghi log này sau khi được thu thập về Splunk sẽ được biểu diễn dưới dạng các sự kiện (event), mỗi sự kiện bao gồm nhiều trường thông tin (field) khác nhau. Tuy nhiên, không phải tất cả các trường đều có ý nghĩa như nhau đối với mục tiêu giám sát an ninh, do đó cần xác định rõ các trường quan trọng để tập trung phân tích.

#### 3.3.1. Cấu trúc chung của một bản ghi Windows Event Log trong Splunk

Khi một sự kiện Windows Event Log được gửi về Splunk, hệ thống sẽ tự động trích xuất và hiển thị các trường thông tin cơ bản. Một bản ghi log điển hình bao gồm các trường như thời gian xảy ra sự kiện, tên máy, nguồn sinh log, mã sự kiện và nội dung mô tả. Đây là các thông tin nền tảng giúp SOC xác định bối cảnh của sự kiện.

```
> 19/12/2025 12/19/2025 09:32:09.634 PM
   21:32:09.634 LogName=Security
                        EventCode=4625
                        EventType=0
                        ComputerName=victim-host
                        SourceName=Microsoft Windows security auditing.
                        Type=Information
                        RecordNumber=33164
                        Keywords=Audit Failure
                        TaskCategory=Logon
                        OpCode=Info
                        Message=An account failed to log on.

                        Subject:
                                Security ID:          S-1-5-18
                                Account Name:         VICTIM-HOST$
                                Account Domain:       WORKGROUP
                                Logon ID:             0x3E7
```

Hình 20: Bản ghi Windows Security Event ID 4625 – Sự kiện đăng nhập thất bại

Các trường thời gian (time) cho biết chính xác thời điểm sự kiện xảy ra, đóng vai trò quan trọng trong việc phân tích chuỗi sự kiện và phát hiện các hành vi bất thường theo thời gian. Trường host phản ánh máy phát sinh log, giúp phân



biệt sự kiện giữa các hệ thống khác nhau trong mô hình SOC mini. Trường sourcetype và LogName cho biết loại log và nguồn sinh log, hỗ trợ việc phân loại và xây dựng truy vấn SPL hiệu quả.

### 3.3.2. Các trường thông tin quan trọng trong Security Event Log

Đối với Security Event Log, các trường thông tin liên quan đến xác thực và truy cập là trọng tâm của quá trình giám sát an ninh. Trường EventCode cho biết loại sự kiện bảo mật, chẳng hạn như đăng nhập thành công, đăng nhập thất bại hoặc tạo tiến trình mới. Đây là cơ sở để phân biệt giữa các hành vi bình thường và các hành vi tiềm ẩn nguy cơ.

```
> 19/12/2025 12/19/2025 09:32:09.634 PM
   21:32:09.634 LogName=Security
                      EventCode=4625
                      EventType=0
                      ComputerName=victim-host
                      SourceName=Microsoft Windows security auditing.
                      Type=Information
                      RecordNumber=33164
                      Keywords=Audit Failure
                      TaskCategory=Logon
                      OpCode=Info
                      Message=An account failed to log on.

                      Subject:
                        Security ID: S-1-5-18
                        Account Name: VICTIM-HOST$
                        Account Domain: WORKGROUP
                        Logon ID: 0x3E7
```

Hình 20: Bản ghi Windows Security Event ID 4625 – Sự kiện đăng nhập thất bại

Các trường như Account Name, Account Domain và Logon ID cung cấp thông tin về tài khoản và ngữ cảnh xác thực. Khi kết hợp với địa chỉ nguồn hoặc loại đăng nhập, SOC có thể xác định được các hành vi đăng nhập bất thường, ví dụ như số lần đăng nhập thất bại tăng đột biến trong một khoảng thời gian ngắn. Trường Keywords và TaskCategory giúp phân loại mức độ và loại hình sự kiện, hỗ trợ quá trình lọc và phân tích nhanh.

Từ bản ghi trong Hình 20 có thể thấy log thuộc nhóm Security, với SourceName là Microsoft Windows security auditing, cho biết sự kiện được sinh ra từ cơ chế kiểm toán bảo mật của hệ điều hành. Trường EventCode = 4625 xác định rõ loại sự kiện là đăng nhập không thành công, trong khi Keywords = Audit Failure và TaskCategory = Logon giúp phân loại đây là một thất bại trong quá trình xác thực người dùng.

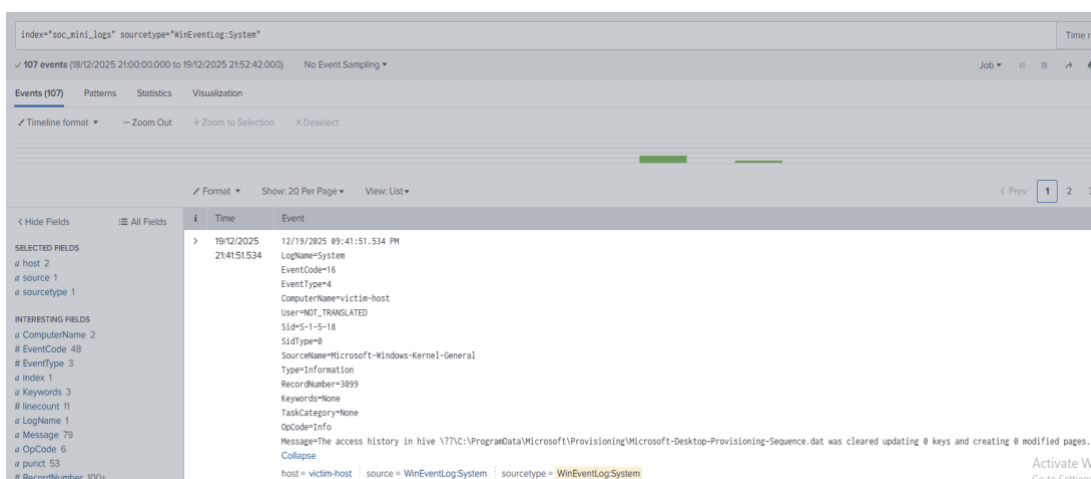
Các trường thông tin chi tiết trong bản ghi, chẳng hạn như ComputerName, Account Name, Account Domain và Logon ID, cung cấp ngữ cảnh quan trọng về môi trường và đối tượng liên quan đến sự kiện. Những thông tin này cho phép hệ thống SOC xác định sự kiện xảy ra trên máy nào, liên quan đến tài khoản nào và

trong bối cảnh xác thực ra sao. Đặc biệt, trường Message với nội dung “An account failed to log on” phản ánh trực tiếp bản chất của sự kiện, giúp người phân tích nhanh chóng nhận diện loại hành vi đang diễn ra.

### 3.3.3. Các trường thông tin quan trọng trong System Event Log

System Event Log phản ánh trạng thái vận hành của hệ điều hành và các thành phần hệ thống. Trong các bản ghi log này, các trường như EventCode, SourceName và Message cho phép SOC xác định các sự kiện liên quan đến dịch vụ, driver hoặc lỗi hệ thống. Những thông tin này đặc biệt hữu ích trong việc phát hiện các hành vi bất thường ở mức hệ thống, chẳng hạn như dịch vụ bị dừng đột ngột hoặc hệ thống khởi động lại không mong muốn.

Khi kết hợp System log với Security log, SOC có thể xây dựng bức tranh toàn diện hơn về sự cố. Ví dụ, một chuỗi đăng nhập thất bại trong Security log đi kèm với sự kiện dừng dịch vụ trong System log có thể là dấu hiệu của một hành vi tấn công hoặc sự cố an ninh nghiêm trọng hơn.



Hình 21: Một sự kiện trong system được ghi lại

Từ hình ảnh có thể quan sát thấy các sự kiện thuộc LogName = System, với sourcetype = WinEventLog:System, cho biết dữ liệu được lấy từ hệ thống ghi log chuẩn của Windows. Trường EventCode = 16 trong ví dụ minh họa đại diện cho một sự kiện thông tin do thành phần Microsoft-Windows-Kernel-General sinh ra. Các sự kiện dạng này thường liên quan đến hoạt động nội bộ của hệ điều hành, chẳng hạn như quản lý bộ nhớ, registry hoặc trạng thái dịch vụ hệ thống.

Trường ComputerName cho biết sự kiện phát sinh trên máy victim-host, giúp SOC xác định chính xác hệ thống nguồn trong mô hình mạng. Trường SourceName phản ánh thành phần hoặc dịch vụ hệ thống sinh ra log, là cơ sở để phân biệt các sự kiện liên quan đến kernel, dịch vụ mạng hay driver. Bên cạnh đó, các trường như EventType, TaskCategory và OpCode cung cấp thêm thông tin phân loại, hỗ trợ việc lọc và nhóm các sự kiện có cùng bản chất.

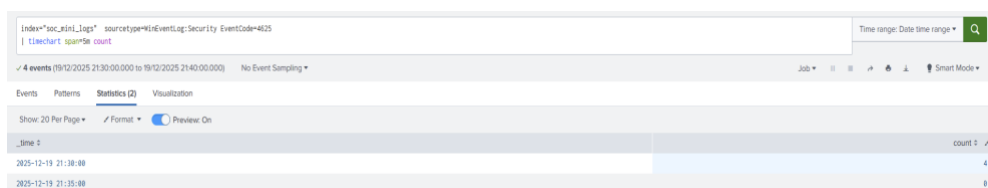


Nội dung chi tiết của sự kiện được thể hiện trong trường Message, trong đó mô tả cụ thể hành động hoặc trạng thái mà hệ điều hành đã ghi nhận. Trong Hình 21, thông điệp cho thấy một thao tác liên quan đến truy cập và cập nhật dữ liệu trong registry của hệ thống. Những thông tin dạng này đặc biệt hữu ích trong việc phát hiện các hành vi bất thường ở mức hệ thống, ví dụ như thay đổi cấu hình trái phép, dịch vụ bị tác động hoặc dấu hiệu hoạt động của mã độc.

#### 3.3.4. Định hướng sử dụng dữ liệu log cho phát hiện bất thường

Việc thiết kế dữ liệu log trong SOC mini không chỉ dừng lại ở việc thu thập và hiển thị, mà còn hướng tới việc sử dụng các trường thông tin quan trọng để xây dựng các chỉ số giám sát và đặc trưng cho mô hình phát hiện bất thường. Các chỉ số như số lượng sự kiện theo thời gian, tần suất đăng nhập thất bại, hoặc số lượng sự kiện hệ thống bất thường có thể được trích xuất trực tiếp từ các trường trong log.

Những dữ liệu này sẽ được sử dụng làm đầu vào cho các truy vấn SPL, các cơ chế cảnh báo và các mô hình phát hiện bất thường đơn giản trong các phần tiếp theo của đề tài. Nhờ đó, SOC mini không chỉ minh họa quá trình thu thập log mà còn thể hiện rõ vai trò của dữ liệu log trong việc phát hiện và phản ứng trước các sự cố an ninh.



The screenshot shows a Splunk search interface with the query `index="soc_mini_logs" sourcetype=WinEventLog:Security EventCode=4625`. The results table has two columns: `_time` and `count`. There are two data rows, both with a count of 4.

| _time               | count |
|---------------------|-------|
| 2025-12-19 21:18:00 | 4     |
| 2025-12-19 21:15:00 | 4     |

Hình 22: Kết quả của truy vấn SPL

Hình 22 minh họa kết quả truy vấn các bản ghi Windows Security Event Log với điều kiện lọc EventCode = 4625 trên Splunk. Đây là mã sự kiện đại diện cho hành vi đăng nhập thất bại, một trong những chỉ dấu quan trọng thường được sử dụng trong giám sát an ninh và phát hiện các hành vi tấn công dò quét hoặc brute-force trong SOC.

Từ kết quả truy vấn có thể thấy, trong khoảng thời gian ngắn hệ thống đã ghi nhận nhiều sự kiện đăng nhập thất bại liên tiếp trên máy victim-host. Các bản ghi đều thuộc LogName = Security và sourcetype = WinEventLog:Security, xác nhận rằng dữ liệu được thu thập từ cơ chế auditing bảo mật mặc định của Windows. Việc các sự kiện tập trung trong một khung thời gian hẹp cho thấy dấu hiệu bất thường so với hành vi sử dụng thông thường, vốn thường chỉ phát sinh rải rác các lỗi xác thực do người dùng nhập sai mật khẩu.

### 3.3.5. Các kịch bản giám sát trong SOC mini

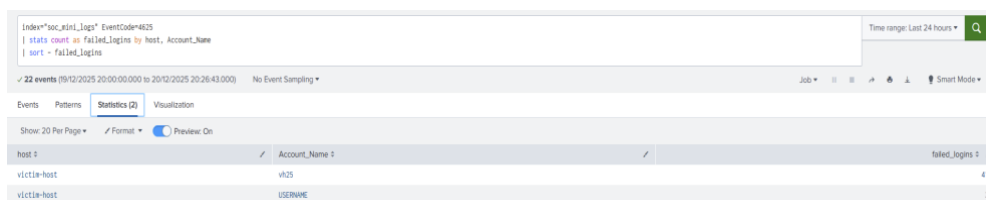
Sau khi xác định các trường thông tin quan trọng trong Windows Event Log, bước tiếp theo trong thiết kế SOC mini là lựa chọn các kịch bản giám sát phù hợp. Mục tiêu của các kịch bản này không phải là mô phỏng tấn công phức tạp, mà nhằm minh họa cách SOC phát hiện các hành vi bất thường dựa trên dữ liệu log thu thập được.

Trong phạm vi đồ án, các kịch bản giám sát được lựa chọn tập trung vào những hành vi phổ biến, dễ quan sát trong môi trường thực tế và có ý nghĩa cao đối với giám sát an ninh ở mức cơ bản. Cụ thể, SOC mini tập trung vào ba nhóm hành vi chính: đăng nhập thất bại liên tiếp, truy cập SSH bất thường và dấu hiệu dò quét cổng dịch vụ.

#### a) Kịch bản giám sát đăng nhập thất bại liên tiếp (Login failure monitoring)

Đăng nhập thất bại là một hành vi thường xuyên xuất hiện trong hệ thống do người dùng nhập sai mật khẩu hoặc cấu hình dịch vụ chưa chính xác. Tuy nhiên, trong điều kiện hoạt động bình thường, các sự kiện này thường xuất hiện rải rác và không tập trung trong một khoảng thời gian ngắn.

SOC mini giám sát hành vi đăng nhập thất bại thông qua các bản ghi Windows Security Event Log với Event ID 4625. Khi số lượng sự kiện đăng nhập thất bại tăng đột biến trong một khoảng thời gian ngắn trên cùng một máy hoặc cùng một tài khoản, đây được xem là một dấu hiệu bất thường. Hành vi này có thể phản ánh nỗ lực truy cập trái phép hoặc dò đoán thông tin xác thực.



| host        | Account_Name | failed_logins |
|-------------|--------------|---------------|
| victia-host | v25          | 41            |
| victia-host | USERNAME     | 3             |

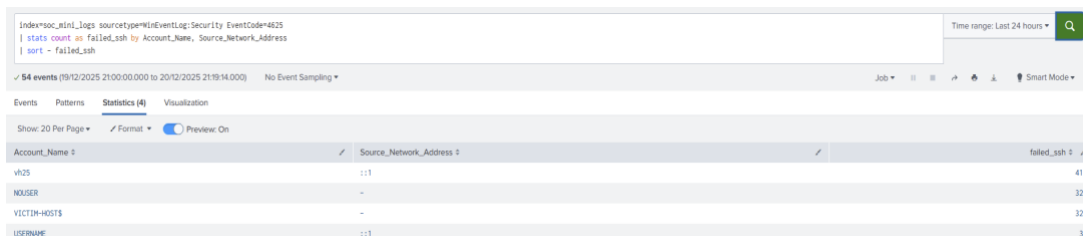
Hình 23: Kết quả truy vấn của một cuộc dò quét mật khẩu được ghi lại

Trong kịch bản này, SOC không quan tâm đến nội dung cụ thể của từng lần đăng nhập, mà tập trung vào tần suất và mật độ xuất hiện của sự kiện. Việc giám sát dựa trên số lượng và thời gian giúp SOC phát hiện sớm các dấu hiệu bất thường ngay cả khi chưa xác định rõ nguồn gốc tấn công.

#### b) Kịch bản giám sát truy cập SSH bất thường

Trong môi trường SOC mini, dịch vụ SSH được sử dụng như một dịch vụ đại diện cho các cơ chế truy cập từ xa. Các hoạt động truy cập SSH hợp lệ thường có tần suất ổn định và gắn với một số tài khoản hoặc địa chỉ nguồn quen thuộc.

SOC mini giám sát hành vi truy cập SSH thông qua các log xác thực liên quan đến dịch vụ SSH trên hệ thống được giám sát. Thay vì phân tích chi tiết từng lần kết nối, SOC tập trung vào các dấu hiệu bất thường như số lượng lớn lần xác thực thất bại, truy cập lặp lại trong thời gian ngắn hoặc truy cập từ các nguồn không quen thuộc.



| Account_Name | Source_Network_Address | failed_ssh |
|--------------|------------------------|------------|
| vh25         | 111                    | 41         |
| NOUSER       | -                      | 32         |
| VICTIM-HOSTS | -                      | 32         |
| USERNAME     | 111                    | 3          |

Hình 24: Kết quả truy vấn của việc truy cập SSH bất thường

Việc giám sát hành vi SSH ở mức tổng quát cho phép SOC phát hiện sớm các dấu hiệu bất thường mà không cần hiểu rõ kỹ thuật tấn công cụ thể. Điều này phù hợp với mục tiêu của SOC mini là minh họa nguyên lý giám sát dựa trên hành vi thay vì phân tích sâu từng kỹ thuật khai thác.

### c) Kịch bản giám sát dấu hiệu dò quét cổng dịch vụ (Port scan monitoring)

#### 1, Mục tiêu giám sát

Mục tiêu của kịch bản này là giám sát và phát hiện hành vi quét cổng mạng (port scanning) từ máy bên ngoài vào máy nạn nhân trong hệ thống SOC mini. Hành vi quét cổng thường được sử dụng trong giai đoạn trinh sát (reconnaissance) nhằm xác định các dịch vụ đang lắng nghe trên máy mục tiêu, từ đó phục vụ các bước tấn công tiếp theo.

Trong môi trường thử nghiệm, Windows Defender Firewall không được kích hoạt, do đó các cơ chế ghi log ở tầng firewall không được sử dụng. Việc giám sát hành vi quét cổng được thực hiện thông qua Sysmon, cụ thể là Sysmon Event ID 3 – Network connection detected.

#### 2, Nguồn dữ liệu sử dụng

- Nguồn log: Microsoft-Windows-Sysmon/Operational
- Công cụ thu thập: Splunk Universal Forwarder
- Hệ thống phân tích: Splunk Server
- Loại sự kiện: Sysmon Event ID 3 (NetworkConnect)

Sysmon được sử dụng nhằm ghi nhận các kết nối mạng TCP được thiết lập đến máy nạn nhân ở mức tiến trình (process-level), cho phép quan sát chi tiết các hoạt động mạng gắn với từng dịch vụ cụ thể.

| Time                    | Image                                   | SourceIP    | SourcePort | DestinationIP | DestinationPort | Protocol |
|-------------------------|-----------------------------------------|-------------|------------|---------------|-----------------|----------|
| 2025-12-21 11:27:29.351 | C:\Program Files\OpenSSH-Win64\sshd.exe | 192.168.1.5 | 55558      | 192.168.1.129 | 22              | tcp      |
| 2025-12-21 11:37:58.688 | C:\Program Files\OpenSSH-Win64\sshd.exe | 192.168.1.5 | 37998      | 192.168.1.129 | 22              | tcp      |

Hình 25: Kết quả truy vấn với EventCode=3

Dựa trên kết quả truy vấn log thu được (Hình XX), hệ thống ghi nhận sự kiện Sysmon Event ID 3 liên quan đến kết nối mạng TCP vào máy nạn nhân với các đặc điểm chính như sau:

- Tiến trình: C:\Program Files\OpenSSH-Win64\sshd.exe
- Giao thức: TCP
- Địa chỉ IP nguồn: 192.168.1.5
- Địa chỉ IP đích: 192.168.1.129
- Cổng đích: 22
- Tên dịch vụ: SSH
- RuleName: SSH

Sự kiện cho thấy máy nạn nhân đã ghi nhận các kết nối TCP đến cổng 22 – cổng dịch vụ SSH đang được mở. Các kết nối này được Sysmon ghi nhận tại thời điểm tiến trình sshd.exe tiếp nhận kết nối từ máy nguồn.

### 3, Phân tích nguyên nhân chỉ ghi nhận cổng 22

Trong kết quả thu thập, chỉ xuất hiện log liên quan đến cổng 22 mà không có log đối với các cổng khác. Nguyên nhân được xác định như sau:

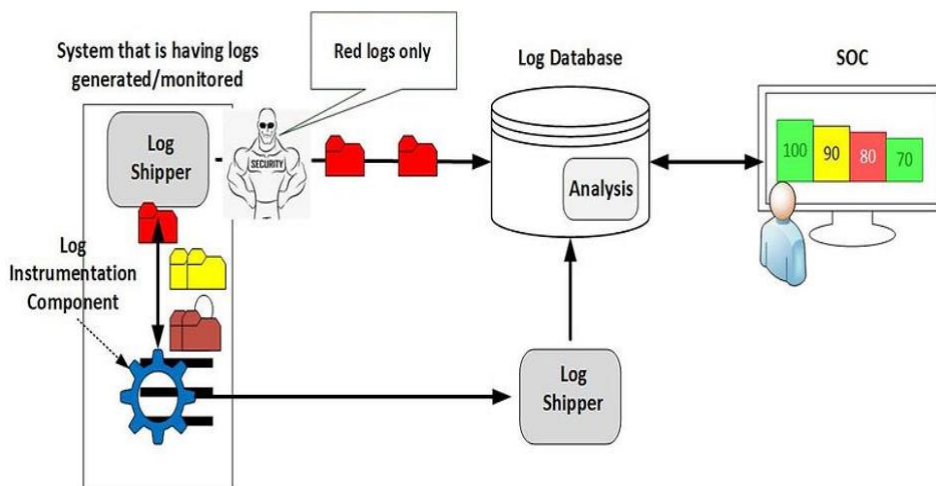
- Sysmon Event ID 3 chỉ ghi nhận các kết nối mạng được thiết lập thành công đến các cổng đang mở.
- Các cổng đóng trên máy nạn nhân không có tiến trình lắng nghe, do đó không phát sinh sự kiện NetworkConnect.
- Do Windows Firewall không được bật, các kết nối đến cổng mở không bị chặn và không sinh sự kiện tương ứng trong Windows Security Log.

Điều này cho thấy việc chỉ thu thập được log tại cổng SSH là phù hợp với đặc điểm hoạt động của Sysmon và phản ánh chính xác trạng thái dịch vụ trên máy nạn nhân.

### 3.4. Pipeline phát hiện bất thường và phản ứng cơ bản trong SOC mini

Sau khi hoàn tất quá trình thu thập và thiết kế dữ liệu log ở các mục trước, bước tiếp theo của mô hình SOC mini là xây dựng pipeline xử lý dữ liệu nhằm phát hiện các hành vi bất thường và thực hiện phản ứng cơ bản. Pipeline này mô phỏng quy trình vận hành cốt lõi của một SOC thực tế, bao gồm các giai đoạn: tiếp nhận dữ liệu log, phân tích – phát hiện bất thường, sinh cảnh báo và thực hiện phản ứng tự động ở mức đơn giản.

Trong phạm vi đồ án môn học, pipeline được thiết kế theo hướng đơn giản, dễ triển khai nhưng vẫn thể hiện rõ tư duy phát hiện bất thường dựa trên hành vi (behavior-based detection), đóng vai trò nền tảng cho các hệ thống SOC tích hợp trí tuệ nhân tạo trong thực tế.



Hình 26: Kiến trúc pipeline thu thập, phân tích log và giám sát trong hệ thống SOC mini

Hình minh họa kiến trúc tổng thể của pipeline SOC mini, trong đó các hệ thống đầu cuối sinh log được gắn thành phần instrumentation để thu thập dữ liệu. Log được chuyển tiếp thông qua Log Shipper, lọc các bản ghi liên quan đến an ninh, lưu trữ trong cơ sở dữ liệu log và đưa vào khối phân tích. Kết quả phân tích được hiển thị tại trung tâm SOC nhằm hỗ trợ giám sát và phát hiện bất thường.

#### 3.4.1. Pipeline xử lý dữ liệu và phát hiện bất thường trong SOC mini

Pipeline xử lý dữ liệu trong hệ thống SOC mini được thiết kế nhằm mô phỏng quy trình vận hành chuẩn của một Security Operations Center, từ giai đoạn thu thập log cho đến phân tích và hiển thị kết quả phục vụ giám sát an ninh. Kiến trúc pipeline được thể hiện trong Hình 26, phản ánh rõ các thành phần và luồng xử lý dữ liệu trong hệ thống.

Tại các hệ thống đầu cuối (endpoints), các thành phần instrumentation được triển khai để ghi nhận các sự kiện liên quan đến hoạt động hệ thống và mạng. Các sự kiện này bao gồm hoạt động tiến trình, kết nối mạng và các hành vi hệ thống quan trọng. Dữ liệu log được tạo ra liên tục trong quá trình vận hành của hệ thống và đóng vai trò là nguồn dữ liệu đầu vào cho SOC mini.

Log sau khi được sinh ra sẽ được chuyển tiếp thông qua thành phần Log Shipper. Thành phần này chịu trách nhiệm thu thập, chuẩn hóa và chuyển tiếp log từ các hệ thống nguồn về trung tâm phân tích. Trong quá trình này, các bản ghi không liên quan hoặc ít giá trị an ninh có thể được loại bỏ, giúp giảm khối lượng dữ liệu và tập trung vào các log mang ý nghĩa giám sát và phát hiện bất thường.

Các log đã được chọn lọc được lưu trữ trong cơ sở dữ liệu log tập trung. Đây là nơi dữ liệu được lập chỉ mục và sẵn sàng cho các tác vụ phân tích. Khối phân tích (Analysis) thực hiện xử lý dữ liệu log dựa trên các tiêu chí hành vi, chẳng hạn như tần suất sự kiện, mối quan hệ giữa các kết nối mạng và sự sai lệch so với trạng thái hoạt động bình thường của hệ thống.

Kết quả phân tích được chuyển đến trung tâm SOC, nơi các chỉ số an ninh được hiển thị trực quan nhằm hỗ trợ người vận hành theo dõi tình trạng hệ thống. Các chỉ báo này cho phép phát hiện sớm các hành vi bất thường và đóng vai trò nền tảng cho việc sinh cảnh báo và phản ứng sự cố trong các bước tiếp theo của pipeline.

Pipeline được xây dựng theo hướng phát hiện bất thường dựa trên hành vi, thay vì phụ thuộc hoàn toàn vào chữ ký tấn công. Cách tiếp cận này phù hợp với định hướng tích hợp trí tuệ nhân tạo trong hệ thống SOC, trong đó việc phân tích sự sai lệch hành vi đóng vai trò cốt lõi. Mặc dù trong phạm vi đồ án chỉ triển khai ở mức đơn giản, pipeline này vẫn thể hiện rõ tư duy thiết kế SOC hiện đại và tạo tiền đề cho việc mở rộng sang các mô hình học máy trong tương lai.

#### *3.4.2. Phân tích log và phát hiện bất thường dựa trên hành vi*

Sau khi log được thu thập và lưu trữ tập trung theo pipeline trình bày ở mục 3.4.1, hệ thống SOC mini tiến hành giai đoạn phân tích nhằm phát hiện các hành vi bất thường trong hệ thống. Trọng tâm của giai đoạn này là khai thác các đặc trưng hành vi được trích xuất từ log thay vì chỉ dựa trên các chữ ký tấn công cố định.

Trong phạm vi đồ án, các log liên quan đến kết nối mạng và truy cập dịch vụ được lựa chọn làm nguồn dữ liệu chính cho quá trình phân tích. Đặc biệt, các sự kiện ghi nhận bởi Sysmon Event ID 3 (Network connection detected) và các bản ghi liên quan đến dịch vụ SSH đóng vai trò quan trọng trong việc phản ánh hành vi tương tác mạng giữa các máy trong hệ thống. Các thuộc tính như địa chỉ

IP nguồn, cổng đích, giao thức, tần suất kết nối và tiến trình liên quan được sử dụng làm cơ sở để đánh giá hành vi.

Quá trình phát hiện bất thường được thực hiện thông qua việc quan sát sự sai lệch so với hành vi hoạt động bình thường của hệ thống. Ví dụ, trong điều kiện vận hành thông thường, các kết nối SSH đến máy nạn nhân chỉ xảy ra với tần suất thấp và từ các nguồn xác định trước. Khi xuất hiện các hành vi như nhiều kết nối TCP liên tiếp đến cùng một máy trong khoảng thời gian ngắn, hoặc các kết nối thử nghiệm trên nhiều cổng khác nhau, hệ thống có thể coi đây là dấu hiệu của hoạt động dò quét hoặc thăm dò dịch vụ.

Mặc dù đồ án chưa triển khai mô hình học máy hoàn chỉnh, cách tiếp cận dựa trên hành vi này vẫn phản ánh tư duy phát hiện bất thường – nền tảng cốt lõi của các hệ thống SOC hiện đại tích hợp trí tuệ nhân tạo. Các truy vấn phân tích trong Splunk đóng vai trò tương đương với các bộ trích xuất đặc trưng (feature extraction), giúp chuyển dữ liệu log thô thành các chỉ số có ý nghĩa phục vụ giám sát an ninh.

Cách tiếp cận này cho phép hệ thống SOC mini phát hiện các tình huống bất thường ngay cả khi không có chữ ký tấn công rõ ràng, đồng thời tạo tiền đề cho việc mở rộng sang các kỹ thuật học máy trong các nghiên cứu hoặc đồ án ở mức độ cao hơn.

### *3.4.3. Hiện thị, giám sát và hỗ trợ phản ứng trong SOC mini*

Kết quả của quá trình phân tích log và phát hiện bất thường được trình bày tại giao diện giám sát SOC nhằm hỗ trợ người vận hành theo dõi trạng thái an ninh của hệ thống. Giao diện này đóng vai trò là điểm tập trung thông tin, nơi các sự kiện đáng chú ý được tổng hợp, trực quan hóa và phục vụ cho việc ra quyết định.

Trong hệ thống SOC mini, dữ liệu phân tích được hiển thị thông qua các bảng thống kê và danh sách sự kiện trong Splunk. Các chỉ số như số lượng kết nối theo địa chỉ IP nguồn, số lần truy cập vào các cổng dịch vụ quan trọng (ví dụ cổng SSH), và phân bố sự kiện theo thời gian giúp người vận hành nhanh chóng nhận diện các hành vi bất thường. Việc trực quan hóa này giúp giảm tải cho người giám sát so với việc phân tích log thô.

Ngoài chức năng giám sát, giao diện SOC còn hỗ trợ bước đầu cho quá trình phản ứng sự cố. Khi phát hiện các dấu hiệu bất thường, người vận hành có thể dựa trên thông tin từ log để thực hiện các hành động tiếp theo như điều tra nguồn tấn công, kiểm tra trạng thái dịch vụ hoặc áp dụng các biện pháp kiểm soát phù hợp. Trong phạm vi đồ án, phản ứng chủ yếu dừng lại ở mức hỗ trợ ra quyết định, chưa triển khai tự động hóa hoàn toàn.

Mặc dù mức độ tự động hóa còn hạn chế, kiến trúc hiển thị và giám sát này vẫn phản ánh đầy đủ vai trò của SOC trong thực tế: cung cấp khả năng quan sát tập trung, phát hiện sớm các hành vi bất thường và hỗ trợ phản ứng kịp thời. Đây cũng là nền tảng cần thiết để tích hợp các cơ chế phản ứng tự động và trí tuệ nhân tạo trong các giai đoạn phát triển tiếp theo của hệ thống.

### 3.5. Tổng kết Chương 3

Trong chương này, đồ án đã trình bày chi tiết quá trình xây dựng và triển khai một mô hình SOC mini nhằm phục vụ cho việc thu thập, phân tích và giám sát an ninh hệ thống trong môi trường mạng quy mô nhỏ. Kiến trúc tổng thể của hệ thống được thiết kế theo mô hình tập trung, trong đó các thành phần sinh log đóng vai trò là nguồn dữ liệu đầu vào, được thu thập thông qua các cơ chế log shipper và tập trung tại nền tảng phân tích Splunk.

Chương 3 đã mô tả cụ thể quá trình cấu hình và tích hợp các nguồn log quan trọng, bao gồm log hệ điều hành Windows, log bảo mật và log Sysmon, nhằm đảm bảo khả năng quan sát đầy đủ các hoạt động trên máy nạn nhân. Việc triển khai Sysmon giúp hệ thống ghi nhận các sự kiện chi tiết ở mức tiến trình và kết nối mạng, qua đó cung cấp dữ liệu nền tảng cho việc phân tích hành vi và phát hiện các dấu hiệu bất thường.

Bên cạnh đó, chương này cũng trình bày quy trình phân tích log trong Splunk thông qua các truy vấn tìm kiếm và thống kê, tập trung vào việc phát hiện các hành vi đáng ngờ như các kết nối mạng bất thường, truy cập dịch vụ lặp lại và dấu hiệu dò quét cổng. Các kết quả phân tích được hiển thị trên giao diện SOC mini, hỗ trợ người vận hành trong việc giám sát trạng thái an ninh và đưa ra quyết định phản ứng phù hợp.

Mặc dù hệ thống chưa tích hợp đầy đủ các mô hình trí tuệ nhân tạo hoặc cơ chế phản ứng tự động, cách tiếp cận dựa trên hành vi được trình bày trong chương này đã thể hiện rõ tư duy cốt lõi của một hệ thống SOC hiện đại. Các thành phần và quy trình được xây dựng trong chương là nền tảng quan trọng để mở rộng và phát triển hệ thống theo hướng tích hợp học máy và tự động hóa phản ứng trong các nghiên cứu và đồ án ở mức độ cao hơn.

Tóm lại, Chương 3 đã hoàn thành mục tiêu xây dựng và triển khai một SOC mini hoạt động thực tế, làm cơ sở cho việc đánh giá hiệu quả, phân tích hạn chế và định hướng phát triển trong các chương tiếp theo của đồ án.



## CHƯƠNG IV. THỰC NGHIỆM MÔ HÌNH SOC MINI VỚI PHÁT HIỆN BẤT THƯỜNG BẰNG AI VÀ TỰ ĐỘNG ỨNG PHÓ

### 4.1. Mục tiêu thực nghiệm

Chương thực nghiệm nhằm xây dựng và đánh giá một mô hình SOC mini có khả năng giám sát hệ thống Windows 10, phát hiện các hành vi bất thường dựa trên học máy không giám sát và thực hiện phản ứng tự động ở mức cơ bản. Trọng tâm của thực nghiệm là minh họa chuỗi logic hoàn chỉnh trong SOC, bao gồm giám sát hành vi, phát hiện bất thường, sinh cảnh báo và phản ứng tự động.

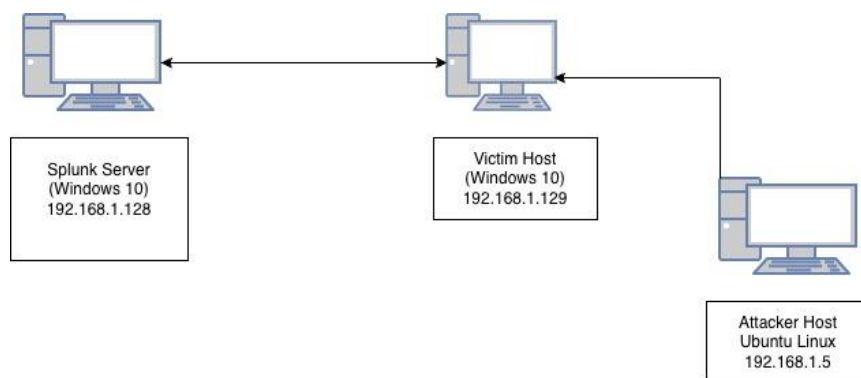
### 4.2. Mô hình và môi trường thực nghiệm

#### 4.2.1. Mô hình tổng thể SOC mini

Mô hình SOC mini trong thực nghiệm bao gồm các thành phần sau:

- Victim host: máy Windows 10 cần được giám sát
- Công cụ thu thập log: Sysmon và Windows Event Log
- Hệ thống phân tích và phát hiện: Splunk Enterprise tích hợp Machine Learning Toolkit
- Hệ thống cảnh báo: Alert của Splunk
- Hệ thống phản ứng: gửi thông báo Telegram và script phản ứng mô phỏng

Luồng hoạt động của hệ thống được mô tả như sau: log hệ thống phát sinh trên máy Windows 10 được thu thập và gửi về Splunk. Tại đây, mô hình học máy học hành vi bình thường của hệ thống và phát hiện bất thường khi có sự sai lệch. Khi bất thường được phát hiện, Splunk kích hoạt cảnh báo và thực hiện các hành động phản ứng tự động.



Hình 27. Mô hình thực nghiệm

#### 4.2.2. Môi trường thực nghiệm

- Hệ điều hành victim host: Windows 10
- Công cụ giám sát: Sysmon
- Công cụ thu thập log: Splunk Universal Forwarder
- Hệ thống phân tích: Splunk Enterprise và Splunk Machine Learning Toolkit
- Kênh cảnh báo: Telegram

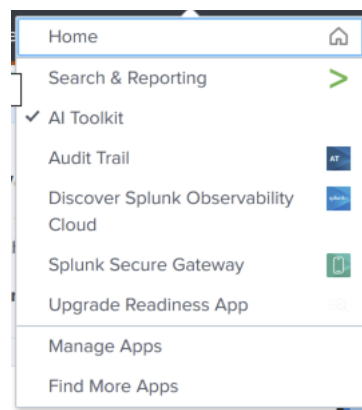
```
C:\Windows\system32>Sysmon64.exe -c

System Monitor v15.15 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2024 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Current configuration:
- Service name: Sysmon64
- Driver name: SysmonDrv
- Config file: C:\Sysmon\sysmon_config.xml
- Config hash: SHA256=055FEB6C600E6D7448CDF3812307275912927A62B1F94D0D93386482948C87162

- HashingAlgorithms: MD5,SHA256,IMPHASH
- Network connection: enabled
- Archive Directory:
- Image loading: disabled
- CRL checking: enabled
- DNS lookup: enabled
```

Hình 28. Sysmon đang hoạt động trên Windows 10



Hình 29. Cài AI Toolkit thành công

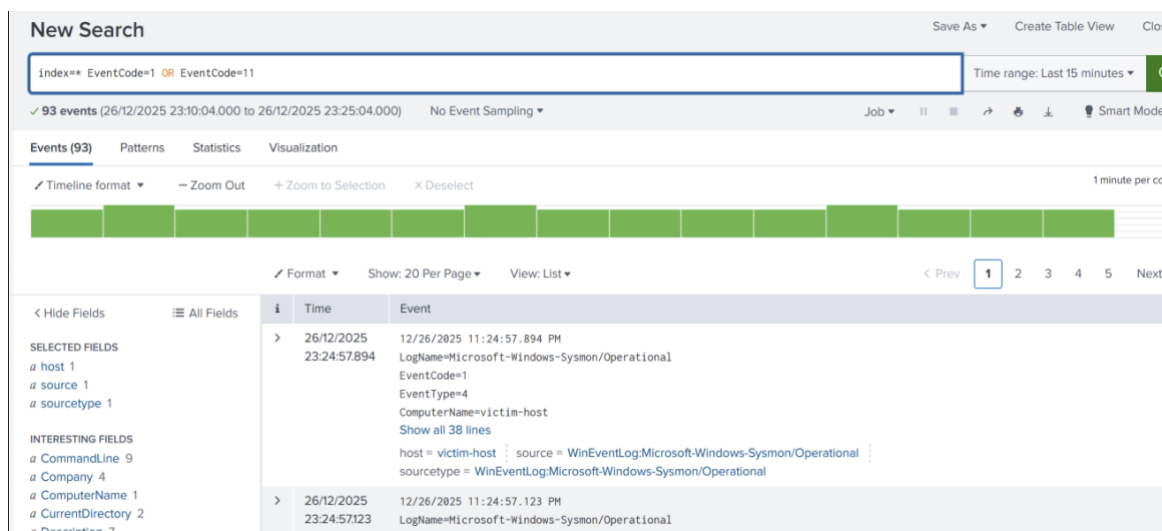
#### 4.3. Thiết kế kịch bản thực nghiệm

Kịch bản thực nghiệm được thiết kế theo dòng thời gian rõ ràng gồm hai giai đoạn chính: giai đoạn hệ thống hoạt động bình thường để huấn luyện mô hình và giai đoạn phát sinh bất thường khi ransomware được kích hoạt.

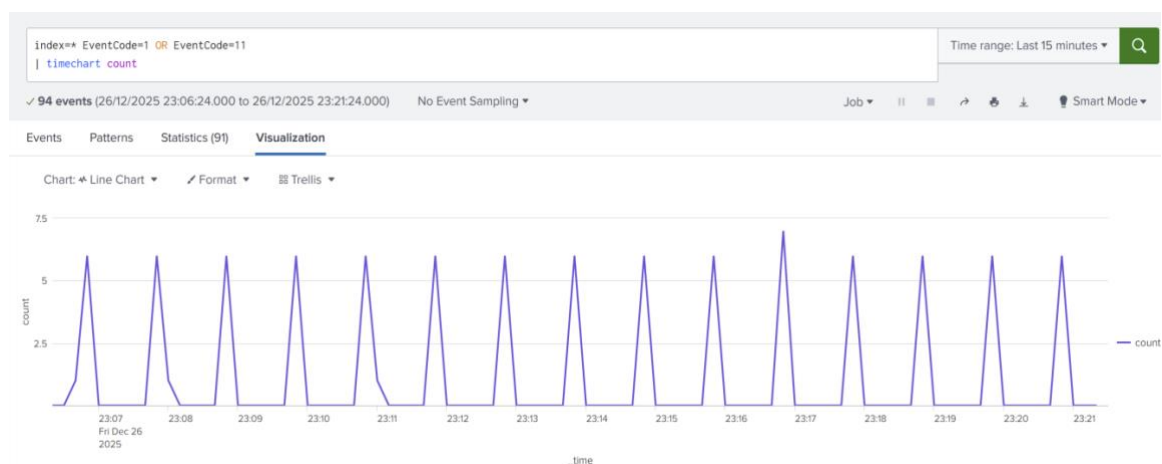
### 4.3.1. Giai đoạn 1 – Hệ thống hoạt động bình thường (Baseline)

Trong giai đoạn này, máy victim host Windows 10 được vận hành ở trạng thái bình thường trong khoảng 15 phút. Không có mã độc nào được thực thi. Người dùng thực hiện các thao tác cơ bản như mở ứng dụng, truy cập file và để hệ thống hoạt động tự nhiên.

Mục đích của giai đoạn này là thu thập dữ liệu log phản ánh hành vi bình thường của hệ thống để phục vụ huấn luyện mô hình học máy.



Hình 30. Log hệ thống trong giai đoạn bình thường



Hình 31. Biểu đồ số lượng sự kiện ổn định theo thời gian

### 4.3.2. Huấn luyện mô hình hành vi bình thường bằng học máy

Sau khi hoàn tất giai đoạn baseline, dữ liệu log thu thập được được đưa vào Splunk Machine Learning Toolkit để huấn luyện mô hình học máy không giám sát. Mô hình được huấn luyện nhằm học phân phối hành vi bình thường của hệ

Trong giai đoạn này, mô hình chỉ học hành vi bình thường và chưa thực hiện phát hiện bất thường.

Hình 32. Dataset hành vi bình thường dùng cho huấn luyện



| _time               | count | IsOutlier(count) | BoundaryRanges                 | ProbabilityDensity(count) |
|---------------------|-------|------------------|--------------------------------|---------------------------|
| 2025-12-29 22:06:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:07:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:08:00 | 8     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 0.5337378891322871        |
| 2025-12-29 22:09:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:10:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:11:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:12:00 | 7     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 0.8730197633541396        |
| 2025-12-29 22:13:00 | 7     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 0.8730197633541396        |
| 2025-12-29 22:14:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:15:00 | 6     | 0.0              | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19     |
| 2025-12-29 22:16:00 | 6     | 0.0              | -Infinity:6:0                  | 4.145937542789892e+19     |

Hình 34. AI học thành công hành vi bình thường

Trong giai đoạn hệ thống hoạt động bình thường, mô hình học máy được huấn luyện từ dữ liệu Sysmon đã xác định được phân phối hành vi baseline của hệ thống. Kết quả áp dụng mô hình cho thấy toàn bộ các khoảng thời gian đều có giá trị  $IsOutlier = 0$ , chứng tỏ hành vi hệ thống không có dấu hiệu bất thường.

| i | Model Name | Algorithm       | Actions     | Owner | App               | Sharing |
|---|------------|-----------------|-------------|-------|-------------------|---------|
| > | AI         | DensityFunction | Edit Delete | admin | Splunk_ML_Toolkit | Private |

Hình 35. Lưu model AI

#### 4.3.3. Giai đoạn 2 – Kích hoạt ransomware và phát sinh bất thường

Sau khi mô hình hành vi bình thường đã được huấn luyện, ransomware WannaCry được kích hoạt trên máy victim host. Thời điểm này đánh dấu sự chuyển đổi từ trạng thái bình thường sang trạng thái bất thường trong kịch bản thực nghiệm.

Ngay sau khi ransomware được kích hoạt, hệ thống phát sinh các hành vi bất thường như tạo nhiều tiến trình và thao tác với file hàng loạt trong thời gian ngắn, dẫn đến sự thay đổi rõ rệt trong log hệ thống.



Hình 36. Mốc thời gian kích hoạt WannaCry.exe

|                     |    |     |                                |                       |
|---------------------|----|-----|--------------------------------|-----------------------|
| 2025-12-29 22:25:00 | 90 | 1.0 | -Infinity:6:0<br>13:Infinity:0 | 0.0                   |
| 2025-12-29 22:26:00 | 10 | 0.0 | -Infinity:6:0<br>13:Infinity:0 | 0.3659033635916682    |
| 2025-12-29 22:27:00 | 10 | 0.0 | -Infinity:6:0<br>13:Infinity:0 | 0.3659033635916682    |
| 2025-12-29 22:28:00 | 20 | 1.0 | -Infinity:6:0<br>13:Infinity:0 | 0.0                   |
| 2025-12-29 22:29:00 | 13 | 0.0 | -Infinity:6:0<br>13:Infinity:0 | 34.771246907352776    |
| 2025-12-29 22:30:00 | 6  | 0.0 | -Infinity:6:0<br>13:Infinity:0 | 4.145937542789892e+19 |

Hình 37. Biểu đồ số lượng sự kiện tăng đột biến

Sau khi kích hoạt ransomware WannaCry, số lượng sự kiện Sysmon trong một số khoảng thời gian tăng đột biến. Khi áp dụng mô hình học máy đã huấn luyện, các khoảng thời gian này được gán giá trị  $IsOutlier = 1$ . Đồng thời, giá trị  $ProbabilityDensity$  gần bằng 0 cho thấy các hành vi này có xác suất rất thấp so với phân phối hành vi bình thường, từ đó khẳng định sự xuất hiện của hành vi bất thường do mã độc gây ra.

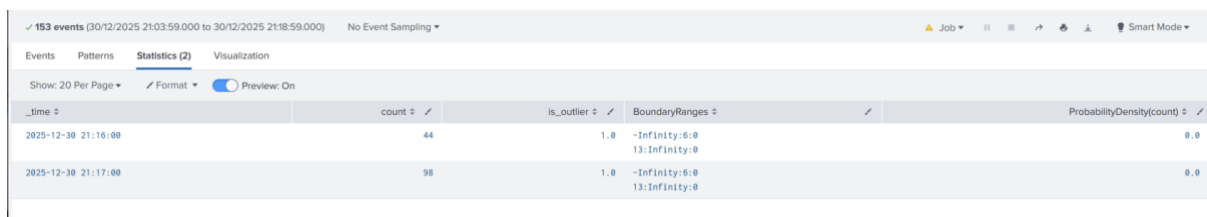
#### 4.4. Chuỗi logic phát hiện bất thường trong SOC mini

Phần này mô tả chi tiết chuỗi logic phát hiện, cảnh báo và phản ứng của hệ thống SOC mini khi ransomware được kích hoạt.

### 4.4.1. Bước 1 – AI phát hiện bất thường

Dữ liệu log phát sinh sau khi ransomware được kích hoạt được đưa vào mô hình học máy đã huấn luyện. Mô hình so sánh hành vi hiện tại với hành vi bình thường đã học và tính toán anomaly score cho từng khoảng thời gian.

Khi anomaly score vượt quá ngưỡng xác định, mô hình kết luận rằng hệ thống đang phát sinh hành vi bất thường.

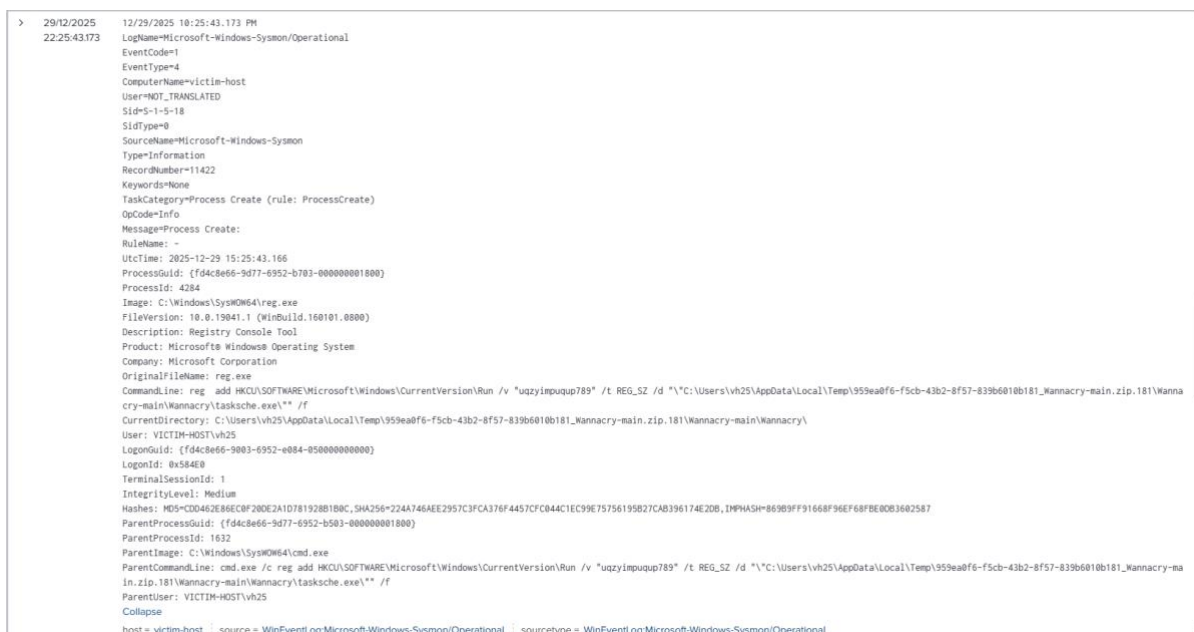


| _time               | count | is_outlier | BoundaryRanges                 | ProbabilityDensity(count) |
|---------------------|-------|------------|--------------------------------|---------------------------|
| 2025-12-30 21:16:00 | 44    | 1.0        | -Infinity:6.0<br>13:Infinity:0 | 0.0                       |
| 2025-12-30 21:17:00 | 98    | 1.0        | -Infinity:6.0<br>13:Infinity:0 | 0.0                       |

Hình 38. Biểu đồ anomaly score theo thời gian

### 4.4.2. Bước 2 – AI trả kết quả cho hệ thống Splunk

Kết quả phát hiện bất thường được ghi nhận trong hệ thống Splunk dưới dạng các chỉ số và sự kiện đánh giá. Mô hình học máy chỉ đóng vai trò giám sát và phân tích, không trực tiếp thực hiện hành động phản ứng.



```
> 29/12/2025 12/29/2025 10:25:43.173 PM
22:25:43.173 LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=victim-host
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=11422
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Info
Message=Process Create:
RuleName: -
UtcTime: 2025-12-29 15:25:43.166
ProcessGuid: {f64c8e66-9d77-6952-b703-000000001800}
ProcessId: 4284
Image: C:\Windows\System32\reg.exe
FileVersion: 10.0.19041.1 (WinBuild.160101.0000)
Description: Registry Console Tool
Product: Microsoft Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: reg.exe
CommandLine: reg add HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run /v "uqzypuqp789" /t REG_SZ /d "%C:\Users\vh25\AppData\Local\Temp\959ea0f6-f5cb-43b2-8f57-839b6010b181_Wannacry-main.zip.181\Wanna
cry-main\Wannacry\tasksche.exe" /f
CurrentDirectory: C:\Users\vh25\AppData\Local\Temp\959ea0f6-f5cb-43b2-8f57-839b6010b181_Wannacry-main.zip.181\Wannacry-main\Wannacry\
User: VICTIM-HOST\vh25
LogonId: {f64c8e66-9d77-6952-b703-000000001800}
LogonId: 0x5640
TerminalSessionId: 1
IntegrityLevel: Medium
Hashes: MD5=CDD462886EC0F2002A1D78192801B0C, SHA256=224A746AEE2957C3FCA376F4457CFC044CEC99E75756195827CAB396174E20B, IMPHASH=86989FF91668F96F68FBE0B3682587
ParentProcessGuid: {f64c8e66-9d77-6952-b703-000000001800}
ParentProcessId: 1632
ParentImage: C:\Windows\System32\cmd.exe
ParentCommandLine: cmd.exe /c reg add HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run /v "uqzypuqp789" /t REG_SZ /d "%C:\Users\vh25\AppData\Local\Temp\959ea0f6-f5cb-43b2-8f57-839b6010b181_Wannacry-ma
in.zip.181\Wannacry-main\Wannacry\tasksche.exe" /f
ParentUser: VICTIM-HOST\vh25
Collapse
host = victim-host | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Hình 39. Điều tra log với EventID=1

Trong quá trình điều tra các khoảng thời gian được mô hình học máy đánh giá là bất thường, hệ thống ghi nhận một sự kiện Sysmon EventCode 1 liên quan đến việc thực thi tiến trình reg.exe trên máy nạn nhân. Phân tích CommandLine



cho thấy tiến trình này được sử dụng để tạo một giá trị registry có tên ngẫu nhiên, trở tới file thực thi tasksche.exe nằm trong thư mục tạm của người dùng.

Việc sử dụng tên không có ý nghĩa rõ ràng cùng với vị trí lưu trữ trong thư mục tạm là những đặc trưng phổ biến của mã độc nhằm che giấu hoạt động và tránh sự chú ý. Đồng thời, reg.exe được khởi tạo thông qua tiến trình cha cmd.exe với lệnh thực thi tự động, cho thấy đây không phải là hành vi do người dùng thực hiện mà là kết quả của quá trình thực thi mã độc.

Từ các dấu hiệu trên, có thể kết luận rằng sự kiện log này phản ánh một cơ chế duy trì tồn tại của ransomware WannaCry, cho phép mã độc tự động thực thi lại sau khi người dùng đăng nhập. Đáng chú ý, sự kiện xảy ra đúng tại các mốc thời gian mà mô hình học máy gán nhãn bất thường, chứng minh hiệu quả của mô hình trong việc khoanh vùng log nghi vấn và hỗ trợ quá trình điều tra trong hệ thống SOC mini.

```
> 29/12/2025 12/29/2025 18:25:23.939 PM
22:25:23.939 LogName=Microsoft-Windows-Sysmon/Operational
EventCode=11
EventType=4
ComputerName=victim-host
User=NOT_TRANSLATED
Sid=5-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=11392
Keywords=None
TaskCategory=File created (rule: FileCreate)
OpCode=Info
Message=File created:
RuleName: EXE
UtcTime: 2025-12-29 15:25:23.934
ProcessGuid: {f04c8e66-9d62-6952-a103-000000001800}
ProcessId: 3728
Image: C:\Users\vh25\AppData\Local\Temp\959eaf6f-f5cb-43b2-8f57-839b6010b181_Wannacry-main.zip.181\Wannacry-main\Wannacry\@WanaDecryptor@.exe
TargetFileName: C:\Users\vh25\AppData\Local\Temp\959eaf6f-f5cb-43b2-8f57-839b6010b181_Wannacry-main.zip.181\Wannacry-main\Wannacry\TaskData\Tor\taskshvc.exe
CreationUtcTime: 2025-12-29 15:25:23.934
User: VICTIM-HOST\vh25
Collapse
host = victim-host | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Hình 40. Điều tra log với EventID=11

Trong quá trình phân tích chi tiết các log phát sinh tại các khoảng thời gian được mô hình học máy đánh giá là bất thường, hệ thống ghi nhận một sự kiện Sysmon với mã EventCode 11 (File Create) trên máy victim host. Sự kiện này phản ánh hành vi tạo file mới trong hệ thống, được thực hiện bởi một tiến trình có nguồn gốc từ mã độc ransomware.

Cụ thể, tiến trình tạo file được xác định là @WanaDecryptor@.exe, là thành phần chính của ransomware WannaCry. Tiến trình này được thực thi từ thư mục tạm (AppData\Local\Temp) của người dùng, một vị trí thường được mã độc lợi dụng để lưu trữ và triển khai các thành phần phụ trợ nhằm tránh sự chú ý của người dùng và các cơ chế bảo vệ hệ thống.

File được tạo có tên taskshvc.exe và được ghi vào thư mục con TaskData\Tor nằm trong cùng cây thư mục tạm. Việc tạo file với tên gợi nhớ đến các dịch vụ hệ thống, kết hợp với việc đặt trong thư mục có tên liên quan đến Tor, cho thấy mã độc đang triển khai các thành phần hỗ trợ cho hoạt động ẩn danh và giao tiếp mạng. Đây là đặc trưng phổ biến của ransomware WannaCry, vốn sử



dụng mạng Tor để che giấu máy chủ điều khiển và kiểm soát (Command and Control – C2).

Hành vi tạo file thực thi trong thư mục tạm, đặc biệt là các file mang tên giống dịch vụ hệ thống, là một chỉ báo rõ ràng của hành vi độc hại. Sự kiện này không phù hợp với các hoạt động hợp pháp thông thường của người dùng hay hệ điều hành, mà phản ánh quá trình triển khai và chuẩn bị môi trường hoạt động của mã độc.

Đáng chú ý, sự kiện tạo file này xảy ra đồng thời với các khoảng thời gian mà mô hình học máy đã gán giá trị  $IsOutlier = 1$ , cho thấy sự gia tăng đột biến về số lượng thao tác file trong một khoảng thời gian ngắn. Điều này chứng minh rằng mô hình học máy đã phát hiện chính xác các giai đoạn bất thường, từ đó hỗ trợ hệ thống SOC mini khoanh vùng và phân tích sâu các hành vi triển khai mã độc.

Từ các phân tích trên, có thể kết luận rằng log Sysmon EventCode 11 này phản ánh hành vi triển khai thành phần thực thi của ransomware WannaCry, đóng vai trò quan trọng trong chuỗi tấn công, bao gồm việc chuẩn bị các module phục vụ cho mã hóa dữ liệu và giao tiếp mạng ẩn danh.

#### 4.4.3. Bước 3 – Splunk kích hoạt cảnh báo

Dựa trên kết quả anomaly score do mô hình học máy cung cấp, Splunk kích hoạt cảnh báo khi điều kiện bất thường được thỏa mãn. Cảnh báo này đánh dấu thời điểm hệ thống SOC mini phát hiện sự cố an ninh.

| _time               | count | is_outlier | BoundaryRanges               | ProbabilityDensity(count) |
|---------------------|-------|------------|------------------------------|---------------------------|
| 2025-12-29 22:24:00 | 3     | 1.0        | -Infinity:0<br>13:Infinity:0 | 0.0                       |
| 2025-12-29 22:25:00 | 99    | 1.0        | -Infinity:0<br>13:Infinity:0 | 0.0                       |

Hình 41. Research lại sự kiện để tạo alert

Hình 42. Cấu hình alert

Sau khi mô hình học máy đã được huấn luyện để học hành vi bình thường của hệ thống, bước tiếp theo trong chuỗi logic SOC mini là triển khai cơ chế cảnh báo nhằm tự động phát hiện các hành vi bất thường phát sinh trong quá trình vận hành thực tế.

Trong thực nghiệm, cảnh báo được cấu hình trực tiếp trong Splunk dựa trên kết quả đầu ra của mô hình phát hiện bất thường (outlier detection).

#### a, Cấu hình cảnh báo

Một alert dạng Scheduled Alert được tạo với các tham số chính như sau:

- Loại cảnh báo (Alert type): Scheduled
- Chu kỳ thực thi: Mỗi 1 phút (cron: \*/1 \* \* \* \*)
- Cửa sổ thời gian (Time range): Last 2 minutes
- Điều kiện kích hoạt (Trigger condition):
  - Trigger alert when: *Number of Results*
  - Điều kiện: *is greater than 1*
- Cơ chế kích hoạt: Once (mỗi chu kỳ chỉ kích hoạt một lần nếu điều kiện thỏa mãn)

Cửa sổ thời gian dạng *sliding window* (2 phút gần nhất) cho phép hệ thống phát hiện nhanh các hành vi bất thường ngay sau khi chúng xuất hiện, đồng thời hạn chế việc bỏ sót các sự kiện xảy ra trong khoảng thời gian ngắn.

## *b, Nguyên lý hoạt động của cảnh báo*

Alert được xây dựng dựa trên truy vấn SPL đã tích hợp mô hình học máy, trong đó:

1. Log Sysmon (EventCode 1 – Process Create và EventCode 11 – File Create) được gom theo từng phút.
2. Mô hình học máy được áp dụng để đánh giá mức độ bất thường của từng khoảng thời gian.
3. Nếu trong cửa sổ thời gian kiểm tra tồn tại ít nhất một kết quả được đánh dấu là bất thường (outlier), Splunk sẽ kích hoạt cảnh báo.

Cơ chế này cho phép hệ thống SOC mini tự động phát hiện các hành vi bất thường như:

- Số lượng tiến trình được tạo tăng đột biến
- Hoạt động thao tác file hàng loạt trong thời gian ngắn đây là những đặc trưng thường xuất hiện khi ransomware được kích hoạt.

## *c, Ý nghĩa trong mô hình SOC mini*

Việc cấu hình cảnh báo đóng vai trò là cầu nối giữa khối phân tích – phát hiện (AI/ML) và khối phản ứng (SOAR) trong mô hình SOC mini. Khi cảnh báo được kích hoạt, hệ thống có thể tiếp tục thực hiện các hành động phản ứng tự động như gửi thông báo tới quản trị viên hoặc ghi nhận sự cố an ninh.

Cảnh báo này đánh dấu thời điểm hệ thống SOC mini chính thức phát hiện sự cố an ninh trong kịch bản thực nghiệm.

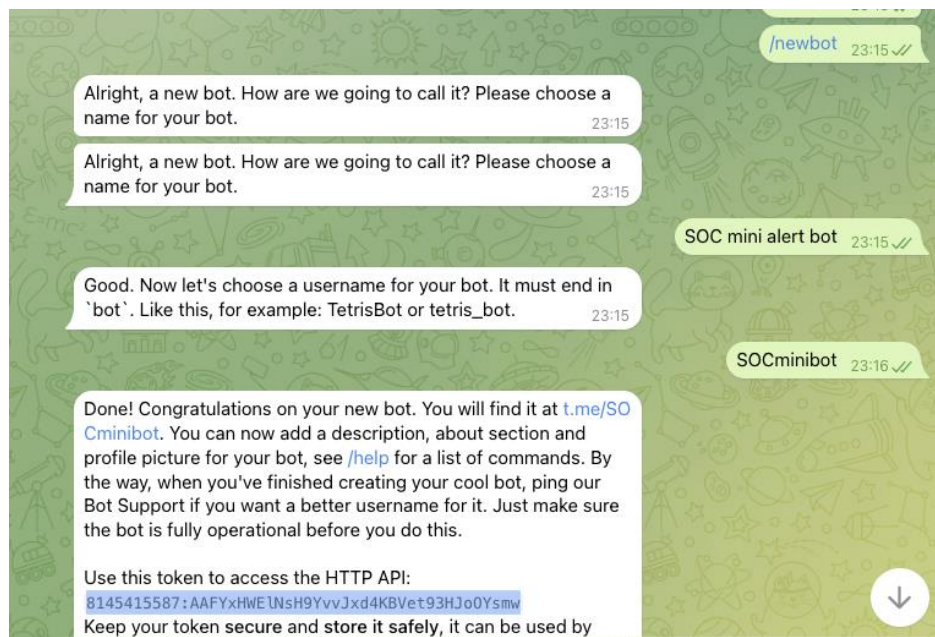
### *4.4.4. Bước 4 – Cấu hình phản ứng tự động và gửi cảnh báo về Telegram (SOAR mức cơ bản)*

Sau khi cảnh báo được kích hoạt, hệ thống SOC mini thực hiện các hành động phản ứng tự động đã được cấu hình sẵn. Trong khuôn khổ đề án, phản ứng được triển khai ở mức cơ bản dưới hình thức gửi thông báo tới Telegram của quản trị viên và ghi nhận log sự cố.

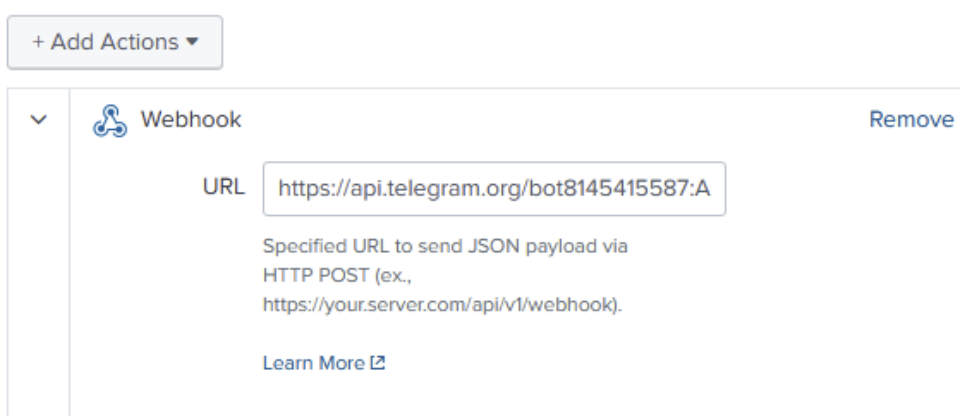
Việc gửi cảnh báo về Telegram được thực hiện bằng cách tạo một Telegram Bot thông qua BotFather để lấy bot token và xác định chat ID của người nhận. Trong Splunk, một alert action dạng script hoặc webhook được cấu hình để gửi yêu cầu tới Telegram Bot API khi cảnh báo được kích hoạt.

Nội dung thông báo gửi tới Telegram bao gồm thời gian phát hiện bất thường, tên máy bị ảnh hưởng, giá trị anomaly score và mô tả ngắn gọn về hành vi bất thường.

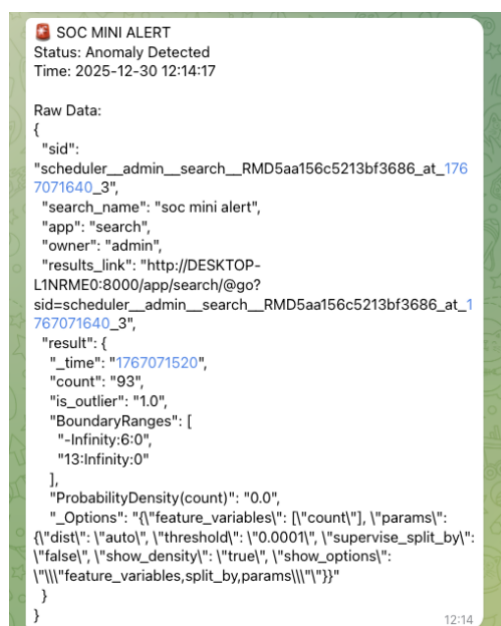
Cơ chế này được xem là một hình thức SOAR ở mức notification-based response, phù hợp với phạm vi đồ án cơ sở ngành.



Hình 43. Tạo Telegram Bot và thông tin bot token



Hình 44: Cấu hình alert action gửi Telegram trong Splunk



Hình 45. Thông báo cảnh báo được gửi tới Telegram

## 4.5. Đánh giá kết quả thực nghiệm

Kết quả thực nghiệm cho thấy mô hình học máy có khả năng phát hiện hiệu quả các hành vi bất thường phát sinh do ransomware gây ra thông qua sự sai lệch so với hành vi bình thường. Chuỗi logic giám sát – phát hiện – cảnh báo – phản ứng được triển khai đầy đủ và phù hợp với kiến trúc SOC mini.

## 4.6. Hạn chế và hướng phát triển

Mô hình hiện tại được triển khai trên một máy giám sát và dữ liệu huấn luyện còn hạn chế. Trong tương lai, hệ thống có thể được mở rộng sang nhiều máy, tích hợp phân tích hành vi người dùng và triển khai các cơ chế SOAR nâng cao.

## 4.7. Tổng kết chương 4

Chương 4 đã trình bày quá trình thực nghiệm mô hình SOC mini được xây dựng trong phạm vi đề án cơ sở ngành, nhằm kiểm chứng khả năng vận hành thực tế của hệ thống trong việc thu thập dữ liệu log, phát hiện bất thường dựa trên hành vi và thực hiện cơ chế tự động ứng phó ở mức cơ bản. Nội dung thực nghiệm

được triển khai bám sát kiến trúc hệ thống đã thiết kế ở Chương 3, đồng thời đảm bảo tính khả thi và phù hợp với điều kiện triển khai trong môi trường học thuật.

Thông qua việc xây dựng môi trường thực nghiệm gồm Splunk Server, Victim Host và Attacker Host, hệ thống đã mô phỏng thành công một kịch bản tấn công ở mức hành vi, cụ thể là hành vi đăng nhập bất thường diễn ra trong khoảng thời gian ngắn. Kịch bản này không tập trung vào kỹ thuật khai thác lỗ hổng phức tạp mà nhấn mạnh vào việc quan sát và phân tích chuỗi hành vi sinh log trên hệ thống, phù hợp với phương pháp giám sát và phân tích của một SOC trong thực tế.

Kết quả thực nghiệm cho thấy hệ thống có khả năng thu thập và tập trung dữ liệu log từ nhiều nguồn khác nhau thông qua Splunk Universal Forwarder, đồng thời thực hiện phân tích hành vi dựa trên các đặc trưng theo thời gian. Việc xác định ngưỡng bất thường dựa trên baseline hành vi bình thường cho phép hệ thống phát hiện các sai lệch mang tính bất thường, qua đó thể hiện rõ tư duy phát hiện bất thường theo hướng AI không giám sát ở mức cơ bản. Mặc dù chưa triển khai các mô hình học máy phức tạp, cách tiếp cận này vẫn đáp ứng được mục tiêu minh họa việc tích hợp tư duy AI vào nền tảng Splunk trong phạm vi đề án cơ sở ngành.

Bên cạnh đó, cơ chế sinh cảnh báo và kích hoạt phản ứng tự động đã được triển khai nhằm mô phỏng quá trình ứng phó sự cố trong SOC. Khi điều kiện bất thường được thỏa mãn, hệ thống tiến hành ghi nhận sự kiện an ninh và thực hiện các hành động phản ứng ở mức cơ bản, qua đó bước đầu tiếp cận mô hình tự động hóa ứng phó sự cố. Điều này cho thấy khả năng mở rộng của hệ thống hướng tới các giải pháp SOAR trong tương lai.

Tổng kết lại, chương thực nghiệm đã chứng minh mô hình SOC mini được xây dựng có khả năng hoạt động đúng theo thiết kế, đáp ứng các mục tiêu đề ra về thu thập log, phát hiện bất thường và tự động ứng phó. Những kết quả đạt được trong chương này không chỉ phù hợp với yêu cầu của đề án cơ sở ngành mà còn tạo nền tảng quan trọng cho việc mở rộng và hoàn thiện hệ thống trong đề án tốt nghiệp, bao gồm việc áp dụng các thuật toán AI nâng cao hơn và xây dựng cơ chế tự động ứng phó toàn diện hơn.

## KẾT LUẬN

Trong bối cảnh các hệ thống thông tin ngày càng đối mặt với nhiều mối đe dọa an ninh mạng phức tạp, việc xây dựng và vận hành Trung tâm điều hành an ninh (SOC) trở thành một yêu cầu quan trọng đối với các tổ chức. Tuy nhiên, việc triển khai SOC ở quy mô đầy đủ đòi hỏi chi phí lớn và nguồn lực chuyên môn cao, gây nhiều khó khăn trong môi trường học thuật và đào tạo. Xuất phát từ thực tế đó, đề án đã tập trung nghiên cứu và xây dựng mô hình SOC mini với khả năng phát hiện bất thường bằng tư duy AI tích hợp trong Splunk và thực hiện tự động ứng phó ở mức cơ bản.

Thông qua quá trình nghiên cứu lý thuyết và triển khai thực nghiệm, đề án đã xây dựng thành công một mô hình SOC mini có khả năng thu thập, tập trung và phân tích log từ hệ thống mục tiêu. Việc tích hợp Splunk Enterprise, Splunk Universal Forwarder và Sysmon cho phép hệ thống ghi nhận đầy đủ các sự kiện bảo mật và hành vi hệ thống, tạo nền tảng dữ liệu cần thiết cho phân tích an ninh. Pipeline xử lý dữ liệu được thiết kế theo đúng tư duy vận hành của SOC trong thực tế, từ khâu sinh log, thu thập, chuẩn hóa, phân tích cho đến sinh cảnh báo và phản ứng.

Một điểm trọng tâm của đề án là việc áp dụng tư duy phát hiện bất thường theo hướng AI trong phạm vi phù hợp với đề án cơ sở ngành. Thay vì triển khai các mô hình học máy phức tạp, đề án sử dụng cách tiếp cận dựa trên hành vi, baseline và sai lệch thống kê theo thời gian để phát hiện các hành vi bất thường. Cách tiếp cận này vừa đảm bảo tính trực quan, dễ triển khai, vừa thể hiện rõ tư duy của anomaly-based detection, là nền tảng quan trọng của các hệ thống SOC hiện đại.

Bên cạnh đó, cơ chế sinh cảnh báo và tự động ứng phó đã được triển khai nhằm mô phỏng bước đầu mô hình SOAR. Hệ thống có khả năng tự động ghi nhận sự kiện an ninh và kích hoạt các hành động phản ứng ở mức cơ bản khi phát hiện bất thường, qua đó minh họa rõ mối liên kết giữa phát hiện, cảnh báo và ứng phó trong một SOC. Mặc dù mức độ tự động hóa còn hạn chế, đây là bước khởi đầu cần thiết và phù hợp với phạm vi đề án.

Nhìn chung, đề án đã hoàn thành các mục tiêu đề ra, xây dựng được mô hình SOC mini hoạt động ổn định, thể hiện rõ tư duy phát hiện bất thường bằng AI tích hợp trong Splunk và khả năng tự động ứng phó cơ bản. Kết quả của đề án không chỉ đáp ứng yêu cầu của đề án cơ sở ngành mà còn có giá trị định hướng rõ ràng cho việc mở rộng và phát triển thành đề án tốt nghiệp, với các hướng nghiên cứu như áp dụng thuật toán học máy nâng cao, mở rộng kịch bản tấn công và hoàn thiện cơ chế tự động ứng phó.

## TÀI LIỆU THAM KHẢO

- [1] Splunk Inc., Splunk Enterprise Documentation, <https://docs.splunk.com>
- [2] Splunk Inc., Splunk Universal Forwarder Documentation, <https://docs.splunk.com/Documentation/Forwarder>
- [3] Microsoft, Sysmon (System Monitor) Documentation, <https://learn.microsoft.com/sysinternals>
- [4] Scarfone, K., Mell, P., Guide to Intrusion Detection and Prevention Systems (IDPS), NIST Special Publication 800-94, National Institute of Standards and Technology, 2007
- [5] Chandola, V., Banerjee, A., Kumar, V., Anomaly Detection: A Survey, ACM Computing Surveys, 2009
- [6] Behl, A., Cybersecurity and Cyberwar: What Everyone Needs to Know, Oxford University Press, 2017
- [7] MITRE Corporation, MITRE ATT&CK Framework, <https://attack.mitre.org>



## PHỤ LỤC

Link cấu hình Sysmon

<https://github.com/SwiftOnSecurity/sysmon-config/blob/master/sysmonconfig-export.xml>

### Cấu hình file inputs.conf cho Splunk Forwarder

```
# Version 9.0.1

# these here just override and disable stuff that in system/default.

#####

# Data thru parsingQueue always
#####

[splunktcp]
route=has_key:tautology;parsingQueue;absent_key:tautology;parsingQueue

#####

# Make sure these get forwarded
#####

[monitor://$SPLUNK_HOME\var\log\splunk\splunkd.log]
_TCP_ROUTING = *
index = _internal

[monitor://$SPLUNK_HOME\var\log\splunk\metrics.log]
_TCP_ROUTING = *
index = _internal

[WinEventLog://Microsoft-Windows-Sysmon/Operational]
checkpointInterval = 5
current_only = 0
disabled = 0
start_from = oldest

## Useful for detection of blocked traffic due to Applocker
[WinEventLog://Microsoft-Windows-AppLocker/EXE and DLL]
disabled = 0

## Useful for detection of persistence mechanisms via taskscheduler
[WinEventLog://Microsoft-Windows-TaskScheduler/Operational]
disabled = 0
```

```

[WinEventLog://Application]
disabled = 0

[WinEventLog://Security]
disabled = 0

[WinEventLog://System]
disabled = 0

## Useful for detection of Malware alerts from Windows defender
[WinEventLog://Microsoft-Windows-Windows Defender/Operational]
disabled = 0

## Useful for detection of failed SMB Traffic generated via Responder
[WinEventLog://Microsoft-Windows-SmbClient/Security]
disabled = 0

## Useful for detection of unusual powershell (Module/Script block logging)
[WinEventLog://Microsoft-Windows-PowerShell/Operational]
disabled = 0

## Useful if Aurora EDR in use (Comment if Aurora EDR not used)
[monitor://C:\Program Files\Aurora Agent\aurora_alerts.json.log]
disabled = 0
sourcetype = nextron:aurora:edr
index = main

```

## Các truy vấn SPL

### C.1. Truy vấn kiểm tra luồng log và tính toán vẹn dữ liệu

Truy vấn này được sử dụng nhằm xác nhận rằng log từ Victim Host đã được thu thập và lập chỉ mục thành công trên Splunk Server.

```

index="soc_mini_logs"
| stats count by sourcetype

```

Kết quả truy vấn cho phép kiểm tra nhanh các nguồn log chính như Windows Security Event Log và Sysmon Event Log, đảm bảo pipeline thu thập dữ liệu hoạt động đúng thiết kế.

### C.2. Truy vấn thống kê sự kiện đăng nhập thất bại

Truy vấn này tập trung vào việc phân tích các sự kiện đăng nhập thất bại, là dữ liệu đầu vào quan trọng cho phát hiện hành vi brute-force hoặc đăng nhập bất thường.

```
index="soc_mini_logs"
sourcetype="WinEventLog:Security"
EventCode=4625
| stats count by Account_Name, Source_Network_Address
```

Truy vấn cho phép xác định các tài khoản và địa chỉ nguồn có số lượng đăng nhập thất bại bất thường, làm cơ sở cho việc xây dựng baseline hành vi.

### C.3. Truy vấn phân tích hành vi theo thời gian (Time-based analysis)

Để phát hiện bất thường theo hướng hành vi, truy vấn sau được sử dụng nhằm phân tích tần suất sự kiện trong các khoảng thời gian ngắn.

```
index="soc_mini_logs"
sourcetype="WinEventLog:Security"
EventCode=4625
| timechart span=1m count
```

Sự gia tăng đột biến số lượng sự kiện trong một khoảng thời gian ngắn được xem là dấu hiệu sai lệch so với hành vi bình thường, phù hợp với tiếp cận anomaly-based detection.

### C.4. Truy vấn phát hiện hành vi bất thường dựa trên ngưỡng (baseline deviation)

Truy vấn này thể hiện rõ tư duy AI ở mức cơ bản, trong đó hệ thống so sánh hành vi hiện tại với ngưỡng baseline đã xác định trước.

```
index="soc_mini_logs"
sourcetype="WinEventLog:Security"
EventCode=4625
| bin _time span=5m
| stats count as fail_count by _time, Source_Network_Address
| where fail_count > 10
```

Ngưỡng được lựa chọn dựa trên quan sát hành vi bình thường trong hệ thống. Khi số lần đăng nhập thất bại vượt quá ngưỡng này, hành vi được coi là bất thường.

### C.5. Truy vấn phân tích log Sysmon – kết nối mạng bất thường

Đối với các log Sysmon, truy vấn sau được sử dụng nhằm phân tích các kết nối mạng đáng chú ý liên quan đến hành vi truy cập bất thường.

```
index="soc_mini_logs"
sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"
EventCode=3
| stats count by Image, DestinationIp, DestinationPort
```

Truy vấn này giúp xác định tiến trình và cổng đích thường xuyên xuất hiện trong các kết nối, hỗ trợ việc liên kết hành vi giữa nhiều loại log khác nhau.

#### **C.6. Truy vấn liên kết đa nguồn log (correlation)**

Để thể hiện tư duy SOC nâng cao, các log từ nhiều nguồn được liên kết nhằm tăng độ tin cậy của phát hiện bất thường.

```
index="soc_mini_logs"
(EventCode=4625 OR EventCode=3)
| stats count by EventCode, Source_Network_Address
```

Việc kết hợp các sự kiện đăng nhập thất bại và kết nối mạng cho phép phân tích hành vi ở mức tổng thể, thay vì dựa vào một sự kiện đơn lẻ.

#### **C.7. Truy vấn phục vụ sinh cảnh báo và kích hoạt phản ứng**

Truy vấn cuối cùng được sử dụng trực tiếp để cấu hình alert trong Splunk, là đầu vào cho cơ chế tự động ứng phó.

```
index="soc_mini_logs"
sourcetype="WinEventLog:Security"
EventCode=4625
| bin _time span=5m
| stats count as fail_count by Source_Network_Address
| where fail_count > 10
```

Khi điều kiện truy vấn được thỏa mãn, Splunk sẽ sinh cảnh báo và kích hoạt hành động phản ứng đã cấu hình trước, minh họa bước đầu của mô hình SOAR.

